OSPREYFLOW

# Installation and Administration Guide

OspreyFlow is an open-source intelligence mapping platform for crime analysis, anti-money-laundering, fraud detection, and event monitoring and alerting.

| | |
|---|---|
| Version | 2.02 |
| Date | 2026-11-14 |
| Describes | OspreyFlow v0.5.0 |
| Status | Issued |

## Document control

**Version 2.02** · 2026-11-14 · For OspreyFlow v0.5.0 · Issued

| Version | Date | What changed |
|---|---|---|
| 2.02 | 2026-11-14 | Guests on Entra ID as built (ADR-148 Amendment 17, the audit's ruling 4b). §6a.7: a guest account is refused, in its own words, until an administrator of people turns on *Admit guest accounts* in *Admin › People*; each change audited; admitted, a guest signs in through the same mapping and is given nothing a member with the same token would not be; turned off, every guest is refused at their next request, and a run as a guest owner stops; the untried guest token's shape restated. §9: the setting, and guests marked in the list. Held by `tests/test_guides_cloud_platform.py`. PDF made by the orchestrator at merge. |
| 2.01 | 2026-11-14 | §9: on Entra ID a dashboard identity is registered by its app registration's application id, with no secret shown (ADR-148 Amendment 10), and its refusals quoted as `entra_people.py` words them; the refusal of every dashboard identity, which the code no longer raises, struck. §6a.1: the decommission's backups bucket and its key by a choice with no default, `BACKUPS=keep` or `BACKUPS=destroy`, as the rendered `DECOMMISSION.md` makes it (ADR-148 Amendment 13 decision 6). Held by `tests/test_guide_v052_admin.py`. PDF made by the orchestrator at merge. |
| 2.00 | 2026-11-14 | §6a on search, as ADR-148 Amendment 13 and the render have it: §6a.1, the poc shape makes the platform's OpenSearch domain as the standard shape does (the refusal struck), `postgres-fulltext` makes none, and the Conduit, the workers and the index's two Jobs are given its address; the shared folders in the standard shape, the Ingest root and no staging; §6a.3, `opensearch.tf` in every shape; §6a.8, the restore's step 6 names the backups' CronJobs it resumes, and step 7, the index rebuilt and the drift check, the index not in a set. §6a.2: the index's rebuild and drift check sized as the Conduit (0.5 CPU, 2 GiB, a 4 GiB limit; the poc's CPU limit 2). §6a.5: their way out, ArcadeDB, the managed stores' networks (OpenSearch on 443), S3 and STS. §13: a local restore's last step rebuilds the index from the graph where there is an OpenSearch (no longer "holds no index of OspreyFlow's yet"). Held by `tests/test_guides_cloud_platform_search.py`, which reads the render, `profile.yaml`'s rows and `restore.py`. PDF made by the orchestrator at merge. |
| 1.99 | 2026-11-14 | §6a.1: *Moving to a new release (poc shape)*, platform-b's paragraph checked against the rendered runbooks: `INSTALL.md` run again from the new release's copy, the backup first as the runbook's *Before an upgrade* does it (the report sync stopped too), the Terraform's pull request applied after the new release's render that makes it (step 3, not step 2), the install's own checks named, v0.5.2's install test planned for 25 November and not yet run, going back not rehearsed. §6a.8: the report sync is rendered only with reporting on. Held by `tests/test_guide_6a_upgrade.py`. PDF made by the orchestrator at merge. |
| 1.98 | 2026-11-14 | Scheduled runs on Entra ID as built (ADR-148 Amendment 16, the audit's ruling 1, option A). §6a.7: a run acts as its owner as *Admin › People* holds them, roles and disabled read at each run, clearance, unit and codes as at their last sign-in; refused, in its own words, for a disabled owner, one not held, one not signed in within 24 hours (never counted toward pausing) and a store that cannot be read, never as "could not be reached", each followed by what happens next for its caller; the 24 hours run from the last recorded access (worked from a Friday to a Tuesday); a leaver to be disabled in *Admin › People* too; a stopped watch shows no reason yet. §8, §9.5, §9.11 and §6a.10 to match. Held by `tests/test_guides_cloud_platform.py`. PDF made by the orchestrator at merge. |
| 1.97 | 2026-11-14 | §6a, v0.5.2's reporting on the cloud-platform profile (ADR-148 Amendments 9 to 11): Superset and the report sync rendered when switched on, one copy each in development; Superset signing in with Entra ID as its own registration, its role from the person's rights (a holder of `manage_dashboards` its builder, Alpha); the dashboard identities' app-only tokens (Viewer on a case at most; their grants removed with them); their egress, copies and secrets; the `superset` database beside `ospreyflow` and `litellm`; the line saying reporting is not available on Entra ID removed; Power BI reading the mart as an option. Appendix A: `cloud_platform.claims.superset_client_id`. PDF reprinted alone. |
| 1.96 | 2026-11-13 | §6a.8: what a backup set holds, as ADR-148 Amendment 13 decision 4 and the render have it: the claims part holds, in every shape, the shared volume's published pipelines, model settings and map settings with the map key file, beside the poc shape's Ingest root, and `ospreyflow-backup-claims` runs in every shape; what is not in a set, the tiles and, in the standard shape, the Ingest root on the shared volume; "the shared volume is not backed up" struck. Held by `tests/test_guides_cloud_platform.py`, which reads the rendered values. PDF made by the orchestrator at merge. |
| 1.95 | 2026-11-13 | §6a.8: RDS's point-in-time restore of 35 days, as the Terraform renders it since ADR-148 Amendment 13, the same as the sets' 35, so every set still kept can be restored with its database; the 7 days and the older set's warning struck. Held by `tests/test_guides_cloud_platform.py`, which reads the rendered Terraform. PDF made by the orchestrator at merge. |
| 1.94 | 2026-11-13 | The `cloud-platform` profile against the ADR-148 audit of 13 November (docs' v0.5.2 sweep, part one). §6a.7: nothing acts as its owner on Entra ID, so loads are started by hand: a pipeline's schedule and watched folder, *Run now* in Operations, `ospreyflow run`, a scheduled rule, the daily check for lapsing KYC documents, a list's refresh schedule, a watch's runs and anyone else's rules, hotlists and watches at a load, each as built, with the scheduler's own words and why they never pause a schedule; §6a.10's "marked stopped" struck, as untrue. §6a.5: one S3 read's 1,000 objects, no SSE-KMS bucket, Athena's default catalog alone. §6a.8: RDS's point-in-time restore of 7 days against the sets' 35. §6a.11: two app registrations, not one; volume encryption by the storage class, a new question. §8, §9.5, §9.11: the same Entra limit where each runs as its owner. §9: *People and roles* on Entra ID, each refusal in its own words, no administrator's fallback for clearance or unit. §10a: on a shared platform, a proxied map provider added in Admin has no way out. Held by `tests/test_guides_cloud_platform.py`. PDF made by the orchestrator at merge. |
| 1.93 | 2026-11-13 | §6a: the least connections counted from the copies each shape renders (the owner's ruling: one Superset and one report sync in poc and development), 834 there and 918 in production, so the 1000 leaves 166 and 82 to spare. PDF reprinted alone. |
| 1.92 | 2026-11-13 | §6a: the managed PostgreSQL's `max_connections` set to 1000 in its RDS parameter group (the owner's decisions), not left to the class's default; the least it must allow, 918, with Superset and the report sync (from v0.5.2) and an upgrade in progress, so 82 to spare; the `db_parameter` line for MoJ's RDS module, and that the setting takes effect at creation or the next reboot. PDF reprinted alone. |
| 1.91 | 2026-11-13 | §6a: the managed PostgreSQL rendered as a `db.t4g.large` in every shape, the poc's too (the owner's ruling), whose RDS default allows the 750 connections the install asks for with no parameter group; a smaller class needs one, and the memory to match. PDF reprinted alone. |
| 1.90 | 2026-11-13 | §6a, from R1 (the cloud-platform install's acceptance on kind): the `ospreyflow` command installed by `uv tool install ./cli`; the managed PostgreSQL's `max_connections` of at least 750 (ADR-114 Amendment 43), set in the RDS parameter group; and what a healthy restore's log ends with. PDF reprinted alone. |
| 1.89 | 2026-11-13 | Appendix A: `network.access_key` (the shared key the front proxy asks for, ADR-114 Amendments 41 and 42) and `appearance.banner_text` (the banner's own words, ADR-132 Amendment 7), from the schema (`tools.admin_guide_options`), missed when they were added. PDF reprinted alone. |
| 1.88 | 2026-11-12 | New §6a.9, the model route on a shared platform: the model gateway (LiteLLM), always rendered; an engine as your organisation's own AI gateway (by a token) or Amazon Bedrock in London (by the gateway's own IAM role, no key stored anywhere), with `kind`, `auth` and `region`, London alone and a model's own id; what is refused, in words; `gateway.tf`'s role, policy and service account, and what the platform team applies; the gateway's own way out, its engines' hosts and STS; what *Admin › Models* allows and refuses, in its own words; for a newly declared Bedrock engine, the Terraform before the new values, since only it makes the gateway's service account (also in §10.1); Laurium's key cross-referenced; what is not yet tried against AWS or your own gateway (ADR-135 Amendments 4, 7 and 8). §6a.5: an engine removed in *Admin › Models* keeps its host open while `osprey.yaml` declares it. *Coming* and the questions for the platform's team renumbered 6a.10 and 6a.11; nothing of the model route was listed as coming. PDF made by the orchestrator at merge. |
| 1.87 | 2026-11-12 | §9.1: the guides from Home. Home links this guide under Admin's card, the user guide under the Glass's and the developer guide under the Ingest Studio's, each only for someone whose roles open that place, and the Conduit refuses anyone else (ADR-145 Amendment 10). A new guide comes with a new image: on Small and `cloud-platform` with a release's images, on Lite with `ospreyflow start --build`. PDF made by the orchestrator at merge. |

| Version | Date | What changed |
|---|---|---|
| 1.86 | 2026-11-12 | §6a, the shared Kubernetes platform, brought up to date. §6a.1: the example `osprey.yaml` with Entra ID's settings and networks; the OFFICIAL-SENSITIVE ceiling set by the profile; the proof-of-concept shape; the render making its own folders; the install and decommission runbooks and the decommission check, not yet run on a cluster; reporting not available on this profile; Laurium, the extraction engine, as its own pod, image and repository, called by the Conduit alone and reached by no screen yet (ADR-148 Amendments 5 and 8; ADR-135 Amendments 6 and 9; ADR-142 Amendment 8 decision 9). §6a.2: the proof-of-concept shape's CPU limits, the backup and restore Jobs' sizes, and the totals from renders. §6a.3: the Terraform for declared S3 and Athena sources and for the backups; what each pod reads, and which service account it runs as. §6a.4: third-party images copied by their digest. §6a.5: each pod's own way out and way in, on single ports; S3 buckets and Athena workgroups declared for connections (ADR-140 Amendment 21). §6a.6: what the policy check refuses. §6a.7: the access tokens' version, the API's id URI and a claims-mapping policy, from which the issuer, audience and signing keys follow; the guest check; the way back in with the new values installed. New §6a.8: backups and restore (ADR-148 Amendment 7), with the shared volume not backed up. §6a.9, what is coming, and §6a.10, the questions for the platform's team, renumbered and extended. §10.1: the extraction engine shown in *Admin › Models*, and how to change it; one order for a change needing new values and Terraform. |
| 1.85 | 2026-11-12 | Sign-in on `cloud-platform` through Entra ID, as built (ADR-148 Amendment 8, P10 part 2). §6a.7: `cloud_platform.claims` in `osprey.yaml`, `groups_claim` described; RS256 alone, 60 seconds' leeway, the signing keys kept, fetched by one request at a time and again at most once in five minutes for an unknown key, held an hour through an outage, Entra unable to give keys a 503 in words; roles in the deployment's Postgres by tenant and `oid`, a person added by object id, *Disable*; the first administrators, and the way back in when nobody can manage people (audited); locking everyone out refused, counting only people who have signed in; a clearance or unit read over a day ago not trusted for a transfer or an alert; the Glass's words when the account cannot be read; a service identity's app-only token. §6a.8: sign-in struck, what is still to come on Entra kept. Keycloak struck from §6a (its pod, group 0, resources, secrets, image, egress and `id.` door; reporting's `bi.` door refused); Entra's sign-in host in the egress list; §6a.9's group 0 question struck. Appendix A: `cloud_platform.claims`, from the schema; `tls_secret` names the Glass's name alone. |
| 1.84 | 2026-11-12 | Appendix A: `models.extraction_engine`, Deep read or Laurium, Laurium on the `cloud-platform` profile alone and its preset there when left unset (P12 part 2, ADR-135 Amendment 9). §6a.2: Laurium's own service, rendered with that preset, and the totals said to be Deep read's. |
| 1.83 | 2026-11-11 | Appendix A from L1.9 part 2 (ADR-140 Amendment 21): `cloud_platform.connector_sources`, the S3 buckets and Athena workgroups a cloud-platform deployment declares; a constrained list's items named by their type. |
| 1.82 | 2026-11-11 | Appendix A from P7b as merged (ADR-148 Amendment 5): `cloud_platform.shape` (standard or poc, poc a development namespace's only); `cloud_platform.connector_hosts` as host or host:port, a bare host meaning 443, so a SQL connection names its port here; and `deployment.highest_marking`'s cloud-platform default, OFFICIAL-SENSITIVE. |
| 1.81 | 2026-11-11 | §6a after its review. §6a.7: the token check, not the Conduit, is what is built, since neither the Conduit's settings nor the profile pass it a mapping yet; the mapping's shape said not to be an `osprey.yaml` block; what fails to load in full (a GUID in lower case, a list in a clearance or unit table, an empty table, scope or `groups_claim`); `sub` required too; a group overage refused only where a group table is used, and its remedy; `acct` optional; guests among the shapes untried against a real tenant. §6a.8: the first administrator named in the settings, refused at render when there is none; Entra's egress line struck (no record yet decides it). §6a.2: room above the totals for set-up jobs and rolling updates. §6a.3: `gateway.tf` makes the gateway's service account too. §6a.5 and §10.1: an engine's way out also needs the new values installed (`helm upgrade`). §6a.6: three synthetic deployments. |
| 1.80 | 2026-11-11 | §6a brought into line with P11 part 2 as merged (76980f2, ADR-135 Amendment 8): the model gateway rendered by default on the `cloud-platform` profile, not only while an engine is enabled, so development's requests come to about 4 CPU (3.95, from a render of the synthetic development deployment) and its memory limits to about 34 GiB; `gateway.tf`, the gateway's own IAM role for Bedrock in eu-west-2 alone, while a Bedrock engine is declared; the gateway's service account (`default`, or `ospreyflow-gateway` under that role); an engine's host allowed out only while it is declared at render; struck from *Coming*. |
| 1.79 | 2026-11-11 | New §6a.7, signing in through Entra ID as the Conduit's token check builds it (P10 part 1, ADR-148 Amendment 6): the claim mapping, one source per claim, by claim or group table; the tenant, issuer, audience, client and scope pinned; a person keyed by `oid`; what is refused, app-only tokens and guests among it; roles never read from the token; the token shapes not yet tried against a real tenant. Not yet reachable from the profile: §6a.8 lists the profile's side as *coming* (the mapping in `osprey.yaml`, Keycloak not rendered, *Admin › People*'s roles in the deployment's Postgres by tenant and `oid`, no scheduled run as its owner and no Superset roles on Entra at first). Coming and the questions renumbered 6a.8 and 6a.9. |
| 1.78 | 2026-11-11 | §10.1: on the `cloud-platform` profile *Admin › Models* refuses an engine the render did not make (declare it, re-render, have the platform team apply the Terraform); `secrets.irsa.gateway_service_account`; Bedrock signs in by the gateway's own IAM role (P11 part 2, ADR-135 Amendment 8). |
| 1.77 | 2026-11-11 | Appendix A: `models.provider(s).kind`, `auth` and `region`, the client's gateway and Bedrock by the IAM role on the `cloud-platform` profile (P11 part 1, ADR-135 Amendment 7). |
| 1.76 | 2026-11-11 | §6a's re-check: the policy check on your own settings in its working form, which needs Docker (Helm's own image) and is unrun until P7b's kind run; the example's map said to be empty on this profile; a named deployment's `terraform` folder; the chart, not the render, makes the two Calico policies (`default.`); which commands ran, and where. |
| 1.75 | 2026-11-11 | §6a after its two reviews, its render commands run as written from `OspreyFlow_Core`: the example's required `map:` section; make the `terraform` folder before the first render (a known issue); the unpinned render first, never installed, then `ecr.tf`, the push with `--from`, and the pinned render; the third-party images copied by tag (a known issue); no CPU limit, so a LimitRange's default and a quota on `limits.cpu` both apply; who reads which keys of `ospreyflow-secrets`, by the blanks; the Terraform state holds every secret; OpenSearch made and unused; Keycloak's group 0 and the identity step not shown; the policy check's fixtures, and `tools.cp_policy_check --config`; the ingress by backend; the coming list and three more questions for the platform's team. |
| 1.74 | 2026-11-11 | The `cloud-platform` profile as built (P7, ADR-148 Amendment 1), docs' D2c part 1. New §6a: what is rendered and what the platform gives instead; the namespace's requests and limits per component (about 27 GiB and 3.7 CPU in development, 70 GiB and 9.7 CPU in production, unmeasured); the Terraform and the secrets each component reads, by name; images into ECR with `ospreyflow images push`; the egress list, and narrowing the managed networks; `make cp-policy-check`; what is *coming* (Entra ID, backups and restore, the runbooks, the gateway by default, the extraction service, the shared folders, the profile's own OFFICIAL-SENSITIVE ceiling); the questions for the platform's team. §1 points to it. |
| 1.73 | 2026-11-11 | The commands table: `ospreyflow images push`, for the `cloud-platform` profile. Appendix A: the `cloud-platform` profile and its `cloud_platform` settings (P7). |
| 1.72 | 2026-11-11 | The second look at 1.71. §9.5: lists imported by a Data Engineer, since the Ingest Studio needs `edit_pipelines` and an Administrator does not hold it; the Studio's *Import a list* templates for OFSI, the UN list and OpenSanctions in its own words, in place of the former subscribe form; a list's schedule under *Manage*, *Schedule* |
| 1.71 | 2026-11-11 | Rules' L2.11 as built (ADR-146 Amendment 6). §9.4: who writes a rule and makes it live, by right and role (an Analyst: a Rule author does not hold `deploy_rules`, and a Data Engineer, who does, cannot open Rules and Monitoring and reads the queue's counts only); no whole-deployment rule; after updating, Rule author assigned, `migrate_rules_to_datasets` (its `--dry-run` first, the original retired, a dataset with no home case reported and its rule left running until a second run), a rule running as its author while they hold Write rules or Deploy rules; whom a rule's alerts reach. §9.5: screening lists imported, mapped and refreshed in the Ingest Studio's Sources, shown read-only under What raises alerts; a refresh's match from a rule kept just for its author is medium, as a Watched pattern. §9.6: a second person for making a rule live where the dataset asks, both of them Analysts. |
| 1.70 | 2026-11-11 | §13's synced-folder warning names a Windows home folder under WSL's `/mnt/c/` in words. |
| 1.69 | 2026-11-10 | Describes v0.5.0. No change to its content. |

| Version | Date | What changed |
|---|---|---|
| 1.68 | 2026-11-10 | Rules' L2.10 and platform-b's P6 as built, no longer *coming*. §9.8: a rule's alerts routed to one team (*‹Team› only*), read by its members and the home case's Authors, enforced in the query; the lead's or cover's *Give to* and *Suppress until…*. §10a: the case map's *Gazetteers in this case's dataset*, with *Add* and *Remove* for `run_pipelines` |
| 1.67 | 2026-11-10 | §8's commands: `ospreyflow release export` and `import [--dry-run]` (a dataset's release as a YAML bundle) and `ospreyflow run` (an orchestrator's trigger as a service identity), the studio lane's L1.7 (ADR-140 Amendment 9 decision 4, ADR-141). |
| 1.66 | 2026-11-10 | Appendix A: `deployment.highest_marking`, the deployment's marking ceiling (studio-b's L1.10, ADR-148 Amendment 2): a load or an import marked above it is refused before anything is written. |
| 1.65 | 2026-11-10 | §13: *Where sets are* names the checkout as the folder holding `OspreyFlow_Core`, since the guide ships in Core and never names the build folder. |
| 1.64 | 2026-11-10 | The backups folder as built (platform-b's P5b; ADR-114 Amendments 37 and 38). §13: every install's set in `<backups folder>/<deployment>/`, the folder asked at setup (`folders.backups`, the Folders screen's **Backups folder**, the prompt); new *Where sets are, and cleaning them up*, *A synced folder* and *Cleaning up*; Small on your own server's `server.backups` its older name. §1a.1, §5a.3, the files table, §14's update row and appendix A's `components.storage.backups` say where sets now go. §5: the answers file's `folders.backups`. No longer coming; appendix A's row is the schema's own. Admin's L2.5b and L2.5c as built: §9.9, *Disable…* lists and transfers views, boards, link-type proposals and drawn items' watches, the recipient cleared to the item's marking (ADR-145 Amendment 9) and holding its case's level, and refuses to disable someone who owns items you may not see; §9.10, Admin's own *Delete ‹case›'s layer now* after its dry run. |
| 1.63 | 2026-11-10 | Admin's L2.7 and platform's P5 as built. §9.1: Proposed types removed, Connections' four kinds, Grading scheme built. §9.2: the role tips, *What each role and level lets a person do*, the refusal that names the roles, `write_sql_transforms` given on its own. §8: `map build --unit`. §10a: the unit the place names are held by, and a dataset's gazetteers (on screen, coming). |
| 1.62 | 2026-11-10 | §9.10: Admin's screen offers the dry runs, though its delete route exists, named. |
| 1.61 | 2026-11-10 | Promotion as built (case lane's L3.4). §9.10: a removed case's layer merged or deleted by the dataset's Authors in the Ingest Studio, Admin's dry runs. §9.11: promotions waiting for review, listed and overdue. §9.2: its words are copies of `help/roles.ts`, held to it by a test. §9.9: Disable's confirming button. |
| 1.60 | 2026-11-09 | Brought up to the product as built (docs lane, D2a). §9.1: Admin as a place of its own, its sections and each one's right, the coming ones said so. §9.2: the roles in the Glass's own words, the places each opens, every right in plain words, custom roles and the Super user. §9.3: the invite form as built. §9.5 and §9.6: where lists and influencers now live. New §9.8 teams and leads, §9.9 Disable and what a person owns, §9.10 datasets, their Authors and linked cases, §9.11 Operations and Audit. §10.1: Admin › Models. New §10a: Admin › Maps. §12: the Alert monitoring board in the Glass. §13: backups to a folder named at setup, coming. The architecture has its own guide now. |
| 1.59 | 2026-11-09 | §7: `grading.scheme`, the scheme drawn items are graded in (a built-in scheme or a scheme file). §8: `ospreyflow grading change`, its dry run and its change (ADR-143 decision 11 and Amendment 6). Appendix A regenerated: the `grading` section. |
| 1.58 | 2026-11-09 | Appendix A regenerated: `connectors.private_hosts`, the private hosts or networks an operator admits the Studio's SQL and API connectors to, and `connectors.secrets`, the connection secrets only the Conduit is given (ADR-140 Amendment 15). |
| 1.57 | 2026-11-08 | §8: `ospreyflow map list`, `map verify`, `map prefetch` and `map build` (ADR-147). Appendix A regenerated: a WMTS provider's `credential_param`. |
| 1.56 | 2026-11-08 | Appendix A regenerated from the deployment schema: `components.source_path`'s description, reworded without a build-calendar note. |
| 1.55 | 2026-11-05 | Describes v0.4.12 (v0.4.11 was not released). No change to its content. |
| 1.54 | 2026-11-05 | Describes v0.4.11. No change to its content. |
| 1.53 | 2026-11-05 | The owner's rulings (build order step 33; ADR-112 Amendment 3, ADR-114 Amendment 33 "Step 33"): §5a.1, someone whose email an account holds can be joined to that account in Admin → People, or the account removed; joining by email (`sign_in.organisation.trust_email`, off by default) and its account-takeover risk; §7 the answer; §8 what `repair-sign-in` now also does; §9.1 and new §9.7, removing someone and joining an organisation account; §16 the refusal's new answers, an empty *Refused organisation sign-ins*, the Conduit needing `view-events`, a refused removal, and the joining-by-email warning. Appendix A: `governance.organisation_provider.trust_email`. |
| 1.52 | 2026-11-04 | The owner's ruling (build order step 29; ADR-114 Amendment 34): §14, an offline bundle carries one platform's images, `linux/amd64` unless `ospreyflow update --make-bundle FILE --platform linux/arm64` names the other, from any machine; any other platform is refused, and `update --from` refuses a bundle for another platform than its machine's, in words, before anything is checked or loaded. |
| 1.51 | 2026-11-04 | The owner's rulings on sign-in (build order step 28): §5a.1, the welcome page's button names the organisation's provider by `sign_in.organisation.label` (ADR-115 Amendment 5), and someone whose email an OspreyFlow account already holds is told so in words and never joined to it (ADR-114 Amendment 33); §8, `repair-sign-in` also gives the workspace's client no refresh token (ADR-050 Amendment 2) and registers the organisation's first sign-in; §9.1, Admin → System's **Acting for people** says when the Conduit cannot act for people and to run `ospreyflow repair-sign-in` (ADR-114 Amendment 36); §16, that line, an arrival whose email is held, and windows that ask to sign in again after about half an hour left alone (a window renews only after the person has done something, ADR-050 Amendment 2). Appendix A: `governance.organisation_sign_in` and `governance.organisation_provider.label` name the button. |
| 1.50 | 2026-11-04 | The owner's ruling (ADR-099 Amendment 11; build order step 27), "no role, no list": §5a.1 and §9.2, a person holding no role is told no dataset's name or id, even when their unit is set before a role; Home says *No cases to show* when they hold no case. |
| 1.49 | 2026-11-04 | As found on the first server (ADR-114 Amendment 35 point 7): §13 and §14, Valkey's data was inside its container and is now moved too; a move that is refused puts back every file the command wrote, so `ospreyflow start` runs the deployment on its old data, and its words say so; the move checks each store apart from the deployment's own containers; a restore starts the identity provider again after PostgreSQL. §16 the move's refusal, and a restore refused with "could not authenticate to Keycloak: 500". |
| 1.48 | 2026-11-04 | The owner's ruling (ADR-114 Amendment 35; build order step 26): the stores keep their data in named volumes. §8 `uninstall --keep-data` now keeps data a later install finds; §13 where each store's data is kept, what a backup reads, and OpenSearch; §14 the one-time move of an existing deployment's data, its words, and what a failed move does to an update; new §14.1 removing the old volumes; §16 a move that is refused. |
| 1.47 | 2026-11-04 | The owner's ruling (ADR-127 Amendment 46; build order step 25): §1a and §11, the Prison Intelligence pack handles post-ingest resolution itself — an install that chooses it writes `components.post_ingest_resolution: false`, and `ospreyflow demo add prison-intelligence` refuses, in words, while it is on. |
| 1.46 | 2026-11-04 | The owner's ruling (ADR-114 Amendment 33; build order step 25): §5a and §7, `server.certificate` and `server.key` are required, and an answers file without them is refused in words; the doctor no longer checks port 80 for a certificate the proxy would obtain itself. |
| 1.45 | 2026-11-04 | Found on the first server (ADR-114 Amendment 33; build order step 25): §4 and §5a, the install waits for the extraction model to download, says so with its size, and only then says it is installed. |

| Version | Date | What changed |
|---|---|---|
| 1.44 | 2026-11-04 | Describes v0.4.10. No change to its content. |
| 1.43 | 2026-11-04 | §5a.4: on a GPU the model stays loaded (`OLLAMA_KEEP_ALIVE=-1`), so the first question after a pause does not wait for it to load. |
| 1.42 | 2026-11-04 | Describes v0.4.9. No change to its content. |
| 1.41 | 2026-11-04 | The owner's ruling (ADR-132 Amendment 5): §1a, the GOV.UK service's name is shown in the page title on every page, the sign-in page's included; no band under the GOV.UK header names it any more. Appendix A: `appearance` and `appearance.service_name` say the same. |
| 1.40 | 2026-11-04 | As measured and found on the first server (ADR-135 Amendment 1, ADR-114 Amendment 33): §5a.4 the model server's KV cache at q8_0 with flash attention on a GPU, the measured times, the doctor's 14 GiB for the 14b (was 12), and `apply` fetching a newly chosen model; §13 the object store copied as the account that runs the backup, and a failed backup's set it cannot remove marked incomplete; §16 a backup refused with "Permission denied", and Ask failing after the extraction model changed. |
| 1.39 | 2026-11-04 | Found on the first server (ADR-114 Amendment 33): §5a the Ingest Studio's upload folder, given to the Conduit's user (uid 10001) before anything starts, and never writable by every account; §16 an upload or a demo pack refused with "Permission denied" on Linux. |
| 1.38 | 2026-11-04 | Describes v0.4.8. No change to its content. |
| 1.37 | 2026-11-04 | Describes v0.4.7. No change to its content. |
| 1.36 | 2026-11-04 | The owner's ruling (ADR-114 Amendment 33): the first administrator holds the Admin and the Analyst roles from the start, whether or not demo packs load, so the cases they author open for them. §1a and §11 no longer ask anyone to give them the Analyst role; §5 and §5a say which roles the account is made with; §9.2 says so too, and that an `admin` made by v0.4.6 or earlier needs the Analyst role added. |
| 1.35 | 2026-11-04 | Found installing Small on the first server of its own (ADR-114 Amendment 33): §1a and §11 a demo pack on a deployment with no demo accounts — its case's Author is the first administrator, in their own unit, with no Editor, and the Admin role does not open a case's graph until someone holds the Analyst role; §5a the answers' `demo_packs` load after the first administrator exists, the installing account's umask does not matter, and `ca` must be readable by every account; §13 a fresh deployment's first backup, its empty items, and a failed backup leaving no partial set; §16 an unreadable CA. |
| 1.34 | 2026-11-04 | The local engine on an NVIDIA GPU (ADR-135 Amendment 1): §2.2a the NVIDIA driver and Container Toolkit, installed by the server's administrator; §2.4 and §5a the doctor's GPU checks; §5a the answers file's `server.gpu`; new §5a.4, what the GPU changes (the model server alone reserves it; the 14b extraction model unless one is named), what is checked before anything starts, and Lite on a Linux computer; §7 `server.gpu`; §16 a refused GPU. Appendix A: `resources.gpu`, and `models.extraction`'s default on a GPU. |
| 1.33 | 2026-11-04 | Describes v0.4.6. No change to its content. |
| 1.32 | 2026-11-04 | §5a: a `DOCKER-USER` rule that matches only arriving connections (`--ctdir ORIGINAL`), found on the first Linux server. |
| 1.31 | 2026-11-04 | Describes v0.4.5. No change to its content. |
| 1.30 | 2026-11-03 | Small on your own server, second part (ADR-114 Amendment 33 drop 2): §2.2a the backups folder and what the organisation's sign-in needs; §5a the answers file's `server.backups`, `server.memory_gib` and `sign_in`, and the doctor's new checks; new §5a.1 sign-in through the organisation's identity provider (Entra ID: the application, its two addresses, its client secret, assignment, the route out; no role until an administrator grants one); new §5a.2 memory sized to the server; new §5a.3 backups to `server.backups` with a cron line; §7 the answers' settings; §8 `repair-sign-in` restores the organisation's sign-in and gives a Small no demo accounts; §13 and §14 backup and `update` on this kind of Small; §16 the organisation's sign-in and the backups folder. Appendix A: `governance.organisation_provider`, `resources`. |
| 1.29 | 2026-11-03 | Small on your own server (ADR-114 Amendment 33, first part): §1 a fourth column and the organisation's own certificate under "HTTP or HTTPS"; new §2.2a, its prerequisites; §2.4 `ospreyflow doctor --mode small --config install.yaml`; new §5a, installing it — the answers file's `server:`, the three names and the one-label wildcard, what is checked before anything starts, port 443 alone, the first administrator, renewing the certificate, and what is not built yet; §5.2's refusal names all three ways; §7 `server`, `admin_email`, `sign_in`; §8.1 what it publishes; §16 the certificate's refusals and a network that cannot connect. Appendix A: `network.tls`, `network.redirect_http`, `network.listen_address`. |
| 1.28 | 2026-11-03 | §8: `ospreyflow repair-sign-in` also sets the Conduit's own client secret again, so a deployment whose stores were wiped can act for its people again. §16: rules that say "the rule's deployer could not be resolved", a hotlist that stops, and a list refresh that re-screens no one. |
| 1.27 | 2026-11-03 | "How OspreyFlow is built": a level 0 diagram (who uses OspreyFlow and what it talks to), a level 1 diagram (every component with the technology it is built on, and what each mode runs on), and a new section, "The interfaces, and what crosses each", giving each interface's direction, protocol, what crosses it and what guards it. |
| 1.26 | 2026-11-02 | Checked against the code end to end (build order step 10). §10: Ask to search carries the case's handling and datasets, so the analyst's engine choice applies to it as to Ask the case; it no longer always runs on the local engine. |
| 1.25 | 2026-11-02 | §9.2: the right to manage connection-strength influencers, held by the Analyst and Admin roles. §9.6: approving an installation-wide influencer version, a second person's decision; a case's own influencers need none. |
| 1.24 | 2026-11-02 | §1, "HTTP or HTTPS": Lite now answers on this computer only — every port it publishes is bound to `127.0.0.1`, the Conduit's own port included — so other machines cannot reach it; Small and Enterprise must have an `https://` address, and `osprey.yaml` refuses a plain-HTTP one; a gov.uk address is refused for Lite. §8.1 says the same. |
| 1.23 | 2026-11-02 | §1: a note, "HTTP or HTTPS" — Lite is plain HTTP on a `localhost` address and has no HTTPS option, and its port is published on every network interface, so it is never opened to a network; Small and Enterprise are HTTPS with a certificate Caddy obtains and renews, port 80 only for the certificate and the move to HTTPS; the managed services over TLS; a gov.uk service over HTTPS. §8.1 links to it. |
| 1.22 | 2026-11-02 | New §1a, Choosing a starter: a theme and a domain at install (`--starter`, and the guided page's first screen), the GOV.UK service's name, several deployments side by side (`--name`, `ospreyflow deployments`, `ospreyflow switch <name>`) and how the checkout's own deployment fits in, and a public dataset of your own choosing (`ospreyflow demo add public`) with the VAST Challenge catalogue and its terms. §7: `starter`, `appearance`, `demo_accounts`. §8: `ospreyflow deployments`, `ospreyflow starters`, `--name`. §11: the `cyber-intrusion` pack, and where each starter's demo comes from. Appendix A: `deployment.graph_port`. |
| 1.21 | 2026-11-01 | §9.5: a sixth connector, the FCDO's UK Sanctions List (the XML file, Open Government Licence v3.0); the OFSI connector marked as reading a closed list, on the Lists tab and in the subscribe form. §12: the `closed` section's labels are the five closing reasons as stored. |

| Version | Date | What changed |
|---|---|---|
| 1.20 | 2026-11-01 | §9.5: the UN and OpenSanctions connectors are marked "licence not confirmed" and read OspreyFlow's synthetic lists only, whatever this device's exceptions admit; the refreshes' counts of customers re-screened and alerts raised are your own unit's. |
| 1.19 | 2026-11-01 | §9.5: a list's refresh schedule, set in Monitoring → Lists and run as the person who set it. §9.6: approval rights — a second person for a rule for the whole deployment and for closing a high-severity alert, and who holds the right to approve; whole-deployment rules live before this version wait for approval after upgrading. |
| 1.18 | 2026-11-01 | §9.5: screening lists — subscribing to a list through its connector, each list's licence, the rule on real lists, and the refresh (*Refresh now*, `python -m scripts.refresh_screening_list`), which re-screens customers against the changed entries only. |
| 1.17 | 2026-11-01 | §12: the monitoring board, and the four monitoring sections the feed carries (`raised_by_rule`, `closed`, `time_to_close`, `hotlist_matches`). |
| 1.16 | 2026-11-01 | §9.4: monitoring, and whom a hotlist's alerts reach (`monitoring.hotlist_audience`, `hotlist_audience_editable`). Appendix A: the `monitoring` settings. |
| 1.15 | 2026-11-01 | §9.1: the Datasets tab. §10: a provider's privacy-contract mark (`privacy_contract`, `contract_reference`); each dataset's egress (`none`, `contracted`, `any`), set in Admin → Datasets and audited; every dataset is `none` after upgrading, so hosted engines receive nothing until an administrator changes one. Appendix A: the two new provider settings. |
| 1.14 | 2026-11-01 | §8: `ospreyflow apply`, and a new §8.3, "Changing a setting". `deployment.env` is readable by its owner alone. §10: a provider enabled on a running deployment, and key entry on the guided install's Models screen. |
| 1.13 | 2026-11-01 | §10 rewritten for several model engines: providers, defaults, labels, keys as `OSPREY_MODEL_KEY_<NAME>`, and what may leave. §8: `ospreyflow models`, `models key` and `models remove-key`. Appendix A: `models.providers`, `models.defaults` and a provider's `label`. |
| 1.12 | 2026-11-01 | The opening says what OspreyFlow is for: intelligence mapping, for crime analysis, anti-money-laundering, fraud detection, and event monitoring and alerting. |
| 1.11 | 2026-11-01 | §8: `ospreyflow switch`. Appendix A: `deployment.name`, the `appearance` settings (the GOV.UK look), and relative storage paths. |
| 1.10 | 2026-10-29 | §11: the Prison Intelligence pack's rehearsal commands are in `DEMO_GUIDE.md`, not the user guide. |
| 1.9 | 2026-10-29 | §11: the two Prison Intelligence packs, the demonstration case and its scale cohort. |
| 1.8 | 2026-10-28 | Describes v0.4.0. No change to how it is installed, updated or looked after. |
| 1.7 | 2026-10-27 | Appendix A: `components.post_ingest_resolution`, whether a load queues entity resolution afterwards. |
| 1.6 | 2026-10-18 | §11: the HMP pack as a prison intelligence network, and adding it again after an update. |
| 1.5 | 2026-10-15 | A cover page, contents, a list of figures, and this version history. |
| 1.4 | 2026-10-15 | §16: a model download that stopped with `rename …-partial …`, and how to finish it. |
| 1.3 | 2026-10-15 | §11: the Enron email corpus as an optional download, with its safeguards. |
| 1.2 | 2026-10-14 | `ospreyflow repair-sign-in`; no step sends an operator to `make`. |
| 1.1 | 2026-10-14 | §14 rewritten: which installs `update` moves, and checking for and moving to a release. |
| 1.0 | 2026-10-14 | First issue in the install package, with screenshots. |
| 0.4 | 2026-10-14 | Enterprise built from your own computer: `install --mode enterprise --cloud`. |
| 0.3 | 2026-10-14 | Enterprise on Kubernetes: the cluster's namespace, storage classes and managed services. |
| 0.2 | 2026-10-14 | The guided install page ships with each release. |
| 0.1 | 2026-10-13 | Lite and Small, with every setting taken from the deployment's own schema. |

## Contents


How OspreyFlow is built 10
The interfaces, and what crosses each 11
1. Choosing a mode 13
HTTP or HTTPS 13
1a. Choosing a starter 13
1a.1 Several deployments side by side 14
1a.2 Adding a public dataset 14
2. Before you start 15
2.1 Lite 15
2.2 Small 15
2.2a Small on your own server 15
2.3 Enterprise 15
2.4 Checking a machine: ospreyflow doctor 16
3. Getting the ospreyflow command 16
4. Installing Lite 16
4.1 The guided page: ospreyflow install --gui 16
5. Installing Small 16
5.1 What is made in your account 17
5.2 On the server, by hand 17
5a. Installing Small on your own server 17
5a.1 Sign-in through the organisation's identity provider 19
5a.2 Memory 19
5a.3 Backups 20
5a.4 The local engine on an NVIDIA GPU 20
6. Installing Enterprise 20
6.1 What is made in your account 21
6a. Deploying into a namespace on a shared platform: cloud-platform 21
6a.1 What is rendered 21
6a.2 What the namespace asks for 23
6a.3 The namespace's Terraform, and the secrets each component reads 24
6a.4 Images into the namespace's registry 25
6a.5 What each pod may reach 25
6a.6 The policy check 26
6a.7 Signing in through Entra ID 27
6a.8 Backups and restore 29
6a.9 The model route 30
6a.10 Coming 31
6a.11 Questions for the platform's team 32
7. The answers file, install.yaml 32
8. Running it 33
8.1 Addresses 34
8.2 Where things are 34
8.3 Changing a setting 34
9. People and accounts 34
9.1 The Admin place 35
9.2 Roles 36
9.3 Inviting someone 37
9.4 Rules and alerts: who writes a rule, and whom its alerts reach 37
9.5 Screening lists: subscribing, licences and the refresh 38
9.6 Approval rights: a second person 39
9.7 Removing someone, and joining an organisation account 39
9.8 Teams and leads 40
9.9 Disable, and what a person owns 40
9.10 Datasets, their Authors and linked cases 40
9.11 Operations and Audit 40
10. Models 41
10.1 Models in Admin 41
10a. Maps 42
11. Demo packs 42
12. Dashboards 43
The monitoring board 44
13. Backup and restore 45

14. Updates 45
14.1 Removing the old store volumes 47
15. Scheduled and watched pipelines 47
16. When something is wrong 48
Appendix A — every osprey.yaml setting 49

## List of figures

Figure 1 — Level 0: the people who use OspreyFlow, its three tiers joined by four ports, and the identity provider, reporting, data in and the optional outside services beside it ..... 10
Figure 2 — Level 1: every component by tier with the technology it is built on, the ports between the Conduit and the Vault, identity, reporting, and what each mode runs on ..... 11
Figure 3 — Admin → People and roles: each person's roles, with Access, Disable and Reset sign-in ..... 35
Figure 4 — A person's access opened under their row: clearance, unit and handling codes ..... 37
Figure 5 — Admin → Demo packs: what each pack shows, where it was loaded, and the command for the rest ..... 43
Figure 6 — Admin → Dashboards: registering a dashboard's account and seeing when it last pulled ..... 44
Figure 7 — Superset at bi.: the boards and charts built on the reporting figures ..... 44
Figure 8 — Admin → System: each component's health, the models in use, the version, and the last update check ..... 46
Figure 9 — Admin → Schedules and runs ..... 47

OspreyFlow is an open-source intelligence mapping platform for crime analysis, anti-money-laundering, fraud detection, and event monitoring and alerting.

For whoever installs OspreyFlow and looks after it: **Lite** (one computer), **Small** (one cloud server on the cloud's managed services, or one server of your own with every store on it) and **Enterprise** (a Kubernetes cluster on the cloud's managed services). It describes what is built, and says plainly where something is not yet.

The other guides in this folder are the user guide (user-guide.pdf), for analysts, and the developer guide (developer-guide.pdf), for data engineers. Appendix A, every `osprey.yaml` setting, is made from the deployment's own schema, and is checked against it on every change.

---

## How OspreyFlow is built

The architecture guide (architecture-guide.pdf) describes it in full, for a reader deciding whether it fits; this is what an administrator needs.

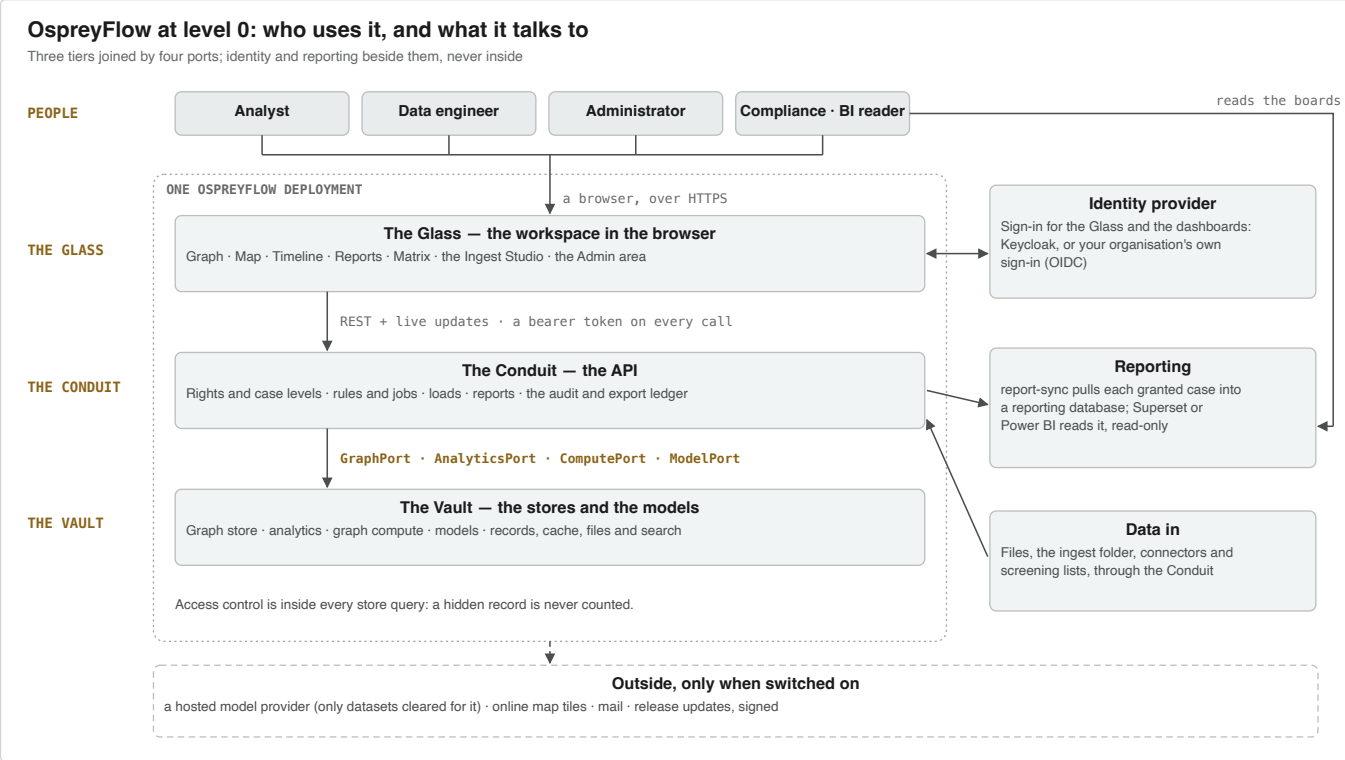



Figure 1. Level 0: the people who use OspreyFlow, its three tiers joined by four ports, and the identity provider, reporting, data in and the optional outside services beside it

Three tiers; everything that passes between them crosses one of four typed ports:

| Tier | What it is |
|---|---|
| **The Glass** | The browser workspace, one web application with four places: the Glass itself (the graph, map, timeline and figures), the Ingest Studio, Rules and Monitoring, and Admin |
| **The Conduit** | The API (FastAPI). Every request is checked against the person making it: access control is applied inside each query to the stores, never after |
| **The Vault** | The stores: the graph store (ArcadeDB), the analytics database (DuckDB inside the Conduit, or ClickHouse shared by several Conduits), search (OpenSearch, or PostgreSQL full-text), PostgreSQL, the object store, and the models |

| Port | What passes through it |
|---|---|
| GraphPort | Typed traversal of the graph, with the person's clearance and handling injected into it |
| AnalyticsPort | Events, trends and histograms |
| ComputePort | Graph algorithms: centrality, communities, ownership chains |
| ModelPort | Extraction, vision, transcription and embedding, through the LiteLLM gateway |

Two narrower ports sit beside them: the media store, for content files (an S3-protocol store — SeaweedFS or AWS S3 — or Azure Blob), and the recognition port.

The level 1 diagram names the technology in each component. Versions are those the release pins; Small and Enterprise use the cloud's managed services where the diagram's last row says.

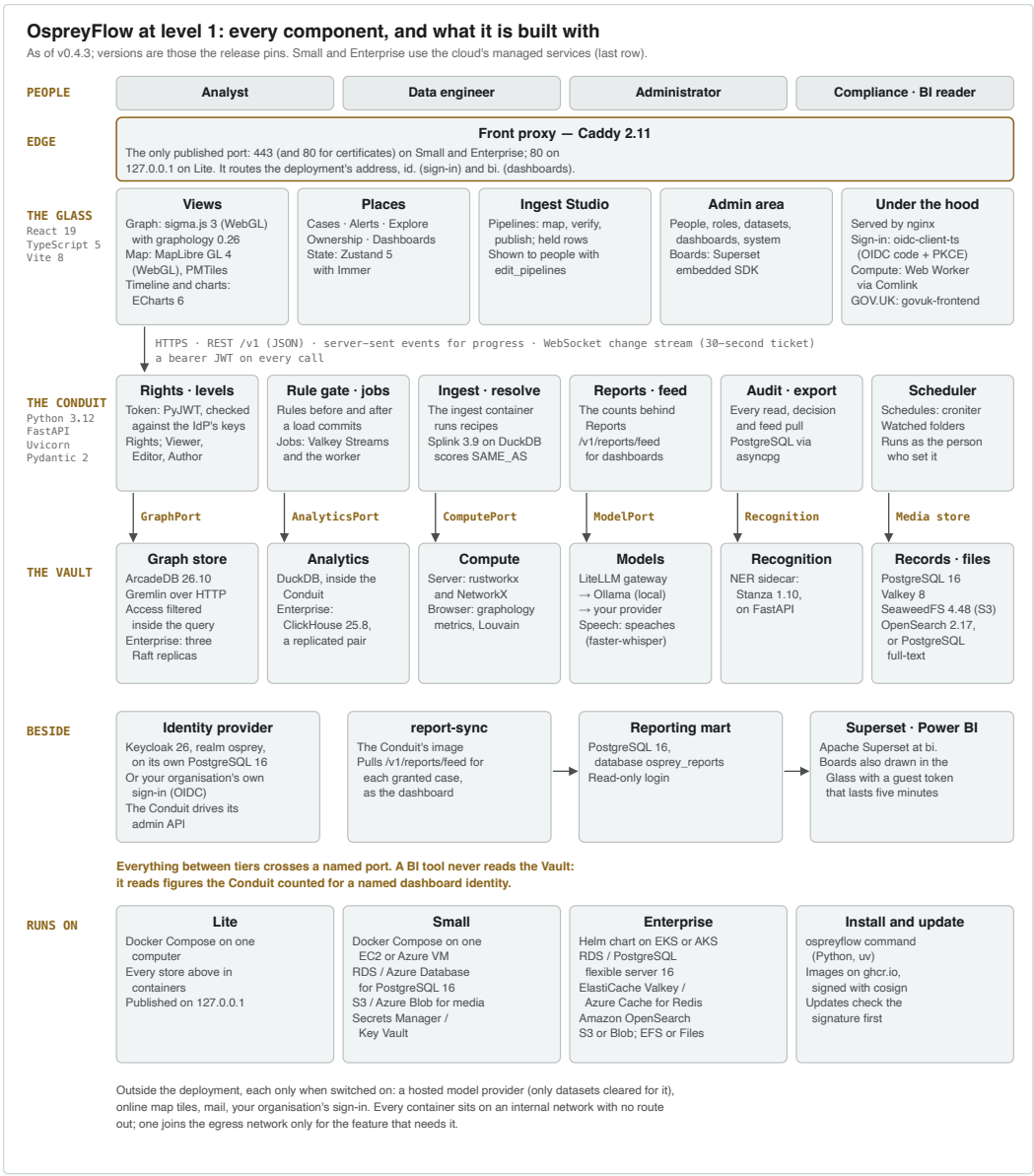



Figure 2. Level 1: every component by tier with the technology it is built on, the ports between the Conduit and the Vault, identity, reporting, and what each mode runs on

**One door in.** A front proxy (Caddy) is the only published port: 80 on Lite, 80 and 443 with automatic HTTPS on Small and Enterprise. Behind it, at the deployment's address, are the Glass; sign-in (Keycloak) at `id.`; and dashboards (Superset) at `bi.`.

**No route out by default.** Every container sits on an internal network with no route to the internet. One joins the egress network only when a configured feature needs it: the model and speech-model downloads, the proxy's certificate, a client's own model provider, mail, an organisation's own sign-in, online map tiles, and on Small and Enterprise the cloud's managed services.

**What the data is.** Model-derived data stays *inferred* until a person confirms it. Records are never merged in storage: matching records are linked with a score and shown as one at query time. Every read is checked against the reader's clearance, unit and handling codes, and a hidden record cannot be detected from a count, a path length or a chart.

### The interfaces, and what crosses each

Each interface has one direction, one owner and one guard. None of them lets a store's own query language, a source system's identifier or an unfiltered count reach the Glass.

| Interface | From → to | How | What crosses | Guarded by |
|---|---|---|---|---|
| **The front door** | Browser → front proxy (Caddy) → the Glass, the Conduit (`/v1`, through the Glass's nginx), sign-in at `id.`, dashboards at `bi.` | HTTPS on 443, with 80 only for the certificate and the move to HTTPS (Small, Enterprise); HTTP on 80, bound to `127.0.0.1` (Lite) | Every request | The only published port; every other container is on an internal network |
| **Sign-in and token** | The Glass, Superset → identity provider → the Conduit | OpenID Connect, authorisation code with PKCE; a signed JWT access token | Credentials, typed only at the identity provider; then who the person is, their clearance, unit, handling codes and roles | Every token's signature checked against the provider's keys on every call |

| Interface | From → to | How | What crosses | Guarded by |
|---|---|---|---|---|
| **Rights** | The Conduit → the Glass (`GET /v1/me/rights`) | REST | What this person may do; the rail and menus follow it | Each route checks its own right, so the Conduit refuses whatever a stale screen offers |
| **The API** | The Glass → the Conduit (`/v1/…`) | HTTPS, JSON, a bearer token on every call | Searches, working sets, edits, loads, reports, exports | Access control inside each store query; a result too large is refused with `limit_exceeded`, never cut silently |
| **Live updates** | The Conduit → the Glass | WebSocket `/v1/investigations/{id}/stream`, opened with a one-time ticket that lasts 30 seconds; server-sent events for long-running progress | Changes to the open case; progress | The ticket is the person's own; the same access as the API |
| **Administration** | The Admin area → the Conduit (`/v1/admin/…`) → the identity provider's admin API | REST | People, roles and access; datasets and their egress; dashboard identities; schedules; health and freshness | Administration rights (`manage_people`, `manage_dashboards`, `administer_system` and others); a dashboard is never given more than its registrar holds |
| **Case access** | The Share panel → the Conduit (`/v1/investigations/{id}/access`) | REST | Who holds Viewer, Editor or Author on the case, by account id | The case's Author; every change kept in the case's history |
| **GraphPort** | The Conduit → the graph store (ArcadeDB) | Gremlin over ArcadeDB's HTTP API, on the internal network only | Typed traversals; writes; a load's revert | The person's clearance and handling codes and the case's datasets are part of the traversal itself |
| **AnalyticsPort** | The Conduit → DuckDB (inside the Conduit) or ClickHouse (HTTP) | In process, or HTTP on the internal network | Event aggregates, trends and histograms; never raw SQL from the Glass | The same filters inside the query; no count includes a record the reader cannot see |
| **ComputePort** | The Conduit → rustworkx and NetworkX; the Glass → graphology in a Web Worker | In process | Centrality, communities, ownership chains | Computed over what the reader can see only; the two engines are held to the same conformance suite |
| **ModelPort** | The Conduit → LiteLLM → Ollama, speaches, or a provider you configure | HTTP, OpenAI-compatible | Text, images and audio to extract from, describe, transcribe or embed; what returns is *inferred* until a person confirms it | Each dataset's egress (`none`, `contracted`, `any`) and the handling codes that may be sent (§10) |
| **Recognition** | The Conduit → the NER sidecar (Stanza) | HTTP on the internal network | Text to tag with names, places and organisations | No route out; what it finds is *inferred* |
| **Media store** | The Conduit and the ingest container → SeaweedFS, S3 or Azure Blob | The S3 protocol, or Blob's API | Content files, staging, site images, the tile cache | Private, encrypted storage; files reach the Glass only through the Conduit |
| **Records, cache and search** | The Conduit → PostgreSQL, Valkey, OpenSearch | The internal network (TLS and a token on Enterprise's managed cache) | The Conduit's own records and audit; caches, the job queue and the change stream; text search | Reached only from the deployment's own network |
| **Ingest** | The Ingest Studio, the ingest folder and connectors → the Conduit → the ingest container | REST; a watched folder | Files and rows, loaded under a published recipe | `edit_pipelines` and `schedule_pipelines`; a run is made as the person who set it; the case's rules judge each load before and after it commits, and hold the rows they refuse |
| **Reporting feed** | report-sync → the Conduit (`/v1/reports/feed`) | REST, with the dashboard identity's own client credentials | Figures only, counted as that dashboard | The dashboard's own token and the cases it was given; every pull in the export ledger |
| **Reporting mart** | report-sync → PostgreSQL `osprey_reports` → Superset or another BI tool | SQL, a read-only login | The feed's rows; pull times and failures | A read-only login; never the Conduit's own tables |
| **Embedded board** | The Glass → the Conduit → Superset | Superset's embedded SDK, with a read-only guest token that lasts five minutes | One board | Given only to a viewer who could count every figure on it |
| **Updates** | `ospreyflow update` → the repository's releases on GitHub and its images on `ghcr.io` | HTTPS | The list of releases, the release's lock and its images | The release's signature, made by this repository's own release workflow, checked with cosign before anything changes (§14) |
| **Outside services** | A container on the egress network → model and speech-model downloads, a provider you configure, mail, your organisation's sign-in, online map tiles, the cloud's managed services | HTTPS | Only what the feature needs | A container joins the egress network only when its feature is switched on |

## 1. Choosing a mode

| | Lite | Small | Small, on your own server | Enterprise |
|---|---|---|---|---|
| Where it runs | One computer (a laptop or a workstation) | One cloud server (AWS or Azure) | One Linux server you provide, inside your own network | A Kubernetes cluster (EKS or AKS), three or more nodes |
| Who looks after the data | You, with `ospreyflow backup` | The cloud: managed PostgreSQL, S3 or Blob, daily backups | You: every store is in a container on the server's disk (section 5a) | The cloud, for its managed services; the graph store in the cluster is not yet backed up (section 13) |
| Its address | `http://ospreyflow.localhost` | `https://<your domain>` | `https://<a name in your network>`, with your organisation's certificate | `https://<your domain>` |
| First sign-in | Demo accounts, passwords in `deployment.env` | A first administrator, by a one-time code | A first administrator, by a one-time code | A first administrator, by a one-time code |
| Built with | `ospreyflow install --mode lite` | `ospreyflow install --mode small --cloud aws\|azure`, from your own computer | `ospreyflow install --mode small --config install.yaml` with a `server:` section, on the server | `ospreyflow install --mode enterprise --cloud aws\|azure`, from your own computer, or onto a cluster you already have |

All three run the same product: the same containers, the same Glass, Ingest Studio and Admin area. Small swaps the deployment's own PostgreSQL and object store for the cloud's, and gets a real domain with HTTPS. Small on your own server keeps every store in a container, as Lite does, and is reached over HTTPS with your organisation's own certificate, on port 443 alone. Enterprise runs the same services as replicas across the cluster's nodes, the graph store and the analytics database as clusters of their own.

A fifth shape, **`cloud-platform`**, is for an organisation's own shared Kubernetes platform: OspreyFlow is rendered into a namespace its platform team made, for pull requests to that platform, and is not installed by `ospreyflow install` (section 6a).

### HTTP or HTTPS

- **Lite serves plain HTTP** at a `localhost` address: `http://ospreyflow.localhost`, or a named deployment's `http://<name>.localhost:<port>` (section 1a.1). That is deliberate. Lite is for one computer, its traffic is meant to stay on that machine, and browsers treat `localhost` as a secure context, so sign-in works without a certificate.
- **Lite has no HTTPS option.** The install, the guided page and every starter give it an `http://…localhost` address, and Lite is not built or tested with a certificate.
- **Lite answers on this computer only.** Every port a Lite deployment publishes — the front proxy's, the graph store's and, when `network.expose_conduit` is on, the Conduit's — is bound to this computer's own address (`127.0.0.1`), so other machines on a network cannot reach it, whatever the firewall allows. A deployment kept by name (section 1a.1) is Lite, so the same holds. Use Small or Enterprise for anything other people reach.
- **Small and Enterprise serve HTTPS** at `https://<your domain>`, and must: `osprey.yaml` refuses a Small or Enterprise deployment whose `network.public_origin` is not an `https://` address, and `ospreyflow apply`, the guided page and the Set-up console say so and change nothing. The front proxy (Caddy) obtains the certificate for your domain and renews it automatically. Port 80 is open only for the certificate's challenge and to send a request for your domain on to HTTPS (443); any other request on port 80 gets "not found", apart from the proxy's own health check. On Enterprise, the cluster's load balancer passes 80 and 443 to the proxy.
- **Small on your own server serves HTTPS with your organisation's own certificate** (section 5a): the front proxy is given the certificate and key, obtains nothing and calls nothing; it publishes port 443 alone (80 only if you ask, and then only to send people to 443). The certificate is checked before anything starts.
- **The managed services behind Small and Enterprise are reached over TLS:** PostgreSQL always (`sslmode` is `require` at least), the object store always over HTTPS, and the cache and the mail server over TLS unless you turn it off (`external.*` and `mail.starttls`, Appendix A).
- **A service on a gov.uk domain must be served over HTTPS,** the GOV.UK theme included, so it is Small or Enterprise, never Lite: `osprey.yaml` refuses a Lite deployment at a gov.uk address. The GOV.UK theme on a `localhost` address stays available for a demonstration on one computer.

## 1a. Choosing a starter

A **starter** is a theme and a domain, chosen at install. It only fills in answers the install already asks — the look, the GOV.UK service's name, organisation and phase, the demo packs and whether demo accounts are made — and every one can still be changed. The `osprey.yaml` it makes records the starter in a comment at the top; nothing at run time reads it. Every domain pack (FIBO, NIEM, STIX) stays available to every case whatever the starter: the domain chooses the demo data and what its demo cases are set to, never what the ontology offers.

| | `crime` | `aml` | `fraud` | `cyber` | `blank` |
|---|---|---|---|---|---|
| **Demo case's domains** | NIEM | FIBO | FIBO | STIX | none chosen |
| **Demo data** | `prison-intelligence`, `hmp` | `operation-ledger`, with its synthetic screening lists | `fixture-corp`; PaySim offered as your own download, never fetched | `cyber-intrusion` | none, and no demo accounts |
| **`ospreyflow` theme** (the base look) | `ospreyflow-crime` | `ospreyflow-aml` | `ospreyflow-fraud` | `ospreyflow-cyber` | `ospreyflow-blank` |
| **`govuk` theme** (GOV.UK, a gov.uk service only) | `govuk-crime` | `govuk-aml` | `govuk-fraud` | `govuk-cyber` | `govuk-blank` |

`ospreyflow starters` (or `ospreyflow install --list-starters`) prints the same table and the command for each.

**A starter that loads `prison-intelligence`** (`crime`) also writes `components.post_ingest_resolution: false` into the `osprey.yaml` it makes, and says so: that pack needs post-ingest resolution off (section 11), and resolution is the whole deployment's setting, so the deployment's other demo cases do not gain automatic "same as" links either. An analyst's own Resolve now still works. The same holds for any answers file whose `demo_packs` names it; one whose own `osprey.yaml` (`config:`) sets it `true` is refused before anything is installed.

**One command per starter.** Add `--yes` to take every other default; leave it out to be asked.

```
ospreyflow install --mode lite --starter ospreyflow-crime
ospreyflow install --mode lite --starter ospreyflow-aml
ospreyflow install --mode lite --starter ospreyflow-fraud
ospreyflow install --mode lite --starter ospreyflow-cyber
ospreyflow install --mode lite --starter ospreyflow-blank
ospreyflow install --mode lite --starter govuk-crime --service-name "Analyse crime intelligence" --organisation "<your
organisation>"
ospreyflow install --mode lite --starter govuk-aml --service-name "Investigate money laundering" --organisation "<your
organisation>"
ospreyflow install --mode lite --starter govuk-fraud --service-name "Investigate fraud" --organisation "<your organisation>"
ospreyflow install --mode lite --starter govuk-cyber --service-name "Investigate cyber incidents" --organisation "<your
organisation>"
ospreyflow install --mode lite --starter govuk-blank --service-name "<your service's name>" --organisation "<your organisation>"
```

**The GOV.UK theme** asks for the service's name, organisation and phase (`--service-name`, `--organisation`, `--phase alpha|beta|live|none`; the phase offered first is `beta`). Without a service name the install is refused, in words, before anything is changed. **Name the service, not a case:** the name is the page title (the browser tab's "<name> – GOV.UK") on every page of every case, so the names offered above describe the whole deployment; "Prison Intelligence" over the Ledger's case is the mistake this avoids. `blank` offers no name: a real service names itself.

**On the guided page** (`ospreyflow install --gui`, section 4.1) the starter is on the first screen, Mode, under **Starter (optional)**; a GOV.UK starter shows the service's name (filled in with the name above), organisation and phase there. The Demo packs screen then shows the starter's packs ticked, to change if you wish.

**In an answers file** (section 7): `starter: govuk-aml`, with `appearance.service_name`, `appearance.organisation` and `appearance.phase`.

**On a deployment with no demo accounts** — Small, on a cloud server or your own — a starter's demo packs still load, each into its own case, with the first administrator (`admin`) as its Author, in the administrator's own unit, and no Editor. The first administrator holds the Analyst role as well as Admin (section 9.2), so the case opens for them; they can share it from there.

### 1a.1 Several deployments side by side

`--name` keeps a deployment of its own beside any other on the same computer:

```
ospreyflow install --mode lite --name crime-demo --starter ospreyflow-crime
ospreyflow install --mode lite --name aml-govuk --starter govuk-aml --service-name "Investigate money laundering" --organisation "
<your organisation>"
```

Each one has:

- its own folder, `~/.ospreyflow/deployments/<name>/`, holding its `osprey.yaml`, every file rendered from it and its `deployment.env` (readable by your account alone, `600`; the folder is `700`);
- its own Compose project and volumes, named `<name>`: no case, account or index is shared;
- its own address — `--address`, by default `http://<name>.localhost:<the next free port>` from 8090 — and its own graph-store port on this computer (`deployment.graph_port`, from 2500).

A name that Docker already knows as another folder's Compose project is refused, before anything is written: two deployments under one name would share containers. The checkout itself is shared; no second checkout or worktree is needed.

**Every command takes `--name`**: `ospreyflow start --name crime-demo`, `ospreyflow status --name aml-govuk`, `ospreyflow demo add hmp --name crime-demo`, `ospreyflow backup --name aml-govuk` (whose whose sets go to `<backups folder>/aml-govuk/`, section 13). Without `--name`, a command acts on the deployment last used, or on the only one there is.

```
ospreyflow deployments          # each one's name, starter, address and whether it is running
ospreyflow switch aml-govuk     # stop the running one, start aml-govuk, open it
ospreyflow switch default       # back to the checkout's own
```

A Lite computer runs one deployment at a time by default, which is what `ospreyflow switch` is for.

**The deployment installed in the checkout** — every install before this version, with its `osprey.yaml` in the checkout and its files in `deploy/generated/` — is listed as `default` and works exactly as before: no command moves, renames or changes it. It could later be moved under `~/.ospreyflow/deployments/` (install a named deployment, restore a backup of the checkout's into it, check it, then uninstall the checkout's with `--keep-data` until you are sure); that is a step for the administrator to take deliberately, never something an update does.

### 1a.2 Adding a public dataset

A public dataset you download yourself can be added to any deployment, at install or later:

```
ospreyflow demo add public --file <the downloaded file> --manifest <its dataset.yaml>
```

A **manifest** says what the dataset is, its source page, its licence or terms as the source states them, the file's SHA-256, whether it holds real people's data, and the Ingest Studio recipe that loads it. The file is checked against the checksum before anything else happens; a file that differs is refused, and nothing is loaded. It loads into a case of its own, named after the dataset.

**Real personal data** (`real_personal_data: true` in its manifest) is loaded only once you type `yes`, accepting that it is real people's data and that your organisation has its own lawful basis to process it — as for Enron (section 11); `--accept-real-data` accepts in a scripted run. It never belongs in a repository or a test run.

**The VAST Challenge catalogue.** OspreyFlow ships manifests and recipes — never the data — for two IEEE VAST Challenge datasets, fictional scenarios published for visual-analytics research:

| Catalogue id | Dataset | Suits | Source |
|---|---|---|---|
| `vast-2012-mc2` | VAST Challenge 2012, Mini-Challenge 2: the fictional Bank of Money's regional network — its firewall log (`Firewall-04072012.csv`) | the `cyber` starter (its case is set to STIX) | the Visual Analytics Benchmark Repository, University of Maryland |
| `vast-2008-mc3` | VAST Challenge 2008, Mini Challenge 3: cell phone call records on the fictional island of Isla del Sueño (synthetic) | the `crime` starter (its case is set to NIEM) | the same repository |

**Their terms.** Neither the source pages, nor the challenges' task pages, nor the repository's mirror at Washington University state any licence or terms of use (checked 2 November 2026). No licence means no right to redistribute is granted: download the data yourself, use it on your own computer, never pass it on, and do not rely on it for commercial use without the publishers' permission. Each manifest says so.

**Their checksums.** OspreyFlow never downloads VAST data, so the catalogue records no checksum, and `demo add public` refuses an entry until you record the checksum of the file you downloaded:

```
python -m scripts.public_dataset --list
python -m scripts.public_dataset pin --manifest vast-2012-mc2 --file Firewall-04072012.csv --out ~/OspreyFlow/vast-2012-mc2.yaml
ospreyflow demo add public --file Firewall-04072012.csv --manifest ~/OspreyFlow/vast-2012-mc2.yaml --name crime-demo
```

`pin` writes your own copy of the manifest, with the recipe beside it; check first that the file came from the source page, since what you pin is what every later check holds the file to. The column layout each recipe reads is the challenge's published one; check it against your download's first line.

## 2. Before you start

### 2.1 Lite

- **Docker**: Docker Desktop on macOS and Windows (on Windows with the WSL 2 back end); Docker Engine with the Compose v2 plugin on Linux. Set it to start when you sign in: the stack comes back after a reboot only once Docker does.
- **Memory**: at least 16 GB available to Docker (32 GB is comfortable).
- **Disk**: at least 60 GB free, plus the demo packs you choose (PaySim is about 0.5 GB to download and more once loaded).
- **Git**, and **internet** for the first install.
- **Port 80 free** (the deployment's one door).

### 2.2 Small

On your own computer, from which you build the server:

- an **AWS or Azure account** you may create resources in;
- **OpenTofu** (`tofu`), which builds the server;
- the cloud's **command line** (`aws` or `az`), signed in to that account;
- **Git** and **uv**;
- a **DNS name** you control, such as `osprey.example.org`. If the name's zone is in the same cloud account (Route 53 or Azure DNS), the records are made for you.

The server itself needs nothing from you: it installs Docker and OspreyFlow on its first boot.

### 2.2a Small on your own server

On the server itself (section 5a):

- **Linux on `amd64`** (the releases are built for `linux/amd64` only), with at least **32 GB of memory** (30 GiB as Docker reports it) and **60 GB free where Docker keeps its data** — put Docker's data root on the server's data disk;
- **Docker Engine with the Compose v2 plugin**, enabled at boot (`sudo systemctl enable --now docker`);
- **Git**, **uv** and **Python 3.12** (Ubuntu 24.04's own; or `uv python install 3.12`);
- the **clock synchronised** (`timedatectl`), since sign-in checks tokens against it;
- **port 443 free** on every interface;
- a **service account** in the `docker` group to install and run it as (not root);
- from the organisation: the **three names** in its DNS, pointing at the server, and a **certificate** naming them, with its unencrypted key (section 5a);
- **outbound access** to the releases and their images, or the organisation's mirror of them;
- a **folder for backups** (`server.backups`), with room for several sets, ideally on a disk of its own;
- for sign-in through the organisation's identity provider (section 5a): OspreyFlow's application **registered with it** (the install prints the two addresses), a **group of the people** who may sign in assigned to it, and **outbound access from the server to the provider** — for Entra ID, `login.microsoftonline.com` on 443 (or through the organisation's proxy);
- for the local engine on the server's **NVIDIA GPU** (optional, `server.gpu: nvidia`, section 5a.4): the **NVIDIA driver** for the GPU, and the **NVIDIA Container Toolkit** with Docker configured to use it, both installed by the server's administrator — OspreyFlow checks them and installs neither;
- recommended: `vm.max_map_count` at least 262144 (for OpenSearch).

### 2.3 Enterprise

On your own computer:

- what Small needs (an account, OpenTofu, the cloud's command line signed in, Git, uv, a DNS name);
- **kubectl** and **Helm**;
- on Azure, **kubelogin** (`az aks install-cli` installs it): the cluster takes Entra ID sign-ins only;

- the **addresses you work from** (`api_cidrs`): the cluster's API, and on Azure the Key Vault, answer those and nothing else, so this computer must be inside one of them.

Onto a cluster you already have, only kubectl, Helm, Git and uv are needed, with kubectl pointed at it.

### 2.4 Checking a machine: `ospreyflow doctor`

`ospreyflow doctor --mode lite` checks, in the order to fix them: Docker installed, Docker running, Compose v2, memory, free disk, Git, uv and port 80, and the GPU when `osprey.yaml` sets `resources.gpu: nvidia` (section 5a.4). `ospreyflow doctor --mode small --cloud aws` (or `azure`) checks Git, uv, OpenTofu and the cloud's command line. `ospreyflow doctor --mode small --config install.yaml`, with a `server:` section in the answers, checks the server you are on instead (section 5a): Docker, memory, disk, 443, the certificate, the clock and the rest, and the GPU with `server.gpu: nvidia` (section 5a.4); a warning (⚠) says what to change but does not stop an install. `ospreyflow doctor --mode enterprise --cloud aws` adds kubectl and Helm (and on Azure kubelogin); without `--cloud` it checks kubectl, Helm and that a cluster answers. Each line is a tick, or a cross with what to do about it; the exit code is 1 when anything is missing. `install` runs the same checks first and stops, having changed nothing, if one fails.

## 3. Getting the `ospreyflow` command

The command is installed once per computer by the bootstrap in the repository:

- **macOS and Linux**: `sh install.sh` from inside a checkout, or `OSPREYFLOW_REPO=<repository address> sh install.sh` to clone it into `~/ospreyflow`.
- **Windows**: `install.ps1` in PowerShell, the same way (`$HOME\ospreyflow`).

It installs **uv** if it is missing (from Astral's own installer), makes the checkout's Python environment, installs the command as a uv tool, and records where the checkout is (`~/.config/ospreyflow/home`, or `%APPDATA%\ospreyflow\home`). It starts nothing. If the command is not found afterwards, open a new terminal, or run `uv tool update-shell`.

The command finds its checkout by `OSPREYFLOW_HOME` first, then the recorded file, then by looking upwards from the folder you are in. Anything it prints that names a password, secret or token is hidden and replaced by a pointer to `deployment.env`.

## 4. Installing Lite

```
ospreyflow install --mode lite
```

asks a few questions — dashboards on or off, the folder the Ingest Studio lists, the folder for a basemap, which demo packs — then (`--starter <theme>-<domain>` fills these in first: section 1a):

1. writes `osprey.yaml` from the answers (refusing, with nothing changed, if a different `osprey.yaml` is already there, unless `--force`);
2. on a release (the checkout sits on a `vX.Y.Z` tag): checks the release's signatures and runs exactly its images, pinned by digest; otherwise builds the images from the checkout;
3. starts the deployment and waits until every service is healthy and the extraction model has downloaded (it says which, and its size: `qwen2.5:7b-instruct`, about 4.7 GB, or the 14b on a GPU, about 9 GB), so Ask works as soon as the install says it is done;
4. makes the demo accounts (unless `--no-demo-accounts`) and loads the chosen demo packs.

It ends by saying the address and that the sign-in details are in `deployment.env`.

**Without questions**: `ospreyflow install --mode lite --yes` takes every default; `--config install.yaml` takes the answers from a file (section 7).
**Building anyway**: `--build` builds from the checkout even on a release tag.

### 4.1 The guided page: `ospreyflow install --gui`

Opens a page in your browser, on this computer only, behind a one-time link (anyone else, or any other link, is refused). It walks through the same answers as screens, with a starter (section 1a) offered on the first, Mode:

- **Lite**: Mode, Folders, Profile, Components, Map (register a local basemap, build it, verify it), Models, Governance, Demo packs, Review (which runs the doctor), then Install, with the install's own output shown live.
- **Small and Enterprise**: Mode, Cloud and region, Domain, Components, Models, Governance, Demo packs, Review — which **saves** the answers: a Small server is built from a terminal (section 5), never from the page.

Everything is worked on a draft copy of `osprey.yaml`; the page closes itself when the install finishes, or after 30 idle minutes. On a release, the page is the release's own — fetched the first time, with its signature checked against the release; in a developer's checkout it is built with `cd apps/harness && npm ci && npm run build`, and the command says so if it is missing or out of date.

## 5. Installing Small

From your own computer:

```
ospreyflow install --mode small --cloud aws --config install.yaml
```

with at least:

```
mode: small
cloud:
  provider: aws            # or azure
  region: eu-west-2        # or uksouth, …
  domain: osprey.example.org
  dns_zone: example.org    # optional: make the DNS records in this Route 53 / Azure DNS zone
  admin_email: ops@example.org   # optional
  size: small              # small (32 GB server), medium (64 GB) or large (128 GB)
```

What happens:

1. **Plan.** OpenTofu shows everything it would make in your account (below). Nothing is made yet.
2. **Build, on your yes.** Answer `yes` (or pass `--yes`) and OpenTofu builds it. Its state is kept in `.cloud/small-<cloud>/` in your checkout, readable only by you. **Keep it, privately**: it is how the server is changed later, and on Azure it holds the database password.
3. **DNS.** With a `dns_zone`, the three records (`osprey.example.org`, `id.…` and `bi.…`) are made for you. Without one, the command prints the address to point them at and waits — up to an hour — until the name resolves to the server.
4. **The server installs itself.** On first boot it installs Docker and OspreyFlow, reads the database password (and on Azure the storage key) with **its own cloud identity**, installs onto the managed services, and gets its HTTPS certificate. The command waits — up to 45 minutes — until `https://<domain>` answers. The server's own log is `/var/log/ospreyflow-first-boot.log`.
5. **The first administrator.** The server makes an account `admin` holding the Admin and Analyst roles and the highest clearance, with a **one-time code** instead of a password, and leaves the code in the cloud's secret store. The command reads it, **shows it once**, and deletes it from the store. At their first sign-in the administrator chooses their own password. Then they invite everyone else from the Admin area (section 9).

### 5.1 What is made in your account

| | AWS | Azure |
|---|---|---|
| Server | One EC2 instance (r6i), encrypted disk, no SSH; reach it with Session Manager | One VM (E-series), no SSH port; Azure's service healing |
| Database | RDS for PostgreSQL 16, private, encrypted, its password kept by Secrets Manager | Azure Database for PostgreSQL, private, its password in Key Vault |
| Objects | S3: media, staging, site images, tile cache (private, encrypted) | Blob for media; the other stores on the server (SeaweedFS), covered by the server's backup |
| Secrets | Secrets Manager | Key Vault (purge protection on) |
| Recovery | EC2 automatic recovery; AWS Backup daily | Azure Backup daily |
| Open to the internet | 80 and 443 only | 80 and 443 only |

Backups are kept 14 days by default (`backup_days`, 7–35).

### 5.2 On the server, by hand

The server's first boot runs, in effect, `ospreyflow install --mode small --config /etc/ospreyflow/install.yaml --yes --force --first-admin-code-file <file>` with the passwords in its environment. Run without `--first-admin-code-file`, it prints the first administrator's code once instead. `install --mode small` with none of `--cloud`, the managed services in its answers, or a `server:` section (section 5a) is refused, naming all three.

## 5a. Installing Small on your own server

For an organisation that gives you one Linux server inside its own network, with its own certificate: every store runs in a container on that server (no managed services), people reach it over HTTPS on port 443 with the organisation's certificate, and nothing else is published. Nothing is built in a cloud account. The decision is ADR-114 Amendment 33.

**On the server**, as the service account that will run it (not root; it must be in the `docker` group, which is root-equivalent, so it is an administrator's account):

```
git clone https://github.com/aykr/OspreyFlow.git /opt/ospreyflow
cd /opt/ospreyflow && sh install.sh
ospreyflow doctor --mode small --config install.yaml
ospreyflow install --mode small --config install.yaml --force
```

(`--force`, because the answers make an `osprey.yaml` that differs from the checkout's own.) The server needs outbound access to the releases and their images (or the organisation's mirror of them) for the install; installing with no outbound access at all is not built. `install.yaml`:

```
mode: small
server:
  address: https://osprey.example.internal       # https:// only; the names below derive from it
  certificate: /etc/ospreyflow/tls/osprey.crt     # PEM: the server certificate, then its intermediates
  key: /etc/ospreyflow/tls/osprey.key             # PEM, unencrypted; owned by the service account, mode 600
  ca: /etc/ospreyflow/tls/org-root.pem            # optional: the organisation's root
  ingest: /srv/ospreyflow/ingest                  # where the CSV exports are put
  redirect_http: false                            # true also publishes 80, only to send people to 443
  # listen_address: 192.0.2.10                    # optional: one interface of a server with several
  backups: /srv/ospreyflow/backups                # where `ospreyflow backup` writes
  memory_gib: auto                                # or a number of GiB: what the stores are sized to
  # gpu: nvidia                                   # optional: the local engine on the server's GPU (5a.4)
sign_in:                                          # optional: the organisation's identity provider
  organisation:
    alias: org                                    # part of the address the organisation registers
    label: Example Department account             # its name on the sign-in pages
    issuer: https://login.microsoftonline.com/<tenant-id>/v2.0
    client_id: 00000000-0000-0000-0000-000000000000
    # its client secret is never written here: OSPREY_ORG_SIGN_IN_SECRET in the terminal
admin_email: ops@example.internal                 # optional: the first administrator's email
components: {dashboards: false}
```

**The certificate and key are required.** An answers file whose `server:` lacks `server.certificate` or `server.key` is refused, in words naming both, before anything is installed. A server of your own always serves the organisation's own certificate: there is no certificate the front proxy obtains for itself, which would need port 80 and a name the public internet can reach.

**The three names and the certificate.** The deployment answers at `<host>`, `id.<host>` (sign-in) and `bi.<host>` (dashboards, when they are on), all on the one address. Ask the organisation's DNS to point each at the server, and its CA for a certificate naming them as subject alternative names — `osprey.example.internal`, `id.osprey.example.internal` and `bi.osprey.example.internal`, or `osprey.example.internal` and `*.osprey.example.internal`. **A wildcard covers one label only:** `*.example.internal` covers `osprey.example.internal` but not `id.osprey.example.internal`, so it is not enough. The certificate's common name is not read, as browsers do not read it.

**What is checked before anything starts.** `doctor`, `install` and every `apply` check the certificate and key and refuse, in words and with nothing changed: a file that cannot be read or is not PEM; a key encrypted with a passphrase; a key that does not match the certificate; a certificate that has expired or is not yet valid; a name of the deployment's it does not cover; and, with `ca`, a chain that does not reach that root (put the intermediates after the server certificate). Fewer than 30 days left is a warning. `doctor --mode small --config install.yaml` also checks: Docker installed, running and started at boot; Compose v2; an `amd64` server (the releases are built for `linux/amd64` only); 30 GiB of memory as Docker reports it (a 32 GB server); 60 GB free where Docker keeps its data; Git, uv and Python 3.12; the clock synchronised (sign-in tokens are checked against it); port 443 free on **every** interface (and 80 with `redirect_http`); port 2480 free; 20 GB free where backups are written (`server.backups`); with `sign_in`, that `OSPREY_ORG_SIGN_IN_SECRET` is set (it also prints the two addresses the organisation registers); and warns for `vm.max_map_count` below 262144, running as root, names that do not yet resolve from the server, and an identity provider whose name does not resolve from it. With `server.gpu: nvidia` it also checks the GPU (section 5a.4).

**What it publishes.** Port 443 (the address's own port), on every interface or on `listen_address`; port 80 only with `redirect_http: true`, and then it only redirects; the graph store's door, 2480, on the server itself (`127.0.0.1`), as is the Conduit's with `network.expose_conduit`. The front proxy serves the organisation's certificate, read-only from where it is — the key is never copied into the deployment's folder — and obtains no certificate, follows no redirect of its own and fetches nothing from the CA. It runs as the account that owns the key, so the key stays `600`.

**Who may reach it** is set in front of the server: the organisation's firewall or security group, or the `DOCKER-USER` chain. A port Docker publishes is **not** filtered by `ufw`'s rules. In the `DOCKER-USER` chain, match only connections that **arrive** at 443, with `--ctdir ORIGINAL`; without it the rule also drops the replies to the server's own outbound HTTPS (to the releases, the images and cosign's transparency log), and the install fails with a time-out. For example, to let one network reach the service through the interface `eth0`:

```
iptables -I DOCKER-USER -i eth0 -p tcp -m conntrack --ctdir ORIGINAL --ctorigdstport 443 \
  ! -s 192.0.2.0/24 -j DROP
```

The chain is emptied when Docker restarts, so put the rule in a unit that runs after `docker.service`.

**The first administrator.** The install makes an account `admin` with the Admin and Analyst roles and the highest clearance, and prints its **one-time code once**, on the terminal; there are no demo accounts. At their first sign-in they choose their own password, then invite everyone else from the Admin area (section 9). The answers' `demo_packs` are loaded after the administrator is made, each into its own case with `admin` as its Author (section 1a says what that means for opening it).

**The extraction model.** Once every service is healthy, the install waits for the deployment's extraction model (`models.extraction`; on a GPU, the 14b) to finish downloading and pass its digest check, and says so on screen, with its size: about 4.7 GB for `qwen2.5:7b-instruct`, about 9 GB for `qwen2.5:14b-instruct` (one to two minutes on the first server). Only then does it go on and say it is installed, so Ask works from the start. A download that is refused stops the install at stage `models`, naming `ospreyflow logs ollama-models`; run the install again once it can be fetched. `ospreyflow update`, `start --build` and `apply` fetch a model whose choice has changed before anything that uses it starts again (section 5a.4).

**The installing account's umask.** A server hardened to `umask 077` or `027` is fine: every file the deployment's containers read from its folder is written readable by every account whatever the umask, and `deployment.env`, which holds the secrets, stays readable by its owner alone. The organisation's root, `ca`, is mounted into the identity provider, which runs as another account: `doctor`, `install` and `apply` refuse one that not every account can read (`chmod 644` it; it holds no secret). The key stays `600`. The install's own tools reach the three names on the server itself and trust the deployment's certificate (and `ca`), so they work before the organisation's DNS does.

**The upload folder.** Files an analyst uploads in the Ingest Studio, and the demo packs' own files, are written to `uploaded/` inside `server.ingest` by the Conduit, which runs as uid 10001. Before anything starts, `install`, `apply`, `start` and `update` make that folder and, when uid 10001 cannot write it, give it

to `10001:10001` with a short-lived container of the Conduit's own image, so the service account needs no root for it. It is never made writable by every account, and an arrangement of your own that already lets uid 10001 write (its group, and mode `2775`, say) is left as it is. If it cannot be given over, the command says why and starts nothing (section 16). Lite on a Linux computer does the same.

**Renewing the certificate.** Replace the two files (same paths), then run `ospreyflow apply`. It checks the new certificate, and only the front proxy is started again.

### 5a.1 Sign-in through the organisation's identity provider

With `sign_in.organisation` in the answers, people sign in with their organisation's own account — Microsoft Entra ID, ADFS, or any OpenID Connect provider — through OspreyFlow's identity provider (Keycloak), which brokers it. The welcome page then offers **Continue with** and the provider's name from `sign_in.organisation.label` — for example **Continue with Example Department account** — first, which goes straight to the organisation's sign-in page, and **Sign in with an OspreyFlow account** beside it, for the accounts an administrator makes (the first administrator's among them). A deployment that names a provider with no label shows **Continue with organisation sign-in**. Without `sign_in`, there is the one **Sign in**, for those accounts alone.

**What the organisation does first** — for Entra ID, in its admin centre's *App registrations*:

1. Register an application for OspreyFlow, a *web* application, and give it the **redirect URI** the install prints (and `ospreyflow doctor --mode small --config install.yaml` prints before it): `https://id.<host>/realms/osprey/broker/<alias>/endpoint` — exactly, with no slash added. Set its **front-channel logout / post-logout redirect URI** to the same address followed by `/logout_response`.
2. Make a **client secret** for it, and hand it over by the organisation's own secure route. It is never written in the answers file or `osprey.yaml`: set it in the terminal for the install, `export OSPREY_ORG_SIGN_IN_SECRET=…`; it is kept only in the deployment's `deployment.env` (mode 600), and the install refuses to start without it.
3. Turn on **assignment required** and assign the application to the **group of people** who may sign in: the organisation decides who may sign in at all.
4. Give the install the **issuer** (Entra ID: `https://login.microsoftonline.com/<tenant-id>/v2.0`) and the application's **client id**.
5. Allow the **server to reach the provider** on 443 — Entra ID is on the internet, at `login.microsoftonline.com` — directly or through the organisation's proxy. Nothing else on the server reaches out for sign-in, and only the identity provider does.

**Roles are OspreyFlow's.** Someone signing in through the organisation for the first time arrives with **no role, no handling code, and a clearance and unit of `unassigned`** that see nothing: Home shows every place dimmed until an administrator grants them. Nothing is taken from the organisation's directory — no group becomes a role. An administrator finds them in Admin → People and roles once they have signed in, and sets their roles, then their access (clearance, unit, handling codes); a later sign-in never takes those back. **No role, no list:** until they hold a role they are told no dataset's name, even if their unit is set first — the unit's dataset list and a case's datasets come back empty (section 9.2).

**Someone whose email an OspreyFlow account already holds.** A person arriving through the organisation for the first time is matched by nothing but their email, and an email the organisation's provider sends is not proof that the person owns the OspreyFlow account with that address (Entra ID does not promise it is verified). So OspreyFlow **never joins the two**: when an account already holds that email — someone you invited by that address, say — the sign-in page says "This email address already belongs to an OspreyFlow account, so your organisation account has not been joined to it. Sign in to that account with its username and password instead, or ask your OspreyFlow administrator." Nothing is made. Then, in Admin → People and roles (section 9.7):

- **Join them to that account**, if you are sure it is theirs: *Refused organisation sign-ins* lists each person refused in the last seven days by their name at the organisation; choose the account and confirm. Their next sign-in through the organisation lands in it, with its roles, clearance and cases. An invited account whose password was never set loses its one-time code: it is reached through the organisation from then on.
- **Or remove that account**, and ask them to sign in again: they arrive as someone new, with no role, and you grant their roles again.
- **Or leave it**: they go on with that account (**Sign in with an OspreyFlow account**).

To avoid it, invite only the people who cannot come through the organisation (the first administrator, outside staff).

**Joining by email, for an organisation that verifies every address.** With `sign_in.organisation.trust_email: true` in the answers (`governance.organisation_provider.trust_email` in `osprey.yaml`; off by default), a person arriving through the organisation is **joined automatically** to the OspreyFlow account holding the same email address, with its roles and clearance, instead of being refused. **This hands any account to whoever the organisation's provider gives its address**: where a person can set their own address, or another tenant can claim one, it is an account takeover — the 2023 "nOAuth" takeovers of Entra ID applications were exactly this. Turn it on only with the organisation's security officer's written sign-off that every address its provider gives is verified and cannot be changed by the person who holds it. `ospreyflow doctor` and the install warn of it every time, and so does each `repair-sign-in`. Only the provider's own address is compared: a person is never asked to type one at first sign-in. An invited account whose password was never set is joined, then asks for a password once. To turn it off, set `trust_email: false` in `osprey.yaml` and run `ospreyflow apply` (it updates the identity provider too): people whose email an account holds are refused again, and you join them by hand.

**The organisation's own certificate authority.** With `server.ca`, the identity provider trusts it as well as the usual public authorities, so a provider on the organisation's own certificates (ADFS, an internal Keycloak) is trusted too.

**After a wipe or a restore**, `ospreyflow repair-sign-in` registers the organisation's provider again, with its client secret from `deployment.env` — safe to run again, and it prints no secret. To change the secret, put the new one in `deployment.env` (`OSPREY_ORG_SIGN_IN_SECRET=`), then run `ospreyflow repair-sign-in`. A Small deployment is never given demo accounts by `repair-sign-in` or `start --build`.

### 5a.2 Memory

`server.memory_gib: auto` reads how much memory Docker has, once, at install, and writes it to `osprey.yaml` as `resources.memory_gib`; the stores are sized to it (appendix A's `resources`):

| Memory | Graph store's heap | OpenSearch's heap | PostgreSQL's shared buffers |
|---|---|---|---|
| 32 GB | 12 GiB | 2 GiB | 1 GiB |
| 64 GB | 25 GiB | 4 GiB | 2 GiB |
| 128 GB | 31 GiB | 8 GiB | 4 GiB |

The three take at most half the server, leaving the rest to the model server, the identity provider, the Conduit and the operating system. To resize, change `resources.memory_gib` (or one of its overrides, `graph_heap_gib`, `search_heap_gib`, `postgres_shared_buffers_gib`) and run `ospreyflow apply`: only the three stores are started again. An override that would give the three more than three quarters of the server is refused.

### 5a.3 Backups

`ospreyflow backup` writes each set to `<server.backups>/<deployment>/` (default `~/OspreyFlow/backups`), readable by its owner only. A set never holds the certificate's key or `deployment.env`; it does hold the case data and the people's identities. Nothing is registered with the operating system, so schedule it with the service account's own crontab (`crontab -e`), beside the organisation's snapshots of the server's disks:

```
0 2 * * * cd /opt/ospreyflow && ~/.local/bin/ospreyflow backup >> ~/ospreyflow-backup.log 2>&1
```

Old sets are not removed: remove them by hand, or with the organisation's own retention. Restoring and updating are as for Lite (sections 13 and 14).

The guided page (`--gui`) does not install this kind of Small.

### 5a.4 The local engine on an NVIDIA GPU

Without a GPU the local engine (Ollama) runs on the server's processors, so a question to Ask the case on the local engine is slow, and material that may not leave the deployment can only ever run there. A server with an NVIDIA GPU can give the local engine the GPU. The decision is ADR-135 Amendment 1.

**Before the install**, the server's administrator installs, and OspreyFlow checks but never installs:

- the **NVIDIA driver** for the GPU (on Ubuntu, `sudo ubuntu-drivers install`, then restart the server), until `nvidia-smi` lists the GPU;
- the **NVIDIA Container Toolkit**, with Docker configured to use it:

```
sudo nvidia-ctk runtime configure --runtime=docker
sudo systemctl restart docker
```

Then add `gpu: nvidia` under `server:` in `install.yaml`; it is written to `osprey.yaml` as `resources.gpu: nvidia`. Lite on a Linux computer with an NVIDIA GPU may set `resources.gpu: nvidia` in `osprey.yaml` itself and run `ospreyflow apply`. It is refused for Small in a cloud and for Enterprise, whose servers are sized without a GPU, and on macOS and Windows, where Docker Desktop gives a container no NVIDIA GPU.

**What changes.** The model server alone reserves every NVIDIA GPU on the server; its image, the models' pinned weights and the gateway are the same. Image descriptions and embeddings run in the same model server, so they use the GPU too; transcription stays on the processors. The extraction model, which also answers Ask the case and Ask to search on the local engine, becomes `qwen2.5:14b-instruct` (about 9 GB, downloaded once) instead of `qwen2.5:7b-instruct`, unless `osprey.yaml` names one under `models.extraction`, which always wins. `ospreyflow apply` fetches a newly chosen model, and waits for it, before the services that use it start again. An `osprey.yaml` saved by the guided page (`--gui`) names every model, `models.extraction: qwen2.5:7b-instruct` among them, so it keeps the 7b on the GPU until that line is removed. On the GPU the model server also keeps its working memory for a question at reduced precision (`OLLAMA_FLASH_ATTENTION=1` and `OLLAMA_KV_CACHE_TYPE=q8_0`), which is what fits the 14b, with the long context it is given, wholly on a 16 GB card. On the GPU the model also stays loaded (`OLLAMA_KEEP_ALIVE=-1`): left to Ollama's default, an idle model was unloaded after five minutes and the next question waited 56 s for it to load again, against 3.3 s once loaded. Without a GPU nothing changes.

**As measured, 4 November 2026**, on the first server (an RTX 5060 Ti, 16 GB), the same question through the product's own route: the 14b on the GPU without those two settings used 18 GB, ran 15% on the processors and 85% on the GPU, and took 9–11 s an answer of about 120 tokens; with them it used 14 GB, ran wholly on the GPU (12.0 GiB, per `nvidia-smi`), and took 3.3–3.6 s. The 7b on the processors took 17.3 s.

**What is checked before anything starts.** `doctor`, `install` and `apply` refuse, in words and with nothing changed: a computer that is not Linux; `nvidia-smi` not installed, or not answering ("NVIDIA-SMI has failed because it couldn't communicate with the NVIDIA driver": install the driver, or restart after installing it); and Docker listing neither the toolkit's `nvidia` runtime nor an NVIDIA CDI device (`docker info`). With the 14b model, less than 14 GiB of GPU memory is a warning naming the 7b: set `models.extraction: qwen2.5:7b-instruct` in `osprey.yaml` and run `ospreyflow apply`. The doctor names the GPU, its memory and its driver, for example:

```
✔ The NVIDIA GPU is NVIDIA GeForce RTX 5060 Ti, 15.9 GiB (driver 595.99.02).
✔ Docker can run a container on the GPU (the nvidia runtime of the NVIDIA Container Toolkit).
✔ The GPU has 15.9 GiB of memory; qwen2.5:14b-instruct asks for at least 14 GiB.
```

To turn it off, set `resources.gpu: none` in `osprey.yaml` and run `ospreyflow apply`.

## 6. Installing Enterprise

From your own computer:

```
ospreyflow install --mode enterprise --cloud aws --config install.yaml
```

with at least:

```
mode: enterprise
cloud:
  provider: aws            # or azure
  region: eu-west-2        # or uksouth, …
  domain: osprey.example.org
  api_cidrs: [203.0.113.0/24]    # the addresses you work from; never 0.0.0.0/0
  admin_email: ops@example.org   # optional
  size: small              # small (3 nodes of 32 GB), medium (4 of 64 GB) or large (6 of 128 GB)
cluster:
  namespace: ospreyflow    # optional
```

What happens:

1. **Plan, then build on your yes**, as for Small (section 5): OpenTofu shows the cluster and the services it would make, and makes them when you answer `yes` (or pass `--yes`). Its state is kept in `.cloud/enterprise-<cloud>/`, readable only by you. **Keep it, privately**: it is how the cluster is changed later, and it holds secrets.
2. **What OpenTofu made becomes the answers.** It names the cluster's two storage classes and every managed service; these join your answers in `osprey.yaml`. Do not give `external:` or the storage classes yourself: with `--cloud` they are refused, since OpenTofu makes them.
3. **A kubeconfig of the install's own**, in the state folder; your `~/.kube/config` is not changed. Use it yourself with `KUBECONFIG=.cloud/enterprise-<cloud>/kubeconfig kubectl get pods -n ospreyflow`.
4. **The passwords and keys** of the managed services are read from the cloud's secret store with your own identity and handed to the install in its environment only — never on a command line, in `osprey.yaml` or on the screen.
5. **The install** puts the chart onto the cluster, makes its Secret (keeping every value already there when run again), configures sign-in, makes the first administrator, prints their one-time code once, and says the address to point `osprey.example.org`, `id.…` and `bi.…` at.

Run again, it changes nothing OpenTofu need not change, no password and no account.

**Onto a cluster you already have**: leave out `--cloud`, point kubectl at the cluster, and give the managed services yourself under `external:` and the cluster's classes under `cluster:` (section 7), with their passwords in the environment: `OSPREY_POSTGRES_PASSWORD`, `VALKEY_PASSWORD`, and for media on Blob `AZURE_STORAGE_KEY`. A site's own Helm values go in with `--chart-values <file>` (repeatable), applied over the rendered ones.

### 6.1 What is made in your account

| | AWS | Azure |
|---|---|---|
| Cluster | EKS, its Kubernetes secrets encrypted with their own key; nodes in three private subnets | AKS, no local accounts (Entra ID only); a system pool and the deployment's own pool, three zones |
| Its API | Answers `api_cidrs` only | Answers `api_cidrs` only |
| Network policy | The VPC CNI's engine, so the chart's policies are enforced | Azure network policy |
| Database | RDS for PostgreSQL 16, two zones, password in Secrets Manager, deletion protection | PostgreSQL flexible server 16, zone-redundant, a delete lock, password in Key Vault |
| Cache | ElastiCache for Valkey, TLS and a token | Azure Cache for Redis, TLS only |
| Objects | S3 (as Small) | Blob for media; the other stores in the cluster |
| Search | Amazon OpenSearch Service (the install always asks for it; the module's own `search = false` leaves it to the cluster) | In the cluster |
| Shared volume | EFS (`ospreyflow-shared`) | Azure Files (`ospreyflow-shared`) |
| Store volumes | Encrypted gp3 (`ospreyflow-volumes`) | Zone-redundant premium disks (`ospreyflow-volumes`) |

Every managed store is reached only from inside the cluster's network. Neither module has yet been built in a real account; the chart and the install have been proved in a local cluster.

## 6a. Deploying into a namespace on a shared platform: `cloud-platform`

For an organisation that hosts OspreyFlow on a shared Kubernetes platform of its own: a shared EKS cluster in AWS London, run by the organisation's platform team. A service there does not get a cluster; it gets a **namespace**, created and changed only by pull request to the platform's environments repository, and its AWS resources (RDS, ElastiCache, OpenSearch, S3, ECR and IAM roles for its service accounts) are asked for the same way. The `cloud-platform` profile writes what those pull requests need. It creates no cluster, no VPC and no namespace, and **it installs nothing**: the set-up console does not offer it, and `ospreyflow install` does not run it. The decisions are ADR-148's.

**Not yet installable end to end.** What is built is the render, the chart, its policy check, the backups and, for the proof-of-concept shape, the install and decommission runbooks. Nothing here has run in the platform's own namespace. On a local test cluster set to the platform's rules, the Conduit and the workers were not yet shown running as user 10001, and of the egress policies only the deny was shown holding, for ClickHouse's pod; each workload's own rows are not yet shown enforced. They are to be shown at the first install on the platform. People sign in through the organisation's own Entra ID (section 6a.7); Keycloak is not rendered on this profile. No token from a real tenant has yet been tried (section 6a.7 lists what one is to settle). The commands that need the platform, a cluster or Docker (`helm install`, `tofu`, the push itself, the policy check on your own settings) have not been run against the platform. The unpinned render below has been run as written, from `OspreyFlow_Core`, on this example, and the push's dry run with the same arguments through the checkout's own command line (`PYTHONPATH=cli python -m ospreyflow.main images push …`), not an installed `ospreyflow`; the pinned render needs the images in the registry first.

### 6a.1 What is rendered

Give the profile in `osprey.yaml`. Three sections are **required**: `cloud_platform`, its `claims` (how people sign in, section 6a.7), and `map:`, since the Conduit reads its basemaps from it at start and this profile has no install to write one ("declare map:"). The example, with placeholder ids and networks:

```
profile: cloud-platform
components:
  analytics_engine: clickhouse
network:
  public_origin: https://ospreyflow-dev.apps.example.org
cloud_platform:
  platform: client               # the platform's settings file
  namespace: ospreyflow-dev      # the namespace the platform's team made
  environment: development       # or production
  registry: 123456789012.dkr.ecr.eu-west-2.amazonaws.com
  allow_from: ["192.0.2.0/24"]   # the networks the platform's ingress admits
  egress_nets:                   # every host a pod reaches, by its networks
    s3.eu-west-2.amazonaws.com: ["198.18.0.0/24"]
    sts.eu-west-2.amazonaws.com: ["198.18.1.0/24"]
    login.microsoftonline.com: ["198.18.2.0/24"]
  claims:                        # section 6a.7
    tenant_id: 00000000-0000-4000-8000-000000000001
    client_id: 00000000-0000-4000-8000-000000000002
    api_client_id: 00000000-0000-4000-8000-000000000003
    clearance: {claim: extension_0123456789abcdef0123456789abcdef_clearance}
    org_unit: {groups: {00000000-0000-4000-8000-000000000011: unit-1}}
    handling_codes: {groups: {00000000-0000-4000-8000-000000000021: [R]}}
    first_administrators: [00000000-0000-4000-8000-000000000031]
map:                             # required
  default: osm-local
  providers:
  - id: osm-local
    label: OpenStreetMap
    kind: vector
    licence: {id: ODbL, redistributable: true, client_scope: open}
    source: file:///data/tiles/osm-local.pmtiles
    variables: {}
    proxy: none
    style: bundled:osprey-dark
    attribution: "© OpenStreetMap contributors"
```

**The example's map is empty on this profile.** Its one provider is a local basemap file, and no basemap can be brought onto the platform yet (below), so copied as it is, the map shows no tiles. Name a remote provider instead for a map that shows; a provider the Conduit proxies names its host's networks in `egress_nets` (section 6a.5). Every `cloud_platform` setting is in Appendix A.

**The marking ceiling is OFFICIAL-SENSITIVE** on this profile unless `deployment.highest_marking` says otherwise: a platform that hosts data up to, but not including, SECRET needs no more.

**Two shapes.** `cloud_platform.shape` is `standard` (the default) or `poc`, the proof-of-concept shape, which a development namespace alone may take ("cloud_platform.shape: poc is a development namespace's (one copy of each store); a production namespace takes the standard shape"). The poc shape runs one copy of each store, ClickHouse with its own Keeper inside it rather than ClickHouse Keeper beside it, no disruption budgets, a CPU limit on every container (section 6a.2), and the Ingest root (uploads and the drop folder) on a claim of its own, `ospreyflow-ingest`. Like the standard shape, it makes the platform's OpenSearch domain when `components.search` is `opensearch` (the default; ADR-148 Amendment 13), and `components.search: postgres-fulltext` makes none.

Then, in `OspreyFlow_Core`:

```
PYTHONPATH=.:packages python -m harness.render --config osprey.yaml --allow-unpinned
```

The render writes `deploy/generated/cloud-platform/` (`deploy/generated/<deployment.name>/` when the deployment has a name), making the folders it needs and removing a file an earlier render wrote and this one does not (it lists what it wrote in `.rendered`):

| File | What it is |
|---|---|
| `values.yaml` | Our Helm chart's values for the namespace: `helm install ospreyflow <chart> -n <namespace> -f values.yaml`. It holds no secret |
| `versions.lock` | Every image and its digest; an image not yet resolved is marked `unresolved` |
| `images.yaml` | What `ospreyflow images push` copies into the registry (section 6a.4) |
| `terraform/*.tf` | The namespace's AWS and Kubernetes resources, in the environments repository's folder shape, for a person to raise as a pull request (section 6a.3) |
| `INSTALL.md`, `DECOMMISSION.md` | The poc shape alone: the install and the decommission, step by step, with the deployment's own names (below) |
| `osprey.yaml` | A copy of the settings it was rendered from |

Until our own images are in the registry, a render without `--allow-unpinned` is refused, naming the images it has no digest for. **Never install the values of an unpinned render**: section 6a.4 ends with the render to install.

**The runbooks (poc shape).** `INSTALL.md` takes the deployment from its settings to a Glass that answers: the checks of the tools and rights, the Terraform's pull request, the unpinned render and the push, the pinned render, `helm upgrade --install`, the sign-in check (and the way back in when nobody can manage people, section 6a.7), and the Glass's health. `DECOMMISSION.md` removes it: a last backup, `helm uninstall`, the claims and our Secret, the buckets

and repositories emptied, and the backups bucket and its key by a choice with no default: its step 7 refuses until it is given `BACKUPS=keep` or `BACKUPS=destroy`. **keep** sets the kept bucket's expiry to the retention you agree (`BACKUP_RETENTION_DAYS`), so the sets stay readable until then; **destroy** removes every set now, which cannot be had back, and schedules the key's deletion (thirty days, cancellable until then). Then `python -m harness.cloud_platform.decommission_check`, which names anything left behind and exits 1 while anything is. A block fenced `bash platform` runs only with the platform's access; the rest runs anywhere. A block fenced `bash later` is in neither runbook's sequence and is run only when its words say: the way back in when nobody can manage people, and the kept backups' removal when their retention ends (run with the decommission, it would delete the last backup it keeps). The install asks for the Entra app registrations before its first block, and its step 2 checks the certificate Secret `cloud_platform.tls_secret` names, when it names one. The install's *What it needs* names the `ospreyflow` command's own install (`uv tool install ./cli`) and the managed PostgreSQL's `max_connections` of 1000, set in its parameter group. The least it must allow is 834 in the poc and development shapes and 918 in production: two Conduits side by side in an update, the worker, the gateway and a reserve, with Superset and the report sync (from v0.5.2: one copy of each in poc and development, two in production) doubled by an upgrade in progress. 1000, set in every shape, leaves 166 and 82 to spare. The Terraform renders RDS as a `db.t4g.large` (8 GiB) in every shape, with a parameter group setting it; with MoJ's `cloud-platform-terraform-rds-instance` module the install gives the module's `db_parameter` line instead. The setting is static: it takes effect when the instance is created, and on an existing one only at its next reboot. Its last section, *Against the client's real tenant*, is no block to run: what only the real Entra tenant can show. The decommission removes a restore's Jobs before the claims, which they would otherwise keep, and its settings keep the bucket prefix, so it can be taken up in a new shell after step 7. **Both were run on a kind cluster (R1, 13 November 2026)**, with stand-ins for the platform's parts (AWS's S3, STS and KMS, EKS's pod identity, RDS, ElastiCache and Entra ID); neither has run against a real account or tenant. The standard shape has no rendered runbook yet.

**Moving to a new release (poc shape).** There is no separate upgrade runbook. A new release is installed by running `INSTALL.md` again from the new release's copy: its `helm upgrade --install` moves the deployment onto the new release's images and values. In order:

1. **Back up first.** Take *A backup now* (section 6a.8) as the runbook's *Before an upgrade* does it, with the Conduit, the workers and the report sync stopped and each one's copy count noted, and check that the set finished (its `manifest.json` is written).
2. **Get the new release's copy**: its tag, checked out in its own folder, with the deployment's own `osprey.yaml` copied in. Read the release's notes first.
3. **Render, push and render pinned from that copy**, exactly as section 6a.4 says. The values to install are the new release's pinned render, never the old one's. A release that needs a change in the Terraform says so in its notes, and the Terraform is this render's `terraform/` folder: its pull request is applied now, before the install, as at the first install.
4. **Run `INSTALL.md` again from that copy**, block by block. Its `helm upgrade --install` replaces each pod on the new release, and its own checks follow, as at the first install: section 6's check that the Conduit reads Entra's settings, and section 7's `/healthz` through the Glass. Then start the Conduit and the workers again at the copy counts noted in step 1, if the install has not.

**What will check it.** v0.5.2's install test, planned for 25 November 2026 on a kind cluster, is to install v0.5.1, then the candidate by these steps over it, and check that the data made before the upgrade is still there. It has not run yet. **Going back to the previous release** (installing its copy again the same way and restoring step 1's backup) **has not been rehearsed**: until it has, treat step 1's backup as the way back, and test the new release on the development namespace before production.

**A platform is a settings file**, `harness/cloud_platform/platforms/<name>.yaml`: its ingress class and annotations, the controller's namespace, its storage class, its egress policy kind and the networks its managed stores answer in, and the names of the secrets the managed stores' details arrive in. Another shared platform is another file beside it, not another profile. The platform's own file is `client.yaml`.

**What runs, and what the platform gives instead.** ArcadeDB and ClickHouse (with ClickHouse Keeper, in the standard shape) run in the namespace as StatefulSets on the platform's `gp2-expand` class; in the standard shape each has a disruption budget allowing one copy down at a time, and two minutes for ArcadeDB to close its databases. Postgres is RDS PostgreSQL 16 and Valkey is ElastiCache (Redis 7), each reached over TLS; SeaweedFS is S3. In every shape the platform's OpenSearch 2.x domain is made by default (`components.search` defaults to `opensearch`), and the pods that read the stores, the Conduit (`api`), the workers (`worker`) and the index's rebuild and drift check (`ospreyflow-search-rebuild`, `ospreyflow-search-drift`), are given its address (`OPENSEARCH_URL`). Caddy is not rendered: the platform's NGINX ingress is the front door, with ModSecurity on and the IP allow-list from `allow_from`. Local models and Whisper are not rendered, since the platform has no GPU. The model gateway (LiteLLM) is rendered always, with or without an engine (section 6a.3 says which identity it runs as; section 6a.9 is the model route). **Reporting is rendered when it is switched on** (`reporting.superset`, `reporting.sync`; ADR-148 Amendments 9 to 11): Superset, at the `bi.` name, signs people in with Entra ID as its own app registration (`cloud_platform.claims.superset_client_id`; a render without it is refused in words), and the report sync's dashboard identities get their tokens from Entra ID (section 6a.7). Superset's settings are its own database, `superset`, which it makes on the managed PostgreSQL at its first start, beside `ospreyflow` and the gateway's `litellm`; the reports are the schema `osprey_reports` inside `ospreyflow`, as on Small, which Power BI may read through a read-only login of its own (an option the install's runbook describes). The Conduit's image is built without Java on this profile, so *Admin › Maps*' **Build** says that the basemap cannot be built here; there is no way yet to bring a basemap built elsewhere onto the platform (*coming*), so the map uses its providers alone.

**Laurium, the review queue's extraction engine.** On this profile the extraction engine is Laurium unless `models.extraction_engine: deep_read` is named (ADR-135 Amendments 6 and 9). Laurium runs as **its own pod,** `laurium`, from its own image, `ospreyflow/laurium` (built from `services/laurium/`, pushed to its own repository in the namespace's registry), on port 8000. It is not inside the Conduit or the workers: the Conduit alone calls it, and it reaches nothing but the model gateway, with a key of its own scoped to its models; it takes no service account, no token and none of our Secret. It is for the review queue's document extraction alone, and **no screen reaches it yet**: the Glass's own extraction (a document's content, email) and Questions and Ask stay on Deep read, so with the preset Laurium is rendered and runs while no analyst action reaches it, until a screen calls the review queue's extraction (*coming*). It has read a real model's answer (3 of 3 on the product's own extraction model, outside the rendered route) but has not yet been run on the organisation's own engine. Until its key is held on the gateway, its calls are refused in words ("Laurium's key is not yet held on the model gateway; the Conduit keeps trying. Try the extraction again shortly."). With `deep_read` named, no Laurium pod, image or repository is rendered.

**Every pod runs as user and group 10001**, non-root, with no privilege escalation, every capability dropped and seccomp's runtime default; every Dockerfile of ours is `USER 10001:10001`. No pod takes group 0.

**The shared folders** are one ReadWriteOnce volume, `ospreyflow-shared`, on the platform's class, and every pod that mounts it is placed on the same node. In the poc shape the Ingest root is on its own claim instead. Moving tiles, the settings files and, in the standard shape, the Ingest root (`ingest`: uploads and the drop folder) off it, and the recipes repository off the shared disk, is *coming*.

### 6a.2 What the namespace asks for

Each container asks for its CPU and memory and has a memory limit. **In the standard shape none names a CPU limit**, on purpose: a CPU limit throttles a store's compaction and the Conduit's bursts. So a LimitRange in the namespace with a default CPU limit puts that limit on every container, and a

ResourceQuota counting `limits.cpu` refuses every pod that names none: both are questions for the platform's team (section 6a.11). **The poc shape names a CPU limit on every container** (0.5 by default; the Glass 0.5, the Conduit 2, the workers 2, named-entity extraction 1, ArcadeDB 2, ClickHouse 2, the search index's rebuild and drift check 2), for a namespace whose quota counts them. ArcadeDB's Java heap is three quarters of its memory limit. **These sizes are proposals, not measurements**: no load has yet run on the platform.

| Component | Copies, development | Copies, production | CPU asked for | Memory asked for | Memory limit |
|---|---|---|---|---|---|
| The Glass (`workspace`) | 1 | 2 | 0.1 | 128 MiB | 256 MiB |
| The Conduit (`api`) | 1 | 2 | 0.5 | 2 GiB | 4 GiB |
| The workers (`worker`) | 1 | 3 | 0.5 | 2 GiB | 4 GiB |
| Named-entity extraction (`ner`) | 1 | 1 | 0.25 | 1 GiB | 2 GiB |
| ArcadeDB | 1 | 3 | 1 | 12 GiB | 12 GiB |
| ClickHouse | 1 | 2 | 1 | 8 GiB | 8 GiB |
| ClickHouse Keeper (standard shape) | 1 | 3 | 0.1 | 512 MiB | 512 MiB |
| The model gateway (LiteLLM) | 1 | 1 | 0.25 | 512 MiB | 1 GiB |
| Superset, when reporting is on | 1 | 2 | 0.25 | 1 GiB | 2 GiB |
| The report sync, when reporting is on | 1 | 2 | 0.1 | 256 MiB | 512 MiB |
| Laurium, when it is the extraction engine | 1 | 1 | 0.25 | 1 GiB | 2 GiB |
| The backups' and the restore's Jobs | — | — | 0.5 | 2 GiB | 4 GiB |
| The restore's ArcadeDB step | — | — | 1 | 12 GiB | 12 GiB |
| The search index's rebuild and drift check, when OpenSearch is used | — | — | 0.5 | 2 GiB | 4 GiB |
| Every init container, and any container not named above | — | — | 0.1 | 256 MiB | 512 MiB |

From renders of the repository's synthetic deployments, counting each running copy:

| Deployment | CPU asked for | Memory asked for | Memory limits |
|---|---|---|---|
| Development, Deep read | 3.7 | about 26 GiB | about 32 GiB |
| Development, Laurium (the preset) | about 4 (3.95) | about 27 GiB | about 34 GiB |
| Development, poc shape, Laurium | about 3.9 (3.85), with CPU limits of 10.5 | about 27 GiB | about 33 GiB |
| Production, Deep read | 8.5 | about 65 GiB | 77 GiB |
| Production, Laurium and a Bedrock engine | about 8.8 (8.75) | about 66 GiB | 79 GiB |

These count each running copy alone: a set-up job, the nightly backup's and a restore's Jobs (above) and the extra copy a rolling update starts need room above them, so a ResourceQuota on requests and memory limits must be larger, or pods are left unscheduled; in the standard shape one on `limits.cpu` refuses them whatever its size.

### 6a.3 The namespace's Terraform, and the secrets each component reads

The Terraform is plain AWS and Kubernetes resources, not the platform's own modules, and each file says what it makes, so a reviewer may swap a block for one of the platform's modules. `tofu fmt` leaves it unchanged and `tofu validate` accepts it.

| File | What it makes |
|---|---|
| `variables.tf` | What the platform gives the namespace: `namespace`, `vpc_id`, `subnet_ids`, `eks_oidc_provider_arn` and `eks_oidc_issuer`. The providers, the backend and the tags are the namespace folder's own |
| `rds.tf` | RDS PostgreSQL 16, encrypted, reached over TLS, and the secret `rds-postgresql-instance-output` |
| `elasticache.tf` | ElastiCache (Redis 7), TLS and a token, and the secret `elasticache-redis` |
| `opensearch.tf` | Every shape, when `components.search` is `opensearch` (the default): the OpenSearch domain, encrypted, HTTPS only, inside the VPC, and the secret `opensearch-output` |
| `s3.tf` | The buckets, private and encrypted, named from a prefix, and the secret `s3-bucket-output` |
| `irsa.tf` | The service account `ospreyflow` and its IAM role, given the buckets, so no S3 key exists anywhere |
| `connector_sources.tf` | Only when S3 buckets or Athena workgroups are declared (section 6a.5): the reads on them, attached to `irsa.tf`'s role |
| `gateway.tf` | Only while a Bedrock engine is declared in `osprey.yaml`: the model gateway's own service account and IAM role, allowed to invoke Bedrock's models in eu-west-2 (`bedrock:InvokeModel`, `bedrock:InvokeModelWithResponseStream`) and nothing else, no S3 included, and trusted by the gateway's service account alone |
| `backups.tf` | The backups' bucket and its own KMS key, their two roles and service accounts, ClickHouse's backup user's password and the Secrets `ospreyflow-clickhouse-backup` and `ospreyflow-backup-output` (section 6a.8) |
| `ecr.tf` | A repository for each image, scanned on push |
| `secrets.tf` | Our own Secret, `ospreyflow-secrets`: each password made here (`random_password`), and each key a person holds (a model engine's, a connection's, the mail server's password; with reporting on, Superset's client secret, `superset_oidc_client_secret`, and the report sync's dashboard identities, `report_sync_dashboards`) as a sensitive variable |

**The platform's Terraform state holds every secret here**: the passwords it makes, and each key a person holds, which is a sensitive variable with no default written into the Secret's data. How the environments repository's pipeline is given those variables is a question for the platform's team (section 6a.11).

**Each pod reads only what it needs, by name.** Only the Conduit and the workers take our Secret whole (with keys they must not see set blank in their own environment); every other pod is given the ConfigMap `ospreyflow-env` alone, and any key it needs by name. The managed stores' details are read from

their own secrets, and only by the pods that read the stores; no such detail is in a file, in `values.yaml` or in our own Secret. The policy check refuses a pod that takes a Secret whole or mounts a service-account token without being allowed to (section 6a.6).

| Component | Reads | Service account |
|---|---|---|
| The Conduit | `rds-postgresql-instance-output` (`rds_instance_address`, `rds_instance_port`, `database_username`, `database_password`, `database_name`), `elasticache-redis` (`primary_endpoint_address`, `port`, `auth_token`) and `s3-bucket-output` (`bucket_prefix`); `ospreyflow-secrets` whole, with every model engine's key and the gateway's salt (`OSPREY_LITELLM_SALT_SECRET`) and database password (`OSPREY_LITELLM_DB_PASSWORD`) blank. It alone keeps the gateway's master key (`OSPREY_LITELLM_MASTER_SECRET`, for its admin API) and the connections' secrets | `ospreyflow`, its token mounted |
| The workers | The same three managed secrets; `ospreyflow-secrets` whole with, besides the Conduit's blanks, the gateway's master key and the connections' secrets blank | `ospreyflow`, its token mounted |
| The Glass, named-entity extraction | The ConfigMap alone: no key of our Secret, no managed store's detail | None; no token |
| Laurium | Nothing: its one setting is the gateway's address | None; no token |
| ArcadeDB | `OSPREY_ARCADEDB_PASSWORD`, `OSPREY_ARCADEDB_CLUSTER_TOKEN` | None; no token |
| ClickHouse | `OSPREY_CLICKHOUSE_PASSWORD`, and its backup user's password from `ospreyflow-clickhouse-backup` | `ospreyflow-backup-clickhouse`, for its backups (section 6a.8); no token mounted |
| The model gateway, and its database's set-up | `OSPREY_LITELLM_DB_PASSWORD`, `OSPREY_LITELLM_MASTER_SECRET`, `OSPREY_LITELLM_SALT_SECRET`, and each enabled engine's key (`OSPREY_MODEL_KEY_<NAME>`, or `OSPREY_MODEL_PROVIDER_KEY` for a single `models.provider`); `rds-postgresql-instance-output`'s address, user and password | `ospreyflow-gateway`, its token mounted, while a Bedrock engine is declared; otherwise none and no token |
| The backups' runs and the restore | ArcadeDB's password; ClickHouse's backup user's password (`ospreyflow-clickhouse-backup`); `ospreyflow-backup-output` | `ospreyflow-backup`, its token mounted |
| ClickHouse Keeper (standard shape) | Nothing | None; no token |

The Conduit and the workers run as the service account `ospreyflow`, which reaches the buckets through its role. The model gateway never runs as it: with no Bedrock engine declared it takes no service account, and while one is declared it runs as its own (`ospreyflow-gateway` on the platform's file), under `gateway.tf`'s role. A platform file naming no gateway account is refused at render, in words, when a Bedrock engine is declared. A password two readers name differently (`ARCADEDB_ROOT_PASSWORD`, `CLICKHOUSE_PASSWORD`) is written from the one `random_password`.

### 6a.4 Images into the namespace's registry

In this order:

1. **The unpinned render** (section 6a.1). Its `images.yaml` names every image: ours to build, and each third-party image by its digest, looked up at render.
2. **Apply `ecr.tf`'s pull request first**: it makes a repository for each image, and a registry makes none on push.
3. **Sign in, then push**, on a computer with Docker, from the checkout you rendered in:

```
aws ecr get-login-password --region eu-west-2 | docker login --username AWS --password-stdin 123456789012.dkr.ecr.eu-west-2.amazonaws.com ospreyflow images push --registry 123456789012.dkr.ecr.eu-west-2.amazonaws.com --from deploy/generated/cloud-platform --dry-run ospreyflow images push --registry 123456789012.dkr.ecr.eu-west-2.amazonaws.com --from deploy/generated/cloud-platform
```

1. **Render again, pinned**, on the same computer, with Docker running:

```
PYTHONPATH=.:packages python -m harness.render --config osprey.yaml
```

This is the render to install: every image is pinned by its digest, ours by the digest the registry gave its copy, and each third-party image by the digest the push copied.

`ospreyflow images push` builds our images from this checkout for the platform's nodes (`linux/amd64` unless `--platform` says otherwise, so a Mac with an Apple chip does not push an arm64 image) and pushes them, and copies each third-party image (`docker buildx imagetools create`). `--dry-run` says each step and runs none. `--registry` must be the render's `cloud_platform.registry`, or the command refuses. Give `--from` with the render's folder: without it the command reads `deploy/generated/cloud-platform/` in the checkout it finds, which is not the render's folder when the deployment has a name. A plan naming a third-party image by its tag alone is refused, since its copy could not be the one the values pin: render again with each image's registry reachable. A repository the namespace's Terraform did not make, or a registry you have not signed in to, stops the push. Signing in is yours, never the command's. With Laurium as the extraction engine, its image and repository are among them.

### 6a.5 What each pod may reach

**Egress is denied by default, and each workload has its own way out.** The chart makes Calico policies from the render's rows: `default.ospreyflow-allow-dns` (order 100, every pod, DNS on port 53 to the cluster's DNS in `kube-system`), one `default.ospreyflow-egress-<workload>` for each workload that reaches anything beyond DNS (order 100), and `default.ospreyflow-deny-egress` (order 200, every pod, every destination), which runs before Kubernetes' own policies. Each allowing rule is TCP to single ports, never a range:

| Workload | Reaches |
|---|---|
| The Conduit | ArcadeDB, ClickHouse, the model gateway, named-entity extraction and Laurium, on their own ports; the managed stores' networks (Postgres 5432, Valkey 6379, and 443 when OpenSearch is used); S3 and STS; Entra ID's sign-in host, `login.microsoftonline.com`, for the keys that sign every token; each proxied map provider's host; each host in `cloud_platform.connector_hosts`; each declared S3 bucket's and Athena workgroup's host |
| The workers | ArcadeDB, ClickHouse and named-entity extraction; the managed stores' networks; S3 and STS. No connection's host |
| The model gateway | The managed stores' networks (its database); STS; each model engine's host, while that engine is declared in `osprey.yaml` at render. Never S3 |

| Workload | Reaches |
|---|---|
| Laurium | The model gateway alone |
| ArcadeDB; ClickHouse Keeper | Their own copies |
| ClickHouse | Its own copies and, in the standard shape, ClickHouse Keeper; S3 and STS, for its backups |
| The backups' runs and the restore | S3 and STS; ArcadeDB and ClickHouse, or the cluster's API, as each needs (section 6a.8) |
| The search index's rebuild and drift check, when OpenSearch is used | ArcadeDB; the managed stores' networks (OpenSearch on 443); S3 and STS |
| The Glass | The Conduit |
| Superset, when reporting is on | The Conduit (who signed in); the managed stores' networks (its database and the mart, its rate limits); Entra ID's sign-in host |
| The report sync, when reporting is on | The Conduit; the managed stores' networks (the mart); S3 and STS; Entra ID's sign-in host (its token) |
| Named-entity extraction | Nothing beyond DNS |

**An engine's way out is made at render.** With no engine declared, no engine's host is allowed. An engine removed in *Admin › Models* keeps its host open while `osprey.yaml` declares it, and one first added there is refused until it is declared, rendered again, the new values installed and the Terraform applied (section 10.1). No pod reaches a mail server: Keycloak, which sent sign-in mail, is not rendered. A `mail:` section therefore does nothing here, yet whenever it is present the render still asks for its host's networks, and with `mail.username` set the Terraform asks for its password (a known issue).

Calico's open-source policy matches networks, not names, so each of those hosts names its networks in `cloud_platform.egress_nets`, and a host without them is refused at render ("egress is denied by default on a cloud platform (ADR-148 decision 7); name the networks of … under cloud_platform.egress_nets, or switch the feature off"). For S3 and STS a platform's file may name them instead (its `egress.service_nets`); the platform's file names none yet, so each deployment names them. **No network wider than /16** (IPv4) or /48 (IPv6), and never a default route, is accepted. Each host is reached on its own port: 443 for S3, STS, Entra ID and the engines' hosts, an address's own port, or, for `cloud_platform.connector_hosts`, `host:port` (a bare host meaning 443, listed at the head of `values.yaml`), so a SQL connection names its port there. The Conduit's own connector allow-list (`OSPREY_CONNECTOR_EGRESS`) holds the same hosts, without their ports.

**S3 buckets and Athena workgroups** that an S3 or Athena connection may read are declared under `cloud_platform.connector_sources` (ADR-140 Amendment 21), each with its host's networks in `egress_nets`:

```
cloud_platform:
  egress_nets:
    synthetic-exports.s3.eu-west-2.amazonaws.com: ["198.18.0.0/24"]
    athena.eu-west-2.amazonaws.com: ["198.18.3.0/24"]
  connector_sources:
    s3:
    - {bucket: synthetic-exports, region: eu-west-2, prefix: client-a/}
    athena:
    - workgroup: analysts
      region: eu-west-2
      databases: [visits]
      results_location: s3://synthetic-athena-results/out/
      table_locations: [s3://synthetic-lake/visits/]
```

The render writes `connector_sources.tf`: read-only statements on the namespace's role, scoped to each bucket and folder, each workgroup, its Glue databases and its tables' folders, and writes on each `results_location` alone. A statement wider than that, or a policy past IAM's 6,144 characters, is refused at render. Then render again, install the new values (`helm upgrade`) and have the platform team apply the Terraform; *Admin › Connections* accepts an S3 or Athena connection within what is declared, and refuses any other, at save, at **Test the connection** and before every read ("The render made no way out or read for … Declare it in osprey.yaml's cloud_platform.connector_sources, re-render, run helm upgrade and have the platform team apply the Terraform."). With nothing declared, every S3 or Athena connection is refused. The workers share the namespace's role, so they hold these reads by IAM, though no way out to them.

**What these reads do not do yet.** One S3 read takes no more than 1,000 objects under its folder: a folder holding more than 1,000 objects is refused whole, and nothing is written. A bucket whose objects are encrypted by a KMS key of its own (SSE-KMS) cannot be read, since the role is given no `kms:Decrypt`; one under S3's own encryption can. An Athena connection reads the default catalog, `AwsDataCatalog`, alone.

**Narrow the managed networks.** The platform's file names its whole shared VPC, `172.20.0.0/16`, as the managed stores' network, so every pod that reaches the stores may reach every address in it on those ports, other tenants' managed stores included. Narrow it to our stores' own subnets once the platform's team give them.

**Ingress, each workload's own.** Each workload admits only the pods that call it, on its own ports (`ospreyflow-ingress-<workload>`), and one that nobody calls admits nothing; the Glass also admits the platform's controller, on its own port. The Ingress serves the Glass at `network.public_origin`'s name and, with Superset on, Superset at its `bi.` name (whose pod also admits the controller); there is no `id.` (sign-in is Entra's). Its read and send timeouts are an hour, for the Glass's live updates, and its body-size limit is the Conduit's upload cap, 512 MiB; ModSecurity may refuse an upload long before that (the first question in section 6a.11).

### 6a.6 The policy check

`make cp-policy-check`, where the build's other gates run, renders **the repository's five synthetic deployments** (development, development with declared S3 and Athena sources, the poc shape, production, and production with a Bedrock engine), templates the chart with Helm, and fails on:

- a pod without `runAsNonRoot`, with a user or group other than 10001, or a supplementary group; privilege or a kept capability; a port below 1024; a `ReadWriteMany` claim; a `hostPath`; a volume's group walked at every start; an image not from the profile's registry; a container without its requests and memory limit, or, in the poc shape, without a CPU limit; a Dockerfile of ours not `USER 10001:10001`;
- no policy denying every pod's egress, or one ordered after Kubernetes' own policies; an allowing rule with no destination, a default route, a network wider than the cap, no protocol and ports, or a range or a named port; an allowing rule beyond DNS in a policy over every pod; a selector it cannot read;
- a pod no ingress policy selects, or an ingress rule admitting pods it cannot name;
- a pod taking a Secret whole, or mounting a service-account token, without being allowed to.

**A pass there says nothing about your own deployment**: run the same check on your own settings. It needs Docker (it runs Helm's own pinned image, so Helm itself is not needed), and runs from `OspreyFlow_Core` with the build's tools on the path (the folder holding the build's Makefile, `<build folder>` here), as `make` runs it:

```
PYTHONPATH=.:packages:<build folder> python -m tools.cp_policy_check --config osprey.yaml
```

The platform's own Gatekeeper constraints are not published to us, so the check does not run them.

### 6a.7 Signing in through Entra ID

**Sign-in on this profile is the organisation's Entra ID** (ADR-148 Amendments 6 and 8). The render reads `cloud_platform.claims` from `osprey.yaml` (Appendix A lists each setting) and gives the Conduit the tenant's issuer, audience and signing keys and the claim mapping; it gives the Glass Entra's sign-in, asking for `openid profile` and the API's scope. A render without `cloud_platform.claims` is refused, in words. Keycloak is not rendered: no pod, no `id.` name, none of its secrets.

**The mapping.** Clearance, organisational unit and handling codes each come from **one** source, never both: a named token claim (a directory extension attribute, say), or a table from Entra group id to value. In `osprey.yaml`, with placeholder ids:

```
cloud_platform:
  claims:
    tenant_id: 00000000-0000-4000-8000-000000000001       # the organisation's Entra tenant
    client_id: 00000000-0000-4000-8000-000000000002       # the Glass's app registration
    api_client_id: 00000000-0000-4000-8000-000000000003   # this API's app registration
    scope: access_as_user                                 # the delegated scope the Glass asks for (the default)
    clearance: {claim: extension_<app id>_clearance}
    org_unit: {groups: {00000000-0000-4000-8000-000000000011: unit-1}}
    handling_codes: {groups: {00000000-0000-4000-8000-000000000021: [R]}}
    groups_claim: groups                                  # the claim listing the person's group ids (the default)
    first_administrators: [00000000-0000-4000-8000-000000000031]
    token_version: "2.0"                                  # or "1.0": the access tokens' version (the default 2.0)
    api_id_uri: api://00000000-0000-4000-8000-000000000003 # this API's id URI (the default api://<api_client_id>)
    claims_mapping_policy: false                          # true when a claims-mapping policy signs the tokens
```

**No issuer, audience or key address is set by hand**: the render works each out from these and gives it to the Conduit. For `token_version: "2.0"` the issuer is `https://login.microsoftonline.com/<tenant>/v2.0` and the audience `api_client_id`; for `"1.0"` the issuer is `https://sts.windows.net/<tenant>/` and the audience `api_id_uri`. The signing keys are read from `https://login.microsoftonline.com/<tenant>/discovery/v2.0/keys` (or `…/discovery/keys` for 1.0), with `?appid=<api_client_id>` added when `claims_mapping_policy` is true. The Glass signs in at `https://login.microsoftonline.com/<tenant>/v2.0` whatever the version, by the authorisation code with PKCE, returning to the deployment's own address with a trailing `/`.

`groups_claim` names the token claim that lists the person's Entra group ids; every `{groups: …}` table is read from it. Leave it at `groups` unless the app registration emits the groups under another claim name.

A clearance or unit group grants one value; a handling-codes group grants a list, and a person's codes are the union of their mapped groups'. A group the table does not name grants nothing.

These fail to load:

- a source naming both a claim and a group table, or neither;
- an unknown key (`clearence`);
- an empty group table, or a group granting an empty value;
- a list in a clearance or unit table;
- a tenant, client or group id that is not a GUID in lower case, as Entra writes it;
- a tenant with no `client_id`;
- a `scope` that is empty or names more than one scope;
- an empty `groups_claim`.

A mapping other than the fixed claim names that Keycloak uses (`clearance`, `org_unit`, `receivable_handling_codes`, and `groups` for the groups) must name its tenant.

**Pinned to the tenant and to the Glass.** Every Entra tenant shares one set of signing keys, so a signature alone says nothing about whose token it is. With a tenant set:

- the signature must be RS256, whatever `OIDC_ALGORITHMS` says; a token up to 60 seconds past its expiry is still accepted, for clock drift;
- the Conduit keeps Entra's signing keys for `OIDC_JWKS_TTL_SECONDS`, and fetches them again for a key id it does not hold at most once every five minutes after a fetch that succeeded: a key Entra publishes within five minutes of such a fetch is refused until the next. One request fetches while the others go on with the keys held; a fetch takes at most five seconds in all, in threads of its own, and never holds up other requests. When a fetch fails after the keys' time is up, the keys held are used for up to an hour more (logged), so a short outage signs nobody out, and a key Entra has rotated out stays valid for that long too. If Entra cannot give keys (unreachable, refusing, an answer that is not a key set, or a set with no key the Conduit can use), sign-in is

refused with a 503 saying so ("sign-in is unavailable: the identity provider could not be reached. Try again shortly."), never as a rejected token, on the run API too;

- the Conduit's token check refuses to start unless its `OIDC_ISSUER` and `OIDC_AUDIENCE` are set, and checks both on every token;
- the token must carry `sub`, `oid` and `exp`, and its `tid` must be the tenant;
- the application it was issued to (`azp` in a v2.0 token, `appid` in a v1.0 token) must be `client_id`, so a token another application in the tenant obtained for this API is no session;
- its `scp` must include `scope` as a whole word (`access_as_user_extra` does not count).

**A person is keyed by `oid`**, Entra's object id, unique within the pinned tenant. Entra's `sub` differs for each application that asks, so it would split one person in two. On Keycloak the key stays `sub`.

**Refused, never guessed.** Each of these is refused at sign-in, never given a default:

- a missing clearance or unit, or a value of the wrong type;
- groups granting two different clearances, or two different units (two granting the same one are fine);
- a group overage, when the mapping uses a group table: past 200 groups Entra leaves the list out of the token, so such a person cannot sign in. The remedy is to have the app registration's tokens carry only the groups assigned to the application. A groups list longer than 200 is also refused, since Entra issues none;
- an empty handling code, alone or in a list;
- an `oid` that is not an object id, or another tenant's token;
- an app-only token (no delegated `scp`, or `idtyp: app`), which is a program, not a person;
- a guest from another directory (`acct` of `1`, or an `idp` naming another tenant or a provider that is not Entra), **while this deployment does not admit guests**, in these words: "this is a guest account, homed outside this organisation's Entra ID, and this deployment does not admit guests: an administrator can admit them in Admin › People". `acct` is an optional claim the app registration must ask for, so `idp` is the check that works without configuration.

**Guests are admitted only when an administrator turns it on** (ADR-148 Amendment 17). In *Admin › People*, **Admit guest accounts** is off on a new deployment; only someone holding `manage_people` can change it, and each change is recorded in the audit log (`set_guest_sign_in`, with what it was and what it is now). While it is on, a guest signs in as any person does: through the same mapping, so with the clearance, unit and handling codes their own token gives (a guest's token from another directory often carries none of your extension attributes or groups, and is then refused as anyone missing a clearance or unit is), and the roles you give them in *People and roles*, which marks them as a guest. Nothing gives a guest more than a member with the same token would have. Turning it off refuses every guest at their next request to OspreyFlow, an open live view included, and a run acting as a guest as its owner stops, counted as an owner who can no longer sign in (above); a guest stops counting as someone who can manage people, and is shown as not enabled. A reporting session a guest already holds in Superset is not ended by it: Superset reads a person's role only when they sign in to it, as it does for a person disabled here. Turning it off is refused while every enabled person who has signed in and can manage people is a guest.

On a deployment using the fixed names (Keycloak), a token carrying `tid` is refused, in these words: "token carries tid: an Entra ID token is refused without an Entra claim mapping".

**Roles are not read from an Entra token.** Its `roles` are app roles an Entra administrator assigns; an app role named `osprey-admin` makes nobody an OspreyFlow administrator. Roles are assigned in *Admin › People*, which keeps them in the deployment's own Postgres, by tenant and `oid`:

- **A person appears after their first sign-in**, with no role, or is added beforehand by object id (*Admin › People*, *Add a person by object id*). Names, sign-in names, passwords and removal are Entra's: *Admin › People* sends you to the Entra admin centre for them. *Disable* is the deployment's own, and a disabled person is refused at their next request, an open live connection included.
- **The first administrators** are named by object id in `cloud_platform.claims.first_administrators` (at least one; a render with none is refused). The Conduit gives each the Admin role when it first records them. Taking it from them later stands, with one exception: at a start when **nobody can manage people** (no enabled person who has signed in holds the right), each one named is given Admin again, added to what they hold, and the audit log records it (`grant_first_administrator`). That is the way back in: name a person who is not disabled here, render again, pinned (section 6a.4), install the new values (the list is in the ConfigMap, so a restart alone reads the old one) and restart the Conduit. With the settings `INSTALL.md`'s step 1 exports (the poc shape's), the values are installed by `helm upgrade --install "$RELEASE" "$CHART" -n "$NS" -f "$FOLDER/values.yaml" --timeout 30m`. In the poc shape `INSTALL.md`'s step 6 gives the render and the install as one block, fenced `bash later`.
- **Locking everyone out is refused.** A change that would leave nobody who can manage people is refused; only an enabled person who has **signed in at least once** counts, so a person added by object id who has never signed in is no proof anyone can administer.
- **Clearance and unit come from the token**, and are recorded at each sign-in. A clearance or unit recorded more than 24 hours ago is not trusted for anything given to that person without their being present: a case transfer to them is refused, in words saying their access is out of date, they cannot be named a case's Author, and a promotion's ageing alert leaves them out (the log says how many, and why), until they sign in again. While they are active it is recorded again at most hourly.
- **If the Conduit cannot read the store**, sign-in is refused with a 503 in words, never treated as no roles, and an open live connection is closed to be tried again later. The Glass then says the account could not be read, offers *Try again*, and keeps *Sign out* within reach.
- **A service identity** (an orchestrator's `ospreyflow run`) signs in with an app-only token of the pinned tenant, carrying an expiry. Its client must be neither the Glass's nor this API's own registration.
- **Superset** (ADR-148 Amendment 9) signs a person in as its own app registration and asks Entra ID for a token for this API's scope, issued to Superset, which the Conduit admits for `GET /v1/me` and `GET /v1/me/rights` alone (any other route answers 403 `route_not_admitted`). Superset's role is the person's rights here, read again at each sign-in: `administer_system` is its Admin, `manage_dashboards` its builder (Alpha), whom *Build a report* in the Glass sends there, `read_reports` its read-only Gamma, and a person with none of them is not let in.
- **A dashboard identity** (ADR-148 Amendment 10), registered in *Admin › Dashboards* by its app registration's application id and a name (the dashboard's), signs the report sync in with an app-only token carrying the app role `Dashboard.Read`; it reads the case list and the report feed alone, within its registration's clearance, unit and codes, and the cases whose Author gives it Viewer (never Owner or Editor, refused). Removing it in *Admin › Dashboards* takes away every case grant it held; registering the same application id again starts with none.

**A run acts as its owner as Admin › People holds them** (ADR-148 Amendment 16). Entra ID has no way for the Conduit to sign in as a person who is not present, so whatever runs as its owner uses what this deployment holds of them: their roles, and whether they are disabled, read from *Admin › People* at each run; their clearance, unit and handling codes as their last sign-in gave them. That is:

- **a pipeline's schedule and its watched folder** (developer guide, §6.3), **Run now** in *Admin › Operations*, which runs as the schedule's owner (section 9.11), and **`ospreyflow run`**, an orchestrator's trigger (section 8), which runs as the pipeline's owner;

- **a rule that runs on a schedule** (user guide, §7.11), and **the daily check for KYC documents that lapse**, which runs each KYC rule as the person who deployed it;
- **a screening list's refresh schedule**, a subscribed list's or a deployment-wide one's (section 9.5);
- **a watch's own runs**, and **at a load, anyone else's rules, hotlists and watches** (user guide, §7.5).

**The 24 hours.** The access held for a person is recorded when they sign in, and again at most hourly while they use OspreyFlow. A run is refused when that record is more than 24 hours old, or there is none (a person added by object id who has never signed in). Such a refusal decides nothing about the owner, so it never counts toward the three refusals that pause a schedule. What it says, and what happens next, depends on what was asked:

- **a slot of a schedule** (a pipeline's, a rule's or a list's), or a watch's run: "the schedule's owner, <id>, has not signed in to OspreyFlow within the last 24 hours, so their clearance and unit are out of date: it runs at its next slot after they sign in" (a rule's says "the rule's author"). A watch keeps its slot and is tried again each minute;
- **Run now** and `ospreyflow run`: the same, ending "run it again once they have signed in", since nothing asked for by hand runs again by itself;
- **the daily KYC check**: the rule's audit says the deployer is out of date and that "the documents that lapsed are not judged by this day's check; the rule judges its customers afresh at its next load". The check does not come back for that day;
- **at a load**: the owner's hotlists and watches are marked stopped, as for any owner who cannot be acted as, and are made active again at the first load after they sign in; a stopped watch's own runs wait for that load. Their rules are not judged at that load. The watch list shows *Stopped* and does not yet say why.

**Other refusals.** An owner disabled in *Admin › People* is refused, and three such refusals in a row pause a schedule, as on Keycloak; so is an owner *Admin › People* does not hold ("is not a person Admin › People holds"). If *Admin › People*'s store cannot be read, the run is refused as that and never counted. None of these says "the identity provider could not be reached": Entra is not asked.

**So a schedule runs only while its owner keeps signing in.** The 24 hours run from the owner's last recorded access, not from the day. An owner last active on Friday at 17:00, with a daily slot at 06:00: Saturday's run goes ahead (13 hours later), Sunday's and Monday's are refused (Monday's comes before they sign in that morning), and Tuesday's goes ahead. Give a schedule that must run unattended for longer an owner who signs in each working day. There is no unattended owner on this profile: reading a person's access from Entra itself at each run needs an application permission the organisation would grant, which this release does not ask for.

**A leaver's runs go on for up to 24 hours.** Disabling or removing a person in Entra stops their sign-in, but runs as them keep the access last recorded for up to 24 hours after it. Disable a leaver in *Admin › People* as well: that stops every run as them at once.

A load started by hand in the Ingest Studio (**Run now**, developer guide §3.9) runs as the person who starts it, and is not affected.

**Not yet tried against a real tenant.** The token shapes above are as Microsoft documents them, and one real token from the organisation's development tenant is to settle each:

- **v1.0 or v2.0 tokens.** An app registration left at its default is issued v1.0 access tokens, whose issuer is `https://sts.windows.net/<tenant>/` (not `https://login.microsoftonline.com/<tenant>/v2.0`) and whose audience is taken to be the `api://` application id URI rather than the client id. Set `token_version` to what the app registration issues.
- **Extension attribute names** are assumed to arrive as `extension_<application id without hyphens>_<name>`, or as `extn.<name>` through a claims-mapping policy. The mapping names whatever the real token carries.
- **A claims-mapping policy** has its tokens signed with an application's own key, read with `?appid=<api_client_id>` (`claims_mapping_policy: true`).
- **Guests**: that a real guest's token carries `idp` (and `acct` of `1`, where it is asked for), and so is refused while guests are not admitted and signs in once they are, while a member's resolves either way.
- **Access tokens, not ID tokens**: the Glass is to send an access token for this API. An ID token carries no `scp`, and is refused as app-only.

### 6a.8 Backups and restore

The managed stores (PostgreSQL on RDS, Valkey on ElastiCache, the media and staging buckets) are the platform's, under its own snapshots and versioning. **The deployment backs up what it runs itself** (ADR-148 Amendments 7 and 13): ArcadeDB, ClickHouse and the claims part. **The claims part holds, in every shape, the shared volume's folders the deployment cannot make again**: the published pipelines (`data/recipes`), the model settings (`model-settings`) and the map settings with the map key file (`map-settings`, ADR-147); and, in the poc shape, the Ingest root's claim. Each is read-only to the backup, and the pods that mount them are writers a restore refuses to run beside. **Not in a set**: the rest of the shared volume, `ospreyflow-shared`: the tiles (`tiles`), made again, and, in the standard shape, the Ingest root (`ingest`: uploads and the drop folder), which there is a folder of the shared volume, not a claim of its own. A restore leaves those as they are, so in the standard shape an upload can disagree with the stores it brings back. The recovery runbook that ships with the product, `deploy/RUNBOOK.md`, has the whole procedure under *The `cloud-platform` profile*, with every command; this section says what it does.

**Nightly, at 02:15 UTC**, whatever the cluster's time zone: the CronJob `ospreyflow-backup` (ArcadeDB's `BACKUP DATABASE`, then ClickHouse's `BACKUP … TO S3`) and `ospreyflow-backup-claims` (the claims part, in every shape: each folder and claim, read-only). Both write one set, `s3://<prefix>backups/sets/<YYYYMMDDTHHMMSSZ>/`, named by their slot, and `manifest.json` last, holding each part's size and checksum and the time the set finished. A set without its manifest is unfinished and is never restored from. Every object is encrypted by the backups bucket's own KMS key (`alias/<namespace>-backups`), whose deletion its policy denies against accident (an administrator who rewrites the policy can lift that, and the decommission does once the retention ends). Two roles write a set, ClickHouse's own and the runner's, each to its own prefix, by IRSA, so no key is stored anywhere; neither can erase a set. The bucket is versioned (an object overwritten keeps its previous version for 7 days), and a set's objects expire 35 days after they were written: the retention is 35 days in all, a proposal until the organisation agrees its own.

**Checking last night's backup.** A backup Job that completed wrote a finished set, and its log names it (`backup: set …`). **A failed run is a failed Job**, its log naming the store, the step and the refusing service's own words. **No alert is raised on it yet: look each morning** (the alert is *coming*). The runbook gives the commands, and the way to list every set, finished or not.

**A backup now**, before an upgrade or a decommission, is a Job made from each CronJob for one slot. The nightly run does not stop the Conduit, so its parts are taken minutes apart and a load running across 02:15 can be in one part and not another: take the backup before an upgrade with the Conduit and the workers stopped (the runbook shows how). Note each one's copy count first. The runbook's commands also scale `deployment/report-sync`, which is rendered only with reporting on (`reporting.sync`), so without it its "not found" is expected, and they scale the Conduit and the workers back to 1: start them again at the copy counts noted instead (a known issue).

**The restore** replaces what ArcadeDB, ClickHouse and the claims hold with one set, **for one copy of each store only**: development, and the poc shape. The production shape's restore is not supported yet, and the chart refuses it when the restore's Jobs are made (`helm template … --set`

`backups.restore.set=…`), in these words: "backups.restore: the restore is supported for one ArcadeDB and one ClickHouse copy; this deployment runs more, and its restore is not supported yet (ADR-148 Amendment 7)". In order:

1. **Room for a second copy.** Each store's restored copy is written beside the live one, so ArcadeDB's and ClickHouse's claims need free space for a second copy of their database; grow a claim first if not (the volume-expansion procedure is *coming*, section 6a.10).
2. **The managed database with the stores.** PostgreSQL must agree with the stores, or anything withdrawn or deleted since the set comes back under today's grants. The platform team restores RDS to the set's finish time by its own point-in-time procedure; the deployment is pointed at it only once nothing that writes runs (step 4). **RDS keeps its point-in-time restore for 35 days**, as the Terraform renders it (`backup_retention_period`), against the sets' 35: every set still kept can be restored with its database.
3. **No backup during the restore**: both CronJobs suspended, and any backup still running left to finish.
4. **Everything that writes stopped**: the render's own list, `backups.writers` in `values.yaml`, each one's copy count noted, then scaled to nothing and its pods gone; then the platform team points the namespace at the restored RDS instance.
5. **The restore's Jobs**, rendered for the set by its own name (never `latest`, never by `helm upgrade`) and applied, then each waited on.
6. **Everything started again**, ArcadeDB first, at the copy counts noted, each waited on until it is ready (the door answers), and the backups' CronJobs (`ospreyflow-backup`, `ospreyflow-backup-claims`) resumed. A healthy restore's logs end in plain words, with no stack trace: the runbook's *A healthy restore* quotes each step's last line.
7. **The search index rebuilt**, where the deployment searches with OpenSearch: the index is not in a set (it is rebuilt from the graph, ADR-150), so the restore ends with its rebuild, then the drift check between the graph and the index, each a Job started from its CronJob, held suspended (`ospreyflow-search-rebuild`, then `ospreyflow-search-drift`), and each waited on.

**It refuses, touching nothing**, while anything that writes still runs, while it cannot see what runs, or while any part of the set is missing, changed or another set's. Each store is replaced only once its restored copy is proven, ArcadeDB's beside the live database and ClickHouse's in a database of its own, then swapped in. **The parts are replaced one after another, not together**: a restore that stops part-way can leave some at the set and others as they were, and each refusal says which. **Running the same set's restore again is the safe way out.** Start nothing while a store's database is missing: the Conduit and the workers would create an empty one in its place. The runbook's *If it fails* lists each refusal, where the data is, and what to do.

**Measured, and not yet measured.** On a two-node test cluster with the platform's rules, against a simulation of S3, STS and KMS, on a test server shared with other work, with synthetic data (a 9.6 MB set): the backup took 7.1 s, the restore's Jobs 16.5 s, and destroyed-to-restored-and-compared 70.8 s, most of it the stores stopping and starting. These are not a service level: they leave out the Conduit's and the workers' own stop and start and RDS's restore, and a real restore grows with its set. **The restore is to be rehearsed and timed again on the organisation's development namespace before production holds real data.**

**Bringing the backups into a deployment installed without them** applies `backups.tf` first (ClickHouse cannot start without its backup role's service account and Secret), then orphans ArcadeDB's StatefulSet before the `helm upgrade`, since its new backups claim cannot be added in place; the runbook gives the commands.

### 6a.9 The model route

Every call to a hosted model goes through **the model gateway (LiteLLM)**, its own pod, `litellm`, rendered on this profile always, with or without an engine (section 6a.1). The Conduit and Laurium call it; nothing else does. Local models are not rendered here (the platform has no GPU). On this profile an engine is one of three kinds (ADR-135 Amendments 4 and 7):

- **Your organisation's own AI gateway** (`kind: gateway`), an OpenAI-compatible endpoint at its address (`api_base`, required), reached through LiteLLM's OpenAI-compatible route and signed in to by a token (`auth: key`, the default for this kind).
- **Amazon Bedrock in London** (`kind: bedrock`), reached at Bedrock's own runtime in `eu-west-2` and signed in to by **the gateway's own IAM role** (`auth: iam_role`, the default for this kind). No key is stored for it anywhere: not in `osprey.yaml`, our Secret, the Terraform, the models file or the gateway's entries, which name only its region.
- A hosted provider LiteLLM knows by its name (`kind: provider`, the default), by its key, as on every other profile.

The first two kinds are this profile's alone; on every other profile they are refused in words naming the profile. Each engine is declared under `models.providers` (or the single `models.provider`), with the settings Appendix A lists:

```
models:
  local_only: false
  sendable_handling_codes: [P]
  providers:
    - name: orggateway                      # your organisation's AI gateway
      kind: gateway
      api_base: https://ai-gateway.example.internal/v1
      label: Organisation AI gateway
      roles: {extraction: gpt-4o-mini}
      privacy_contract: true
      contract_reference: DPA 2026/07
    - name: bedrock                         # Amazon Bedrock in London
      kind: bedrock                         # auth: iam_role and region: eu-west-2 by default
      # a model's own id: check your account is offered it on demand in London
      roles: {extraction: anthropic.claude-3-haiku-20240307-v1:0}
  defaults: {extraction: orggateway}
cloud_platform:
  egress_nets:                              # each engine's host, by its networks
    ai-gateway.example.internal: ["198.18.4.0/24"]
    bedrock-runtime.eu-west-2.amazonaws.com: ["198.18.5.0/24"]
```

**The region answer is London, and only London.** `region` is Bedrock's alone and takes only `eu-west-2`, its default. A Bedrock model is named by its own id (`anthropic.…`); a cross-region inference profile's id (`eu.…`, `us.…`, `apac.…`, `global.…`, or any other part before the provider's) and an ARN are refused, since either may send the call outside London. A model Bedrock offers in London only through an inference profile cannot therefore be used here.

**Refused in words**, each naming the field and never its value, wherever an engine is read (`osprey.yaml` at render, the Conduit's start, the models file and *Admin › Models*): Bedrock by a key, with an address, or in any region but London; a region on any other kind; your gateway with no address, or by the IAM role (it signs in by a token for now, until its owners say how it accepts the namespace's identity); a provider by the IAM role; an engine named `bedrock` of any other kind; an address with anything before its host (`https://…@…`), a query or a fragment, key or not, or a path segment shaped like a key; and a label or contract reference shaped like a key, or holding one among its words. Write a reference with spaces: one long word mixing letters and digits is taken for a key.

**What the render makes for Bedrock, and what the platform team applies.** Only while a Bedrock engine is declared, the namespace's Terraform includes `gateway.tf` (section 6a.3). It makes:

| Resource | What it holds |
|---|---|
| `aws_iam_policy <namespace>-gateway-bedrock` | One statement: `bedrock:InvokeModel` and `bedrock:InvokeModelWithResponseStream` on `arn:aws:bedrock:eu-west-2::foundation-model/*`. No S3 action and no other service, so IAM itself holds the region |
| `aws_iam_role <namespace>-gateway` | Trusted for `sts:AssumeRoleWithWebIdentity` by the cluster's OIDC provider alone, with `StringEquals` on its `:sub` (`system:serviceaccount:<namespace>:<the gateway's account>`) and its `:aud` (`sts.amazonaws.com`) |
| The policy's attachment | The policy above, on that role |
| `kubernetes_service_account` | The gateway's own account, annotated with the role (`eks.amazonaws.com/role-arn`) |

The gateway's account is named in the platform's settings as `secrets.irsa.gateway_service_account` (`ospreyflow-gateway` on the client's platform). It must differ from the namespace's own account, whose role holds the buckets and is never the gateway's; a platform's settings naming no gateway account are refused at render, in words, when a Bedrock engine is declared. With no Bedrock engine declared, `gateway.tf` is not rendered and the gateway runs under no role, with no token mounted. The platform team applies `gateway.tf` with the rest of the namespace's Terraform, by pull request. IAM role names are account-wide, as `irsa.tf`'s are.

**The way out.** The gateway's pod alone reaches each declared engine's host, on its port: your gateway's host from its address (its own port, or 443); Bedrock's runtime in London, `bedrock-runtime.eu-west-2.amazonaws.com`, on 443; or a provider's own host, which the profile knows only for `openai`, `anthropic` and `gemini` (any other provider names its `api_base`, or the render is refused: "names no api_base, so its traffic's host is not known and cannot be allowed"). The gateway also reaches STS in the platform's region, whatever engine is declared, and the managed stores' networks, for its database; never S3 (section 6a.5). These hosts are in the gateway's own egress policy, `default.ospreyflow-egress-litellm`, and no other pod's. Name each engine host's networks under `cloud_platform.egress_nets`, as for any host; a host without them is refused at render with section 6a.5's words. With no engine declared, no engine's host is allowed out.

**What Admin › Models allows and refuses here** (section 10.1). It offers the three kinds. An engine is enabled only where the render made its way out (and, for Bedrock, the gateway's own role). Adding one the render did not make, or moving an engine to a host it did not make, is refused, the engine's name in brackets: "On this deployment an engine is reached only once the render has made its way out of the namespace, and it made none for this engine (bedrock). Declare it in osprey.yaml, re-render, and have the platform team apply the Terraform; then it can be enabled here." For a Bedrock engine without the gateway's role, "(and, for Bedrock, the gateway's own IAM role)" follows "namespace". Such an engine is also refused a key and limits, and one a restored models file names is marked *not made by the render*.

**The order.** For your gateway or a provider it is section 10.1's: declare it in `osprey.yaml`, render again, install the new values (`helm upgrade`), have the platform team apply the Terraform, then add it in *Admin › Models*. **For a newly declared Bedrock engine the Terraform comes first**: the new values run the gateway as its own service account, which only `gateway.tf` makes, so the gateway's new pod cannot start until it is applied (as with `backups.tf`, section 6a.8). Render again, have the platform team apply the Terraform, install the new values, then add it. An engine removed in *Admin › Models* keeps its host open for as long as `osprey.yaml` declares it; the host closes once the engine is taken out there, the deployment rendered again and the new values installed.

**Keys.** No key is asked for a Bedrock engine: its key state reads *IAM role: no key kept*, the screen offers no **Enter key** or **Remove key** for it, and the Conduit refuses setting or removing one. Your gateway's token is a key like any other: entered write-only with **Enter key**, or, for an engine declared in `osprey.yaml`, given to the Terraform as a sensitive variable (section 6a.3). **Test the connection** names what refused a call in words of its own for each kind: for Bedrock, the gateway's role (pointing at `terraform/gateway.tf`, not the bucket role), the model's access not enabled for the account, the role's credentials expired, or the model not offered on demand in London; for your gateway, its token or its own policy (the answer cannot tell them apart), a model not offered to the token, its rate limit, or a refusal in a form that is not OpenAI's (something in front of it).

**Laurium's key.** Laurium's own key on the gateway, and what it does until the key is held, are section 6a.1's.

**Not yet tried.** The route is checked as rendered, against a stand-in gateway, and not against AWS or your organisation's gateway: no account was reachable from the build. Still to be shown at the first install:

- that the gateway's role signs a real Bedrock call in London;
- whether the gateway's AWS client uses STS's regional endpoint: only `sts.eu-west-2` is allowed out, and the gateway's account carries no regional-endpoint annotation;
- whether a model's first use needs an administrator to enable it in Bedrock's *Model access*, or AWS Marketplace actions, first; newer Claude models are offered in London only through inference profiles, which are refused here;
- Bedrock's own words for a model not enabled, an invalid id and a model not offered on demand, which AWS does not document and *Test the connection* reads (none has been measured against Bedrock);
- any call through your organisation's own gateway, by its token, and whatever stands in front of it;
- your gateway signed in to by the namespace's identity, refused until its owners say how it accepts one.

### 6a.10 Coming

- **On Entra ID**: an owner's access read from Entra itself at each run, so a schedule runs on days its owner does not sign in (section 6a.7), display names (a person is shown by object id until then), and one real token from the organisation's tenant to settle the shapes section 6a.7 lists as untried.
- **The backups' alert** on a failed or missing run, the production shape's restore, the restore rehearsed on the organisation's development namespace, and the point-in-time restore of RDS done with it.
- **The volume-expansion and upgrade runbooks** for ArcadeDB and ClickHouse, and the disruption budgets' drain test.
- **Laurium reached from a screen** (the review queue's extraction), and run on the organisation's own engine at the first install.
- **A basemap on the platform**: the tiles bucket, and a basemap built elsewhere brought onto it.

- **The shared folders, the settings files and the recipes repository** off the one volume (the poc shape's Ingest root is off it already).
- **The standard shape's runbooks**, as the poc shape has.

### 6a.11 Questions for the platform's team

None stops the render; each is the team's to answer before the first install.

1. **ModSecurity's body limits.** Which request-body limits does the controller's ModSecurity apply to this Ingress? Its bundled recommended file refuses a body over 12.5 MiB (`SecRequestBodyLimit 13107200`), and may refuse one over 128 KiB that is not a multipart form (`SecRequestBodyNoFilesLimit 131072`); the Conduit's uploads are raw bodies. Does the snippet's `SecRuleEngine On` take effect over the bundled `DetectionOnly`? May the limits be raised for this Ingress, or the upload paths exempted? Until answered, the largest upload the platform takes is unknown, and may be well under 512 MiB. Whether the controller admits the `modsecurity-snippet` annotation at all (some installs refuse snippets) is part of the same question.
2. **The ResourceQuota** the namespace is given (section 6a.2).
3. **Calico's version**, and whether its policies take a tier: the render names them `default.`, as Calico 3.28 and later store them. The build's schema check (kubeconform) skips the schemas it does not have, so Calico's objects are not checked against one.
4. **Certificate coverage**: whether the platform's certificate covers the deployment's name. If not, name a certificate in `cloud_platform.tls_secret`.
5. **Node-local DNS**: whether the cluster runs it, since its address is outside `kube-system`, which `default.ospreyflow-allow-dns` names.
6. **The storage class's volume binding.** In the poc shape the Conduit mounts two ReadWriteOnce claims, the shared one and the Ingest root's. With `WaitForFirstConsumer` both are made in its node's zone; with `Immediate` they may land in two zones, and no node could mount both.
7. **KMS inside the allowed ranges**: whether the networks named for STS, or any regional range a pod is allowed, also hold KMS's addresses. No row names KMS, but Calico matches networks, not names.

1. **The namespace's LimitRange**: its default CPU limit, if any, which every container here would take, and whether the ResourceQuota counts `limits.cpu`, which would refuse every pod of the standard shape (section 6a.2).

Added in this guide, beyond ADR-148's own list:

1. **The managed stores' subnets**, to narrow `172.20.0.0/16` (section 6a.5), and the networks of S3's gateway endpoint and STS, for the platform's file.
2. **The sensitive variables**: how the environments repository's pipeline is given a key a person holds (a model engine's, a connection's, the mail server's password), since the Terraform takes each as a sensitive variable with no default, and its state then holds it (section 6a.3).
3. **The app registrations**: who in the organisation registers the Glass (a single-page application, returning to the deployment's address with a trailing `/`) and this API (exposing its scope), and makes the extension attributes or groups the claims name (section 6a.7). They are two registrations, `client_id` and `api_client_id`, not one.
4. **Volume encryption**: whether the platform's storage class, `gp2-expand`, encrypts its volumes. ArcadeDB's and ClickHouse's data, the shared volume and, in the poc shape, the Ingest root are encrypted at rest only if it does; the render does not check.

## 7. The answers file, `install.yaml`

Every question `install` asks can be answered in this file; unknown settings are refused by name.

| Setting | Meaning |
|---|---|
| `mode` | `lite`, `small` or `enterprise` |
| `components.dashboards` | Superset and report sync on (`true`, the default) or off |
| `folders.ingest` | The folder the Ingest Studio lists (absolute, or from `~`); default `~/OspreyFlow/ingest` |
| `folders.tiles` | Where a built basemap lives; default `~/OspreyFlow/basemap` |
| `folders.backups` | Where `ospreyflow backup` writes, each deployment's sets in `<this>/<deployment name>/`; never inside the checkout (absolute, or from `~`); default `~/OspreyFlow/backups` (section 13) |
| `models.local_only` | `true` (default): no case content leaves the deployment |
| `demo_packs` | A list of pack ids (section 11) |
| `paysim_file` | The downloaded PaySim file, when `paysim` is chosen |
| `mail.host`, `mail.port`, `mail.from`, `mail.starttls`, `mail.username` | A mail server for invitations (section 9.3); its password is never here |
| `cloud.provider`, `cloud.region`, `cloud.domain`, `cloud.size`, `cloud.dns_zone`, `cloud.admin_email` | Small (section 5) and Enterprise (section 6) |
| `cloud.api_cidrs` | Enterprise with `--cloud`: the addresses the cluster's API answers (section 6) |
| `cluster.namespace`, `cluster.storage_class`, `cluster.shared_storage_class` | Enterprise: the namespace, and onto a cluster you already have its storage classes (section 6) |
| `server`: `server.address`, `server.certificate`, `server.key`, `server.ca`, `server.ingest`, `server.redirect_http`, `server.listen_address`, `server.backups`, `server.memory_gib`, `server.gpu` | Small on your own server (section 5a); refused with `cloud` or `external`, and for Lite and Enterprise. `server.certificate` and `server.key` are required. `server.backups` is where backups are written (default `~/OspreyFlow/backups`); `server.memory_gib` is `auto` or a number of GiB, at least 16 (section 5a.2); `server.gpu` is `none` (the default) or `nvidia`, the local engine on the server's NVIDIA GPU (section 5a.4) |
| `admin_email` | Small on your own server: the first administrator's email |
| `sign_in.organisation`: `alias`, `label`, `issuer`, `client_id`, `trust_email` | Small on your own server: sign-in through the organisation's identity provider (section 5a.1). `alias` defaults to `org`; `issuer` is `https://`. Its client secret is never here — `OSPREY_ORG_SIGN_IN_SECRET` in the terminal — and a setting naming a secret is refused. `trust_email` is `false` (the default) or `true`, joining by email — only with the security officer's sign-off (section 5a.1) |
| `external` | The managed services the deployment runs on — written by OpenTofu, or by you for a cluster you already have |
| `config` | Use this `osprey.yaml` exactly as it is, instead of `components`, `folders` and `models` |
| `starter` | A starter, `<theme>-<domain>` (section 1a): fills in the answers below that are not given |

| Setting | Meaning |
|---|---|
| `appearance.brand`, `appearance.service_name`, `appearance.organisation`, `appearance.phase` | The look (appendix A's `appearance`); `govuk` needs `service_name`, which names the whole service |
| `demo_accounts` | `true` (default) makes the demo accounts; `false` makes none (the `blank` starter's answer) |
| `grading.scheme` | `5x5x5` (default), `3x5x2`, or a scheme file (`.yaml`, beside `osprey.yaml`): the scheme drawn items are graded in. Changed later only by `ospreyflow grading change` (§8), which changes the items and this setting together |

The answers become `osprey.yaml` (appendix A): `mode` sets `profile`, `components.dashboards` sets both `reporting.sync` and `reporting.superset`, and the address is `http://ospreyflow.localhost` for Lite, `https://<domain>` for Small and Enterprise, and `server.address` for Small on your own server (with `server.certificate`, `key` and `ca` as `network.tls`, `server.backups` as `components.storage.backups`, `server.memory_gib` as `resources.memory_gib`, `server.gpu` as `resources.gpu`, and `sign_in.organisation` as `governance.organisation_sign_in` and `governance.organisation_provider`).

## 8. Running it

| Command | What it does |
|---|---|
| `ospreyflow start` | Brings the deployment up and waits for every service; `--build` rebuilds from the checkout first |
| `ospreyflow stop` | Stops every container; nothing is removed |
| `ospreyflow switch [<name>]` | Makes this the deployment running: stops any other OspreyFlow deployment on the machine (each with its own settings), then starts and opens the named one (`default` for the checkout's; section 1a.1). `--list` names each deployment, running or stopped, and changes nothing. A deployment in another checkout is still picked with `OSPREYFLOW_HOME=<its product folder> ospreyflow switch` |
| `ospreyflow deployments` | Lists this computer's deployments — the checkout's as `default`, and each kept by name — with the starter each was made from, its address and whether it is running |
| `ospreyflow starters` | Lists the starters, and the install command for each (section 1a) |
| `ospreyflow status` | Each service's state and health; exits 1 unless everything is running and healthy |
| `ospreyflow open` | Opens the Glass in your browser |
| `ospreyflow logs [service] [--follow] [--tail N]` | The services' logs (the last 200 lines by default) |
| `ospreyflow apply` | Applies a changed `osprey.yaml` to the installed deployment (section 8.3): renders it again, keeps every password and key, asks for a newly enabled provider's key (from `OSPREY_MODEL_KEY_<NAME>` or a hidden prompt), and restarts only the services whose settings changed. It makes no account, adds no demo pack and touches no data |
| `ospreyflow repair-sign-in [--no-demo-accounts]` | Registers the sign-in again — the identity provider's clients, roles and the demo accounts (leave them out with `--no-demo-accounts`; a Small deployment installed without them never gets them), the Conduit's own client secret from the deployment's settings, which a wiped or re-imported identity provider no longer holds, the workspace's own client (which is given no refresh token), and the organisation's identity provider with its client secret, its first sign-in (refusing, or joining by email when `trust_email` is on) and the record of refused sign-ins Admin → People lists (section 5a.1); safe to run again, and prints no secret |
| `ospreyflow models` | Lists the model engines, each role's default engine, and whether each provider's key is present (yes or no — never the key) |
| `ospreyflow models key <name>` | Sets or replaces a provider's key, from `OSPREY_MODEL_KEY_<NAME>` in the terminal or a hidden prompt; writes it to `deployment.env` alone and restarts the model gateway (and the Conduit when the key's presence changes) |
| `ospreyflow models remove-key <name>` | Removes a provider's key; the provider stays enabled but shows "no key" and is not offered to analysts |
| `ospreyflow grading change --to <scheme> --mapping <file> --dry-run` | Says how many drawn items each line of the mapping (every grade of the old scheme to one of the new) would move, writes nothing, and gives the token the change needs. `--to` is `5x5x5`, `3x5x2` or a scheme file: a YAML file with `scheme` (a name of its own), `source`, `intelligence` and `handling`, each its list of grades. Runs beside a running deployment |
| `ospreyflow grading change --to <scheme> --mapping <file> --confirm <token> [--stop-api]` | Changes every live drawn item's grade, each keeping the grade it had before beside the new one; refused unless the token is the dry run's for the items as they are now, and while the Conduit runs unless `--stop-api` says to stop it. After the change it sets `grading.scheme` (a scheme file kept beside `osprey.yaml`), applies the settings and starts the Conduit. A refusal names the items it concerns and changes nothing; a run stopped part way leaves the Conduit stopped: run the dry run and the change again |
| `ospreyflow release export <dataset> --name <name> --release-version <version> --out <folder>` | Writes the dataset's release as a YAML bundle into a new, empty folder: `release.yaml` (`apiVersion: ospreyflow.io/v1`, `kind: DatasetRelease`, checked by `packages/schemas/release.schema.json`), the domain model, each published pipeline and each reference list's definition, and a small list's rows as a CSV named by its checksum. Never a credential, loaded data, case membership, an owner or a licensed screening list's rows. Does what Studio › Releases' *Export* does, as you: set `OSPREY_TOKEN` to your own sign-in token (and `OSPREY_API_URL` for another deployment's address). A pipeline marked above what you may view is left out, and the command says how many |
| `ospreyflow release import <folder> --dataset <id> [--dry-run]` | Reads a bundle whole (every file's SHA-256, nothing it does not list) and lands the model, the pipelines and the lists as drafts in the dataset, each pipeline through the Studio's own save gates; with `--dry-run`, says what it would write and writes nothing. A refusal writes nothing. Nothing goes live: make the model live in the Studio |
| `ospreyflow run <dataset> <pipeline> --external-run-id <id> [--version <n>\|latest] [--wait] [--fail-on held\|rejections>N%]` | Triggers a deployed pipeline as the deployment's service identity (`OSPREY_TOKEN_URL`, `OSPREY_CLIENT_ID`, `OSPREY_CLIENT_SECRET`, by client credentials); the run acts as the pipeline's owner, never as the identity. The same `--external-run-id` again loads nothing more. `--wait` waits for the run; `--fail-on` exits 2 when held rows or the share of rejected rows meets it, or when the run's counts are withheld. Exits 1 on a refusal, in words. Where people sign in with Entra ID (`cloud-platform`), the owner as *Admin › People* holds them, refused if they have not signed in within 24 hours (section 6a.7) |
| `ospreyflow map list` | Lists the map providers, each with its tier, whether its key is set (never the key) and its state; the local basemap, the place-name fonts and the prefetch areas |
| `ospreyflow map verify` | Checks every provider's attribution, and a tier-4 service's projection and zooms, in the Conduit |
| `ospreyflow map prefetch` | Fetches every prefetch area's tiles now, saying for each how many were fetched and any failure in plain words |

| Command | What it does |
|---|---|
| `ospreyflow map build <region> --unit <unit> [--planetiler-jar <path>]` | Builds the tier-1 basemap in the Conduit (the jar copied into the tiles folder first), and its place names as the gazetteer dataset `gazetteer-osm-<region>`, held by `--unit` (required; an unknown unit, or a re-build for another unit, is refused) |
| `ospreyflow images push --registry <registry> [--from <folder>] [--platform <platform>] [--dry-run]` | On the `cloud-platform` profile: builds our images from this checkout for the platform's nodes (`linux/amd64` by default; the Conduit without Java) and copies each third-party image by its digest, into the namespace's registry, following the render's `images.yaml` (`deploy/generated/cloud-platform/` unless `--from` names another). A repository the namespace's Terraform did not make, or a registry you are not signed in to, stops the push; `--dry-run` says each step and runs none |
| `ospreyflow uninstall [--keep-data] [--yes]` | Removes the containers; with `--keep-data` the data volumes stay, and the next install of the same deployment finds them; without it cases, accounts and indexes go too. Your checkout, `osprey.yaml` and your own folders are never touched. (Before the stores had named volumes, section 13, a reinstall did not find the stores' data) |

Every command takes `--name <name>` to act on a deployment kept by name, or `--name default` for the checkout's own (section 1a.1). Every service restarts itself if it stops; nothing is registered with the operating system.

**Enterprise** is looked after with Kubernetes' own tools, not these verbs (which drive a Compose deployment): `kubectl get pods -n ospreyflow`, `kubectl logs`, and `helm uninstall ospreyflow -n ospreyflow` to remove it (the stores' volume claims are left in place, and the classes OpenTofu makes keep a volume even when its claim is deleted).

### 8.1 Addresses

One front proxy is the deployment's only door. Under the address in `network.public_origin`:

- the **Glass** — with its four places, the Ingest Studio, Rules and Monitoring and Admin among them — at the name itself;
- **sign-in** (Keycloak) at `id.`;
- **dashboards** (Superset) at `bi.`, when dashboards are on.

Lite publishes port 80 (or its own address's port) and `2480` for the graph store's own tools, both on this computer only (`127.0.0.1`): other machines cannot reach a Lite deployment. Small publishes 80 (for the certificate and the move to HTTPS) and 443 on every network interface, because other people reach it. Small on your own server publishes 443 alone (80 only with `redirect_http`, and then only to redirect), and 2480 and the Conduit's door on the server only (section 5a). Which of them is plain HTTP and which HTTPS: the note **HTTP or HTTPS** in section 1. The Conduit's own port is published only with `network.expose_conduit: true` — on Lite, on this computer only.

### 8.2 Where things are

| Where | What |
|---|---|
| `osprey.yaml` (the checkout) | The deployment's settings; never a secret |
| `~/.ospreyflow/deployments/<name>/` | A deployment kept by name (section 1a.1): its own `osprey.yaml`, every file rendered from it, its `deployment.env` (`600`), and any `backups/` an earlier release wrote there (new sets go to the backups folder, section 13); `~/.ospreyflow/current` names the one last used |
| `deploy/generated/<profile>/` | The deployment: `compose.yaml`, `deployment.env` (every password and key it made), `Caddyfile`, `glass.json`, `realm.json`, `litellm.yaml`, `versions.lock`, `RUNBOOK.md`, `state/` |
| `backups/` | Backup sets an earlier release wrote here; no longer written, and `ospreyflow doctor` names any left (section 13) |
| `.install/` | The guided page's draft and answers; a release install's verified lock |
| `.cloud/` | OpenTofu's state for a Small server or an Enterprise cluster, and the cluster's kubeconfig — keep it private |
| Your ingest and basemap folders | As the answers named them |

`RUNBOOK.md`, written for each deployment, lists what runs, its paths and its addresses.

`deployment.env` is readable by your own account alone (`600`): `ospreyflow install` writes it so, and `ospreyflow apply`, `models key` and `models remove-key` keep it so.

### 8.3 Changing a setting

Edit `osprey.yaml` in the checkout, then run:

```
ospreyflow apply
```

It checks the file first, and if anything in it is wrong it says what, and changes nothing. Then it renders the deployment again from it, keeping every password and key the deployment already has, and starts again only the services whose settings changed; the rest keep running. A provider newly enabled under `models.providers` needs its key: give it as `OSPREY_MODEL_KEY_<NAME>` in the same terminal, or type it at the hidden prompt `apply` shows. `apply` makes no account, adds no demo pack, rebuilds nothing and never touches the stored data. Do not run `ospreyflow install` again over a running deployment to change a setting; `ospreyflow start --build` rebuilds the code but reads the settings the deployment already has.

A changed `deployment.name` names a different deployment, which `apply` refuses: install it as a new one.

## 9. People and accounts

Everyone signs in through the deployment's identity provider; the password is only ever typed on its own sign-in page. What a person may do is their **roles**; what they may see is their **clearance**, unit and handling codes, and the cases they are given.

**Where people sign in with Entra ID** (`cloud-platform`, section 6a.7), Entra holds their accounts, and *People and roles* gives them roles, adds them by object id before they first sign in, and disables them. What Entra holds is refused here, in words, each followed by "On this deployment Entra ID holds people's accounts...": inviting ("People are not invited here."), access ("A person's clearance, unit and handling codes are changed in Entra ID."), a sign-in's reset ("A sign-in is reset in Entra ID."), removing ("A person is not removed here: they would return, with no roles, at their next sign-in. Disable them instead,

or remove them in Entra ID.") and joining ("There is no organisation account to join."). **A dashboard identity** is its own Entra app registration, which holds its secret: *Dashboard identities* registers it by its application id, and shows no secret. Without an application id it is refused ("on Entra ID a dashboard identity is its own app registration: give its application id (the registration holds its secret)"), and so is the deployment's own application, the Glass's or the API's. No administrator can give a missing clearance or unit instead: a person whose token carries neither is refused at sign-in (section 6a.7). A person is shown by object id, not by name. A guest account, homed in another organisation's Entra ID, signs in only while **Admit guest accounts** is on, below the list (section 6a.7), and is marked as a guest in it; while it is off, a guest is listed as not enabled.

### 9.1 The Admin place

**Admin** is one of the four places (key `A`); Home and the place switcher offer it to whoever holds one of its sections' rights. A side list groups its sections, each shown only to someone holding its right, and each section's routes refuse anyone without it, so hiding a section is never the control. Under the GOV.UK theme the list is a GOV.UK side navigation.

| Group | Section | Right | What it does |
|---|---|---|---|
| People | **People and roles** | `manage_people` | Invite people; set their roles, clearance, unit and handling codes; the Super user preset; **Disable…** with its transfers (section 9.9), re-enable; reset a sign-in; remove an account; join someone the organisation's sign-in refused to their account (section 9.7); name an Author for a case that has none |
| People | **Roles** | `manage_people` | The built-in roles and their rights; custom roles; teams, their leads and cover (sections 9.2 and 9.8) |
| People | **Dashboard identities** | `manage_dashboards` | Register a dashboard's account (its secret shown once; on Entra ID, by its app registration's application id, with no secret shown), see when it last pulled, remove it |
| Data | **Datasets** | `administer_system` | Every dataset's kind, unit, highest marking, egress, promotion policy, Authors and linked cases (section 9.10) |
| Data | **Connections** | `administer_system` | The named connections pipelines read through: files, a SQL database, an HTTP API or JSON files |
| Running | **Operations** | `operate_schedules` | Every scheduled or watched pipeline (pause, resume, run now, change its time, its runs), and promotions waiting for review (section 9.11) |
| Running | **System** | `administer_system` | Each component's health, the models in use, the version and whether an update exists, and who dataset owners may be |
| Running | **Models** | `manage_models` | Model engines, each job's model, their keys, limits and usage (section 10.1) |
| Running | **Maps** | `manage_geospatial` | Map providers and their keys, the local basemap, prefetch areas (section 10a) |
| Policies | **Grading scheme** | `administer_system` | The deployment's grading scheme, read-only, with **Copy the grading change command** (section 8) |
| Policies | **Approval rights** (coming) | `administer_system` | Who may approve each kind of decision, and a warning where fewer than two can |
| Policies | **Uploads** (coming) | `administer_system` | The largest picture an analyst may add, and the formats accepted |
| Audit | **Audit** | `read_audit` | The audit log, filtered by who, what and when (section 9.11) |
| Demo packs | **Demo packs** | `administer_system` | Which packs are loaded, and the command that adds one |

**The guides from Home.** Home links this guide under Admin's card (**Read the administration guide (PDF)**), the user guide under the Glass's and the developer guide under the Ingest Studio's, each only for someone whose roles open that place. The Conduit sends a guide only to such a person and refuses anyone else in words (`GET /v1/guides/{user|developer|administration}`). Home shows the guides the Conduit's image was built with, so a new guide comes with a new image: on Small and `cloud-platform`, when a release's new images are installed; on Lite, with `ospreyflow start --build`.

**System → Acting for people** says "The Conduit cannot act for people: run `ospreyflow repair-sign-in`" when the identity provider refuses the Conduit's own credential.

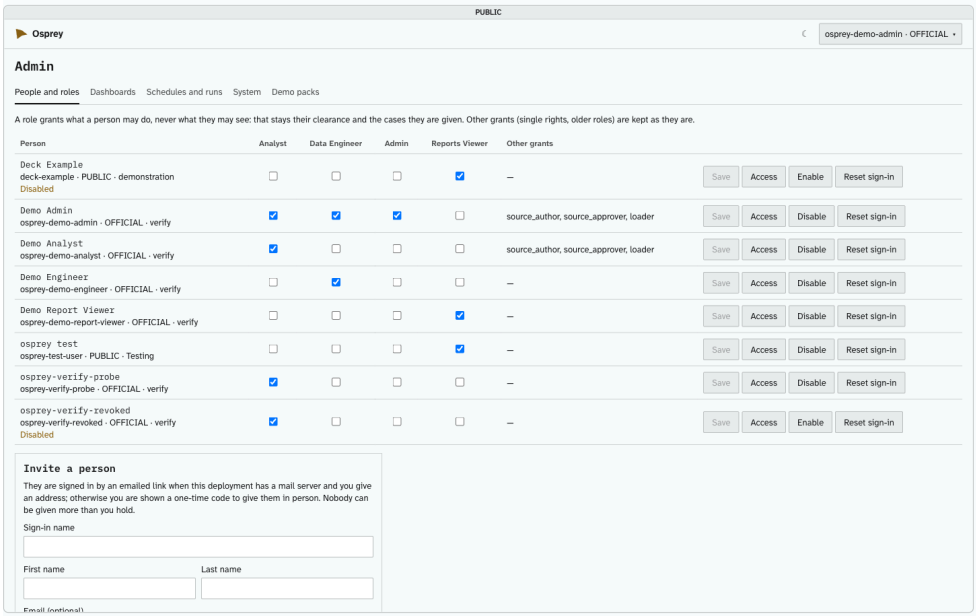



Figure 3. Admin → People and roles: each person's roles, with Access, Disable and Reset sign-in

### 9.2 Roles

The words below are the Glass's own, copied from `help/roles.ts`, the file the help page *Roles, teams and Authors* reads them from; a test (`test_guide_role_words.py`) fails if a copy here says anything different.

| Role | What it is for | Places it opens |
|---|---|---|
| **Analyst** | Investigates cases, works alerts and keeps watches. Reads figures and boards. | The Glass, Rules and Monitoring |
| **Data Engineer** | Builds and runs pipelines, reviews promotions into a dataset and decides held rows. | The Glass, the Ingest Studio, Admin (Operations) |
| **Administrator** (`osprey-admin`) | Looks after people, roles, teams, datasets and the deployment. Does not investigate by being one. | Admin, the Glass |
| **Reports Viewer** | Reads a case's figures and the dashboards, and sees the alerts on cases they can read. Never works an alert. | The Glass |
| **Rule author** | Writes the rules that raise alerts, and works the alerts in the queue. | The Glass, Rules and Monitoring |
| **Super user** (a preset) | Analyst, Data Engineer and Rule author together, given as three roles. Still never the second person on their own work. | All four |

**Custom roles.** Admin → Roles lists the built-in roles with their rights (**Copy ‹role› into a new role**) and the deployment's own under **Custom roles**, each with **Edit**, **Copy**, its versions and who holds it. **New role** asks for a **Role name** and its rights, grouped as Cases, Investigation (the Glass), Alerts and rules, Ingest Studio, Reporting, Administration and Other. **Nobody can give more than the person giving it holds** — clearance included — which is why the first administrator holds the highest clearance. A single right can also be given on its own. Each built-in role, a custom role, a team and its lead have a short tip in Roles, and People folds open **What each role and level lets a person do**. A refusal for a missing right names the roles that have it: "You need ‹Right›; the ‹Role› role has it. Ask an administrator to give it to you." (in Admin, after "Not done."). `write_sql_transforms`, the Ingest Studio's expert steps, is in no built-in role: give it on its own (developer guide, section 3.4b).

Each right, in plain words:

| Right | Lets a person |
|---|---|
| `create_case` | Start a case. |
| `share_case` | Give people a level in a case. |
| `remove_case` | Remove a case they are an Author of. |
| `export` | Export from a case, through the export checks. |
| `export_override` | Export an item that asks its originator first, with a reason. |
| `investigate` | Search, expand, follow paths and filter in a case. |
| `edit_graph` | Add and change entities and links in a case. |
| `confirm_inferred` | Confirm what a model suggested, so it is no longer inferred. |
| `extract_files` | Add files to a case, run extraction and decide its findings. |
| `resolve_entities` | Say two entities are the same, or not. |
| `record_assessment` | Record judgements, gaps and assumptions. |
| `ask_model` | Ask the model a question about a case. |
| `run_analysis` | Run analyses such as communities and centrality. |
| `propose_link_type` | Propose a new type of link. |
| `draw_on_boards` | Draw on a case's boards. |
| `promote_to_dataset` | Propose a drawn item for the dataset. |
| `propose_types` | Propose a new entity type. |
| `read_alert_queue` | See the alerts in a case's queue. |
| `triage_alerts` | Claim, close and hand back alerts. |
| `deploy_rules` | Turn rules on and off for a case. |
| `read_rule_audit` | Read who changed which rule, and when. |
| `read_held_rows` | See rows a load held back for review. |
| `decide_held_rows` | Release or reject held rows. |
| `trace_ownership` | Trace ownership and neighbourhood risk. |
| `keep_watches` | Keep watches and hotlists. |
| `load_screening_lists` | Load and refresh licensed screening lists. |
| `author_rules` | Write the rules that raise alerts. |
| `manage_strength_influencers` | Change what makes a link strong. |
| `edit_pipelines` | Build and change pipelines. |
| `verify_pipelines` | Test a pipeline against its sample. |
| `publish_pipelines` | Deploy a pipeline. |
| `run_pipelines` | Run a pipeline. |
| `schedule_pipelines` | Put a pipeline on a schedule. |
| `add_ingest_files` | Add files for a pipeline to load. |

| Right | Lets a person |
|---|---|
| `revert_loads` | Take back a load. |
| `edit_target_model` | Change a dataset's domain model. |
| `review_promotions` | Review items proposed for a dataset. |
| `accept_types` | Accept a proposed type into a domain model. |
| `merge_datasets` | Merge a drawn dataset into another. |
| `read_reports` | Read a case's figures and the dashboards. |
| `read_report_feed` | Download a case's figures for a dashboard. |
| `read_data_feeds` | See the data feeds a case's pipelines send. |
| `administer_system` | Change how the deployment runs. |
| `manage_people` | Add people and give them roles. |
| `manage_dashboards` | Register dashboards. |
| `operate_schedules` | Pause and resume schedules. |
| `manage_ontology` | Change the deployment's ontology. |
| `manage_geospatial` | Choose the maps the deployment shows. |
| `read_audit` | Read the audit log. |
| `read_export_ledger` | Read the record of what left the deployment. |
| `manage_models` | Choose the models and their keys. |

**Someone with no role sees no datasets.** A person holding no role (or only a role this deployment does not know) is told no dataset's name or id anywhere: the list a new case chooses from and the datasets a case reads come back empty, and a model engine's reason for being unavailable names none, whatever unit or case level they have been given. Home tells them "Your account opens no place yet. Ask an administrator to give you a role.", and *No cases to show* when they hold no case. A single right given on its own counts as a role here. Set their roles first, or straight after their access, and they see what that role allows.

**The first administrator** (`admin`, on a deployment with no demo accounts) holds both the **Admin** and the **Analyst** roles from the start, whether or not demo packs are loaded. The Admin role alone does not open a case's graph, and the first administrator is the Author of every demo pack's case there. An `admin` made by v0.4.6 or earlier holds Admin alone: add the Analyst role in People and roles.

### 9.3 Inviting someone

**Invite a person** asks for a sign-in name, their first and last name, optionally an email, a clearance, a unit, handling codes and, for each role, **Invite as ‹role›**. With a mail server configured and an email given, they get an email with a link to set their password. Otherwise you are shown a **one-time code** (sixteen letters in four groups) to give them in person; it is shown once, and at first sign-in they choose their own password. **Reset sign-in** works the same way.

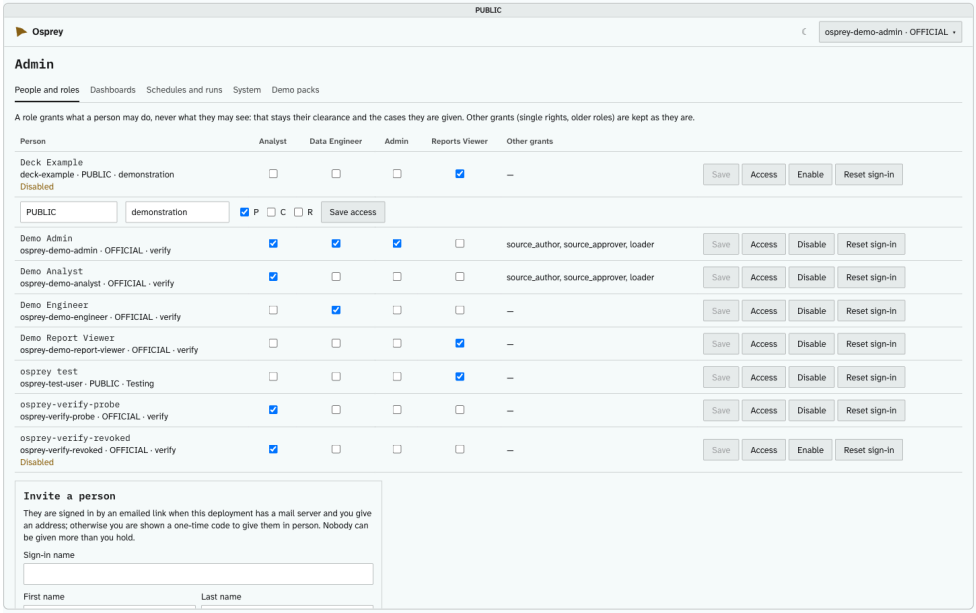



Figure 4. A person's access opened under their row: clearance, unit and handling codes

A mail server is set in `osprey.yaml`'s `mail:` (appendix A); if it signs in, its password is given once at install as `OSPREY_SMTP_PASSWORD` and kept only in `deployment.env`. With mail, the sign-in page also offers *Reset your password*.

### 9.4 Rules and alerts: who writes a rule, and whom its alerts reach

Analysts work alerts in **Rules and Monitoring** (user guide, section 7). A rule is written on a dataset in its **rule editor** (Rules and Monitoring → **What raises alerts**, *Write a rule on a dataset*), tested on the last 30 days, then made live. A rule has at most one draft and one live version at a time, and only the version that was tested can be made live; a rule's dataset is one its case reads. Who may do each, by right:

| What | Right, and the case level it needs | Built-in roles holding it |
|---|---|---|
| Write a rule and test it | `author_rules`, an Author of the case | Rule author |
| Make a rule live, or approve another's | `deploy_rules`, and Rules and Monitoring itself; an Author of the case | Analyst. A Data Engineer holds `deploy_rules` but cannot open Rules and Monitoring |
| Work an alert (claim, give, close) | `triage_alerts`, an Editor of the case | Analyst, Rule author |
| Read the alerts | `read_alert_queue`, and Rules and Monitoring itself (the Reports Viewer's Home lists the alerts on the cases they read) | Analyst, Rule author, Reports Viewer. A Data Engineer holds `read_alert_queue` but reads the queue's counts only, not its alerts |

Rules and Monitoring opens to whoever holds `triage_alerts` or `author_rules`, with `read_alert_queue`: a Data Engineer alone does not open it. **A Rule author alone cannot make a rule live**: give the person an Analyst role as well, or the **Super user** preset (Analyst, Data Engineer and Rule author, given as three roles). An administrator alone holds none of these. **No new rule covers the whole deployment**: a rule watches one dataset, chosen once in the editor.

**After updating to v0.5.0.** No one holds Rule author: give it in Admin → People and roles to whoever writes rules. `scripts.migrate_rules_to_datasets` (in the update's one-off steps) turns each rule that covered the whole deployment into one rule per dataset, in that dataset's home case, with the same conditions, owner and name: a running rule keeps running, and one still waiting for its first approval becomes a draft, to be tested and made live. Run it with `--dry-run` first: it says what it would do and writes nothing. The original rule is then retired, with a version saying why. **A dataset with no home case is reported, never guessed**: that rule is left whole and running, converted to no dataset, so that no alert is raised twice and no dataset goes unwatched. Make the dataset's home case and run the script again; the second run converts it. **A rule runs as its author**: on every run (a load, a schedule, a list's refresh, *Test*) its author must still hold `author_rules` or `deploy_rules`, or it raises nothing and the run says why ("the rule's author, ‹owner›, no longer holds author_rules or deploy_rules"). Check that each rule's owner holds one, and transfer the rules of someone leaving at **Disable…** (section 9.9).

**Whom its alerts reach.** A rule's alerts reach the case's team, or one team only when the rule says **‹Team› only**: that team's members and the Authors of the dataset's home case, enforced in the query (section 9.8). A drawn item's watch raises its alerts for its owner. A watched pattern's alerts reach its owner and the people of the owner's **unit** (the unit set on their account, section 9.3); a hotlist's alerts reach its owner, and the owner's unit too only when the hotlist is shared. Two settings in `osprey.yaml` decide hotlists:

```
monitoring:
  hotlist_audience: only_me        # or team: a new hotlist is shared with its owner's unit
  hotlist_audience_editable: true  # false: owners cannot choose, and a change is refused
```

`hotlist_audience` is where a **new** hotlist starts; it never changes an existing one, and every hotlist made before the setting existed reaches only its owner until the owner changes it. With `hotlist_audience_editable: false`, every new hotlist takes `hotlist_audience`, the Glass offers no choice and says so, and a change is refused in words. A match on data its owner cannot see is never shared. Change either with `ospreyflow apply` (section 8.3). Both are in appendix A.

### 9.5 Screening lists: subscribing, licences and the refresh

OspreyFlow screens customers against sanctions, PEP and adverse-media lists that the deployment **subscribes** to. Each list is read through its **connector**, which knows one publisher's own export format:

| Connector | Reads | Licence (as its publisher states it, 1 November 2026) |
|---|---|---|
| OFAC SDN list | `SDN.CSV`, with `ALT.CSV` and `ADD.CSV` beside it when present | A US Government work, in the public domain; OFAC's own pages state no licence |
| HM Treasury OFSI consolidated list | `ConList.csv` | Open Government Licence v3.0. **Reads a closed list**: the OFSI Consolidated List closed on 28 January 2026 and is no longer updated. Use the UK Sanctions List below for UK designations |
| UK Sanctions List (FCDO) | `UK-Sanctions-List.xml` (the XML format) | Open Government Licence v3.0 (Crown copyright). The only source of UK sanctions designations since 28 January 2026. Its XML schema carries a notice of its own about commercial use; OspreyFlow does not ship it |
| UN Security Council consolidated list | `consolidated.xml` | **Licence not confirmed.** No open licence found: the UN's terms of use allow personal, non-commercial use. Confirm with the UN before relying on it. Synthetic lists only until then |
| EU consolidated financial sanctions list | the FSF XML 1.1 file | The European Commission's reuse notice (Decision 2011/833/EU) |
| OpenSanctions | `entities.ftm.json` | **Licence not confirmed.** CC BY-NC 4.0: **non-commercial only**. Screening inside a business is commercial use and needs OpenSanctions' data licence. Synthetic lists only until then |

Check the licence for your use before you subscribe. The architecture's licence register (spec 00 §7) records where each statement was read.

**A closed list: OFSI.** HM Treasury closed the OFSI Consolidated List on 28 January 2026; the FCDO's UK Sanctions List is now the only source of UK designations. OspreyFlow keeps the OFSI connector, so a file you already hold can still be read, but nothing new will ever be published to it: the lists shown under What raises alerts say "Closed list" on such a list's row, and the Ingest Studio's **Import a list** offers its template as "OFSI consolidated (closed list)", beside "UK Sanctions List". To screen against UK designations, download `UK-Sanctions-List.xml` from the list's page (gov.uk/government/publications/the-uk-sanctions-list; the FCDO keeps it at a fixed address, `sanctionslist.fcdo.gov.uk/docs/UK-Sanctions-List.xml`), put it in the ingest folder, and import it with the **UK Sanctions List** template. OspreyFlow does not fetch it for you. The connector reads the XML only (its schema is published; the CSV's column order is not).

**Licence not confirmed: UN and OpenSanctions.** Until their licences for a customer's screening are confirmed, these two connectors read OspreyFlow's own synthetic lists only. What raises alerts marks each such list "Licence not confirmed", with the reason, and the Ingest Studio's **Import a list** names their templates "UN consolidated (synthetic only until licensed)" and "OpenSanctions (synthetic only until licensed)". A real UN or OpenSanctions file is refused, in words, even when this device's exceptions admit its dataset, and nothing loads; `python -m scripts.load_screening_list` refuses a list whose dataset is `opensanctions` or `un_consolidated` the same way.

**Real lists and this device.** OspreyFlow ships only synthetic lists. A real list loads only when this device's own `config/real_data_exceptions.yaml` (never committed, never copied between machines) names its dataset — for example `ofac_sdn` — for the use the subscription gives; otherwise the refresh is

refused, in words, and nothing loads. Add an entry with `python -m scripts.real_data_exceptions add`. A list counts as synthetic only when its file is one of OspreyFlow's own (`packages/demo_fixtures/screening_lists/`, known by its fingerprint); a file cannot make itself synthetic by saying so.

**Where lists live.** Lists are imported, mapped and refreshed in the **Ingest Studio → 2 Sources**, under **Screening lists**, by whoever holds `load_screening_lists` and opens the Ingest Studio, which needs `edit_pipelines`: a Data Engineer. An Administrator holds `load_screening_lists` but not `edit_pipelines`, so cannot open the Studio; give them the Data Engineer role as well, or use the command below. Rules and Monitoring → **What raises alerts** shows them, read-only: "Screening lists are imported, mapped and refreshed in the Ingest Studio's Sources. This tab shows them; it no longer adds or refreshes one."

**Importing, and a dataset reading it.** In **Screening lists**, **Import a list** asks for a **List name**, its **Template** (the connector), and its **File in the ingest folder** (for example `lists/SDN.CSV`); a list with no template maps its own columns, one for each screening field. Each list's row has **Subscribe**, so that the dataset you are in reads it (*Lists this dataset reads*). A location outside the ingest folder is refused. Put each new download of the list in the same place.

**The refresh. Refresh now** on a list's row (or, on the host, `python -m scripts.refresh_screening_list "<list name>"`, with `--list` to see the subscriptions) reads the file again and applies it as a new **version**: the publisher's own date where the format has one, otherwise the file's fingerprint. OspreyFlow compares it with the version before and re-screens every customer of every case with a screening rule against **the added and changed entries only**, as each rule's deployer and within that case's datasets; each new match is an alert in that case's queue, its link to the listed party inferred until a person confirms it. It is high-severity from a case's screening rule, and medium, listed as a *Watched pattern*, from one kept just for its author (a known issue: user guide, section 7.2). A file that is not in the connector's format fails in words and leaves the list as it was. Every refresh is recorded under **Latest refreshes**, with what it added, changed and removed, and how many customers it re-screened and how many alerts it raised **in your own unit**: each screening rule re-screens as its deployer, and its customers and alerts are counted for the deployer's unit alone, so an administrator never learns how many of another unit's customers a list touched. *Refresh now* answers the same way. The audit records who refreshed which list.

**When.** A list is refreshed when someone presses **Refresh now**, runs the command, or on the list's own **refresh schedule**, set from its row's **Manage** column with **Schedule**: **Refresh every day** or **every week** (and **On** which day), **At (UK time)**, then **Save schedule**; **Refresh by hand only** stops it. The **Refreshed** column says when each list is refreshed, or "by hand". A rule can also run **when a screening list refreshes** (user guide, section 7).

- **A scheduled refresh runs as the person who saved the schedule**, resolved afresh each time — never as the system. If they can no longer sign in or no longer hold `load_screening_lists`, that refresh is refused, recorded under **Latest refreshes** in words, and nothing is read; save the schedule again as someone who holds the right. Where people sign in with Entra ID, a refresh is refused while its owner has not signed in within the last 24 hours (section 6a.7).
- Each scheduled time runs once, whichever Conduit replica takes it; after downtime only the latest runs. A refresh that ran on its schedule says so under **Latest refreshes**.
- Put each new download in the list's location before the scheduled hour: the schedule reads the file that is there.

### 9.6 Approval rights: a second person

Three decisions wait for a second person with the right, and **the person who proposed one can never approve it** (ADR-133 decision 7):

| Decision | Who proposes it | Who approves it |
|---|---|---|
| Making a rule live on a dataset that asks for a second person (its **Promotion of drawn items** setting, *Second person reviews*; a composite asks if any member does) | An Author of the case who holds `deploy_rules` and opens Rules and Monitoring (an Analyst), once the draft is tested | **Another** Author of the case who holds `deploy_rules` and opens Rules and Monitoring (an Analyst): never the draft's author, or whoever asked for it to go live (on the rule's row in Rules and Monitoring → **What raises alerts**: **Approve**, or **Reject** and **Send the rejection** with words; each step is on the **Changes** tab) |
| Closing a **high-severity** alert another person may see | A member of the case who triages alerts (`triage_alerts`, Editor) | **Another** member who triages alerts in that case |
| A new version of the **installation-wide connection-strength influencers** (ADR-139) | Anyone holding `manage_strength_influencers` (the Analyst and Admin roles hold it) | **Another** person holding it |

A rule on a dataset that does not ask, or one kept just for its author, needs no approval. An alert only its owner may see (their own hotlist's, kept to them) is closed by its owner alone, since no second person may read it. Writing and testing a rule needs `author_rules`; making it live needs `deploy_rules` and Rules and Monitoring itself (section 9.4). A data engineer attaches rules to pipelines (Checks on load) but does not write them.

**So a dataset that asks for a second person needs at least two Authors of the case who hold `deploy_rules` and open Rules and Monitoring (Analysts)**; with one, a rule there can be tested but never made live.

**Approving influencers.** In the Glass's rail, **Connection strength**, a version waiting for a second person shows what it would put in force, who proposed it and why. Another holder of the right chooses **Approve version N**, or **Send it back** with words; its proposer sees the approval withheld and may withdraw it. Until a version is approved, the influencers shipped in the weights file are in force. Every version is kept, with who proposed and who decided it, and each step is in the audit stream. A case's Author may add influencers for that case, or switch off installation-wide ones in it, without a second person; that too is audited. Give the right singly (`right:manage_strength_influencers`) to someone who should set influencers without the rest of a role.

Every proposal, approval and rejection is in the case's rule audit, and every rule keeps its versions — who proposed each and who decided it. **After updating to v0.5.0**, a rule that covered the whole deployment is turned into one rule per dataset (section 9.4).

### 9.7 Removing someone, and joining an organisation account

**Remove** on a person's row deletes their account from the identity provider, once you confirm it: they can no longer sign in, and their sign-in name and email address are free again. Nothing they made is changed — cases, alerts, recipes and history keep their id, which is shown where their name was; the audit log's entry for the removal says whose id it was. A case whose last Author is removed is still reached by an administrator's access to its sharing. To keep the account but stop them signing in, **Disable** it instead. You cannot remove your own account, an account OspreyFlow itself uses (none is offered), or the last enabled person who can manage people.

**Refused organisation sign-ins** shows, above the people, everyone who signed in through the organisation in the last seven days and was refused because an OspreyFlow account already holds their email address (section 5a.1) — by their name at the organisation, how often, and when last. Choose the account that is theirs and **Join**; confirm, and their next sign-in through the organisation lands in that account, with its roles, clearance and cases. Join only when you

are sure they are the same person: the organisation said only that its account carries the same address. Each account joins one organisation account; an account already joined, or one OspreyFlow itself uses, is not offered. Every removal and every join is in the audit log.

### 9.8 Teams and leads

A **team** is a set of people with a lead. Admin → Roles makes one from a role (**Team for**): a **Team name** and an optional **Team mailbox**, then **Make a team**. Its status line says who leads it, who covers and until when, and who is acting today. **Name** sets the lead and **Hand over** passes it on; under **Cover for** and **Cover's last day**, **Save cover** names someone to stand in while the lead is away, and **End cover** ends it. Only a member of the team may be its lead or cover, the lead cannot cover for themselves, a cover needs a last day (today or later), and a service account is never a lead or a cover. A team can answer for a dataset (section 9.10); its members do while they are in it, and not after. A rule's alerts can be routed to one team (**‹Team› only**, under the rule's *Alert goes to*): only its members and the Authors of the dataset's home case read them, enforced in the query, and the lead, or their cover while it lasts, gives each to a member (**Give to (a member of the team)**) or sets it aside with **Suppress until...**, up to 90 days ahead, when it stays open and counted. *Coming:* a case level given to a team.

### 9.9 Disable, and what a person owns

**Disable...** on a person's row first reads what they answer for and asks who takes each item: "‹name› answers for N things. Choose who takes each one: nothing is deleted, and every transfer is audited." Each item has its own **Transfer to...**; then **Transfer and disable**, or **Confirm disabling** when they own nothing (and **Cancel**). It lists:

- the cases of which they are the only Author, a dataset's home case among them;
- the teams they lead;
- their hotlists, watches and saved patterns;
- the typology rules they own;
- their pipeline and screening-list schedules;
- their views and boards, private or shared;
- the link types they proposed that still wait for a decision;
- their watches on items they drew.

A transfer is refused, in words, when its recipient cannot take it: the person being disabled, a service account, someone disabled, someone of another unit, someone outside the team, someone without the right the item needs, someone who is not an Author of the case of a rule or pipeline schedule, someone without the level a view (Viewer) or a board, proposal or drawn item's watch (Editor) needs on its case, or someone not cleared to the item's marking: for a view or a board, the case's highest marking; for a proposal or a drawn item's watch, the dataset's highest (ADR-145 Amendment 9). People who are not cleared are left out of its **Transfer to...**. Items of another unit are left to that unit's administrator ("N transferred, and those stand; not disabled yet..."). You cannot disable your own account. **Enable** brings a disabled person back.

The panel ends with what it does not list yet: "Not listed here yet: promotions waiting for review, reviews waiting on them." It never names or counts an item you may not see. When the person owns some, it says so: the transfers you choose go through and stand, but the person stays enabled ("...not disabled yet: they still own items you may not see...") until an administrator who may see those items, or an Author of their case, transfers them. It reads this from `GET /v1/admin/people/{user_id}/ownership` (`manage_people`).

### 9.10 Datasets, their Authors and linked cases

Admin → **Datasets** lists every dataset: its **Kind** (*Source*, loaded through the Ingest Studio; *Composite*, read from several sources; *Drawn*, made by a drawing), its **Unit**, the **Highest marking it may hold** (or the deployment's highest), its **Egress** (section 10) and its details:

- **Promotion of drawn items**: *Author promotes*, or *Second person reviews*. It names who can approve, says "No one can approve a promotion: none of its Authors holds Review promotions." when nobody can, and warns when fewer than two people can ("one absence stops every promotion").
- **Authors**: the people or team who answer for the dataset, who are its home case's Authors. **Change owner of ‹dataset›** asks "Who answers for ‹dataset›?" and is audited. Before its first *Make live* a dataset says "Not live yet: who answers for it is asked at its first Make live."
- **Linked cases**: every case reading it, open or removed, with its analyst layer's items, links and size (never the layer's contents), the home case tagged. For a removed case's layer, **Merge ‹case› into the dataset (dry run)** and **Delete ‹case›'s layer (dry run)** say what each would do. After the delete's dry run, **Delete ‹case›'s layer now** ("It cannot be undone.") deletes it: its items are withdrawn and kept in the audit, and promoted items are not touched (`POST /v1/admin/datasets/{dataset_id}/cases/{investigation_id}/delete`, `administer_system`, a dataset of your own unit only). One of the dataset's Authors may also delete it in the Ingest Studio's 4 Runs (developer guide, section 7.8). The merge is done only there, by one of the dataset's Authors after their own dry run.

**Who may be an owner.** Admin → System's **Dataset owners may be** is *People and teams* (the default), *People only* or *Teams only*. It governs every naming of a dataset's owners; a client who wants no person's name shown as an owner chooses teams only. A service account is never an owner.

**A home case per dataset.** Every dataset has one home case, named for it and of its unit. It holds the dataset's own reports and its alerts that belong to no working case. It is made at a dataset's first *Make live*, which refuses to go live until someone answers for the dataset ("who answers for this dataset?"), and with a drawing made as a case of its own. For datasets that existed before, `python -m scripts.make_home_cases` gives each its home case, dry run first.

### 9.11 Operations and Audit

**Operations** (`operate_schedules`) has the schedules (pipeline, case, schedule, owner, next and last run; **Pause**, **Resume**, **Run now**, **Save schedule**; **Run now** runs as the schedule's owner, so where people sign in with Entra ID it is refused, in those words, while the owner has not signed in within the last 24 hours: section 6a.7) and **Promotions waiting for review**: the load, the dataset it goes into, who sent it, when, and how long it has waited. **Alert the reviewers and administrators after N days** (1 to 90) sets when a waiting promotion is overdue; an overdue one alerts the dataset's Authors who hold `review_promotions`, and administrators of its unit. A promotion is listed only to someone who may review it; with none, it says "No promotion you may see is waiting for review." Each overdue one raises its alert once, and its row reads "‹N› days, overdue".

**Audit** (`read_audit`) reads the audit log. **Which entries** chooses the record (*Cases, people, datasets and loads*; the *Rule audit of one case*; or the *Engines' history*, which also needs `manage_models`), a kind (analyst assertions, loads and promotions, types, people and roles, datasets, reads and refusals), a person, a case, a dataset and a period; then **Show entries**. Each entry gives when, who, what, its kind, its case and its words. Entries about another unit's cases are not shown, and where your own read of a record would not show its words, the entry says "Withheld: your own read of this record would not show them".

## 10. Models

By default every model runs on the deployment itself (extraction, vision, transcription and embedding — appendix A, `models.*`) and **no case content leaves it**. A client with its own agreement with one or more model providers may enable them as further **engines**: `openai`, `anthropic` and `gemini` (Google), and other LiteLLM providers such as `azure` or `bedrock` in the same shape.

```
models:
  local_only: false
  sendable_handling_codes: [P]
  providers:
    - name: gemini
      roles: {extraction: gemini/gemini-2.5-flash}
    - name: openai
      label: OpenAI (client tenancy)
      roles: {extraction: gpt-4o, vision: gpt-4o-mini}
      privacy_contract: true
      contract_reference: DPA 2026/07
  defaults:
    extraction: gemini
```

- **`providers`** lists each enabled provider: its model for each role it takes, an optional `api_base` (`https://` only) and an optional `label` — the name analysts see. Without one, the label is OpenAI, Anthropic or Gemini.
- **`defaults`** names each role's default engine: `local` or a provider's name. A role not named runs on `local`.
- **`privacy_contract`** marks a provider as under a privacy contract: set it to `true` only when your organisation holds a data-processing agreement with the provider that covers this key. It is `false` unless you set it. **`contract_reference`** says which agreement, in words ("DPA 2026/07"); it is shown to analysts, so it is never a secret, and one that looks like a key is refused.
- The older single `provider:` is still read, as a one-entry list whose roles default to it. Naming both `provider` and `providers` is refused.

**Keys.** Each provider's key is `OSPREY_MODEL_KEY_<NAME>` — for example `OSPREY_MODEL_KEY_GEMINI` (the single `provider:` keeps `OSPREY_MODEL_PROVIDER_KEY`). Give it in the installer's terminal before `ospreyflow install`, or on the guided install's Models screen; an enabled provider without its key stops the install, and a later install keeps a key already given. To enable a provider on a running deployment, add it to `osprey.yaml` and run `ospreyflow apply` (section 8.3), which takes its key from `OSPREY_MODEL_KEY_<NAME>` or asks for it at a hidden prompt. On a running deployment, `ospreyflow models key <name>` sets or replaces a key and `ospreyflow models remove-key <name>` removes it (section 8); `ospreyflow models` says whether each is present. A key is kept in `deployment.env` alone and read only by the deployment's model gateway — never by the Conduit, never written to `osprey.yaml`, never shown in the Admin area or any page of the Glass.

**On the guided install page** (section 4.1), the Models screen has a key field for each enabled provider. A key typed there is sent only to the install page, on this computer — a request from anywhere else is refused — and is held there until the install gives it to `deployment.env`. It is never written anywhere else, never logged and never shown again: the field empties once the key is sent, and the page says only "key set" or "no key".

**What may leave.** Material is sent to a provider only when both of these allow it:

- **its handling code** is in `sendable_handling_codes` (one list, for every engine); and
- **every dataset it comes from** allows that provider. Each dataset has an **egress** setting: - `none` — never sent to a hosted engine. **This is every dataset's setting until you change it.** - `contracted` — sent only to a provider marked `privacy_contract: true`. - `any` — sent to any enabled provider.

Anything else runs on the local engine, whatever was chosen, and is refused in words when the deployment has no local model for the role. Material whose datasets are not known is treated as `none`, so nothing leaves by omission. Embeddings never leave the deployment.

**Setting a dataset's egress.** Only an administrator sets it: Admin → Datasets lists every dataset, the unit that holds it and its egress; choose the setting and press Save beside it. Each change is recorded in the audit log — who made it, when, and from what to what.

> **After upgrading to this release, hosted engines receive nothing** until an administrator sets
>
> a dataset's egress to `contracted` or `any`. Every existing dataset, demo packs included, starts
>
> at `none`; until you change one, every question runs on the deployment's own models, whatever
>
> engine an analyst chooses. Set only the datasets you are entitled to send.

**Who chooses.** The administrator sets each role's default. An analyst may choose, for each question in Ask the case, among the engines offered — the local engine and each enabled provider that has a key — each shown "under contract" or "no contract". An engine the case's datasets may not reach is shown but cannot be chosen, with the reason beneath the choice. Ask to search offers the same choice: its question goes under the case's handling and from the case's datasets, through the same two checks, and the deployment's own model answers whenever they do not allow the engine chosen. Every answer names the engine and model that produced it.

Admin → System shows each role's model, each engine with its models, the roles it is the default for, whether its key is present and whether it is under a privacy contract (with its reference), and a notice that case content then leaves the deployment. `ospreyflow models` shows the same mark beside each provider ("privacy contract: yes (DPA 2026/07)" or "privacy contract: no"), and the guided install's Models screen shows it as the configuration holds it.

### 10.1 Models in Admin

Admin → **Models** (`manage_models`) does on screen what `ospreyflow models` does from the command line, which stays for headless use and recovery. **What the installer declared** says whether the deployment is local-only (`local_only` in `osprey.yaml`). **Engines** lists each engine, its jobs and models, whether it is under a privacy contract, its key, its limits and **Edit**, **Set limits**, **Enter key** or **Rotate key**, **Remove key**, **Test the connection** and **Remove**; **Add an engine** adds one. A key is **write-only**: its field says "not shown, never sent back", and the screen says only *Key set*, *No key*, or *Key lost: enter it again*. **Each job's default engine** sets the engine for extraction and Ask, image description, transcription and embeddings. **Limits** are requests a minute, tokens a minute and a token budget for a period, applied by the gateway on the engine's own key. **Usage** gives each engine's calls, failures and tokens by job, from the gateway's own records, never by person. Every change is in **History** and the audit log.

**On a cloud platform** (`profile: cloud-platform`), an engine is reached only once the deployment's render has made its way out of the namespace, and for Amazon Bedrock the gateway's own IAM role, whose service account the platform's settings name as `secrets.irsa.gateway_service_account` (ADR-135 Amendment 8). Admin → **Models** therefore refuses, in words, to add an engine, or to move one to an address, that the render did not make: declare it in `osprey.yaml`, render the deployment again, install the new values (`helm upgrade`, which restarts the pods that read them) and have the platform team apply the Terraform, then add it here: the order *Admin › Connections*' own refusal gives (section 6a.9 has the whole route). For a newly declared Bedrock engine the Terraform comes first, since only it makes the gateway's service account (section 6a.9). This refusal's own words leave out installing the values (a known issue). An engine a restored models file names but the render did not make is marked *not made by the render* and is neither offered to analysts nor given to the gateway.

**The extraction engine, on a cloud platform.** Under **What the installer declared**, *Admin › Models* shows the review queue's extraction engine, read-only: "Extraction engine: Laurium, chosen at set-up: change it in osprey.yaml, re-render, and have the platform team apply it." (or *OspreyFlow Deep read*); no screen reaches Laurium yet (section 6a.1). Laurium is a service the render makes, so nothing in Admin changes it: set `models.extraction_engine` (`deep_read` or `laurium`; left unset, `laurium` on this profile), then follow section 6a.4 in its order (the unpinned render, `ecr.tf`'s pull request applied for Laurium's repository when it is newly chosen, the push, the pinned render), and install the new values (`helm upgrade`). Here the Terraform comes before the values, unlike the engines' and connections' order above, since Laurium's repository must exist before its image is pushed. As with the engines' refusal, the row's words leave out installing the values. Switching back to `deep_read` leaves Laurium's repository holding its images, and the Terraform cannot remove a repository until it is emptied.

## 10a. Maps

Admin → **Maps** (`manage_geospatial`) holds the map providers, the local basemap and prefetched areas; `ospreyflow map list`, `map verify`, `map prefetch` and `map build` do the same from the command line (section 8).

- **Providers**, tier 1 to 4, each with its attribution and licence, its key, its state, **Make the default**, **Edit**, **Enter key** or **Rotate key**, **Remove key** and **Remove**; **Add a provider** adds one. A key is kept the way a model key is: never shown back, and never given to the browser. Where more than one provider is drawable, analysts choose between them with the map's **Basemap** switch.
- **The local basemap**: choose the **Region to build**, the **Unit the place names are held by** (empty: your own) and **Build the basemap**; **Verify the providers** checks each one answers. The build also makes the region's gazetteer dataset, held by that unit. A dataset takes a gazetteer of its own unit (`PUT /v1/datasets/{dataset_id}/gazetteers/{gazetteer_id}`, with `run_pipelines`): its places are copied into the dataset, so a case still reads one dataset; removing it deletes nothing ("…its places stay in this dataset as its own, and the map's place search no longer offers them…"). On screen, the case's map shows **Gazetteers in this case's dataset** beside its place search, each "added" or "not added", with **Add** and **Remove** for holders of `run_pipelines`; a case reading a composite dataset or a drawing takes none.
- **Prefetch areas**: areas whose tiles are fetched ahead of use, and **Fetch every area** by hand only, every 6 hours, every day or every week.

**On a shared platform** (`cloud-platform`), a provider whose tiles the Conduit fetches (its proxy) is reached only through a way out the render made from `osprey.yaml`'s `map:` section (section 6a.5). One added here is given none, so its tiles cannot be fetched until it is declared there, the deployment rendered again and the new values installed. **Build the basemap** is not available there (section 6a.1).

Changes are in **History** and the audit log.

## 11. Demo packs

| Id | What it shows | How it arrives |
|---|---|---|
| `hmp` | Prison intelligence: a prison's people and places, cell shares, co-defendants, conflicts, incidents, visits in person and by video, phones, calls and payments (synthetic) | Generated |
| `fixture-corp` | Network shapes, and duplicate records matched without being merged (synthetic) | Generated |
| `operation-ledger` | Preventive AML: a structuring ring, onboarding screened before it commits, ownership through a trust (synthetic) | Generated |
| `prison-intelligence` | Prison intelligence, end to end: a fictional jail's records as an intelligence team receives them, loaded through the Ingest Studio from source files, each with its own marking (synthetic) | Generated |
| `prison-intelligence-scale` | The same estate at scale: 3,000 prisoners and 30,000 links across six establishments, to show a large network grouped by community (synthetic) | Generated |
| `cyber-intrusion` | Cyber threat analysis in STIX 2.1: a fictional threat actor's campaign against a water company — its backdoor, two command-and-control servers, the indicators that find them and the traffic observed; its case is set to STIX (synthetic) | Generated |
| `paysim` | Mobile-money fraud: 6.36 million simulated transactions with fraud labels | Downloaded by you |
| `enron` | **Real data**: about 150 people's real email at Enron, 1998–2002 — who wrote to whom, when, and about what | Downloaded by you; accepted before it loads; never by an install |

**Which a starter brings** is section 1a's table: a starter loads its domain's packs, into cases set to its domain's packs. A **public dataset** of your own choosing, such as a VAST Challenge dataset, is added with `ospreyflow demo add public` (section 1a.2).

Choose them at install (`demo_packs`), or later: `ospreyflow demo list`, `ospreyflow demo add <id>`. Each loads into its own case, with the installing administrator as Author: the demo administrator where there are demo accounts (the demo analyst its Editor), and otherwise the first administrator, `admin`, in their own unit, with no Editor (section 1a); they hold the Analyst role as well as Admin, so the case opens for them. Adding **HMP** again is safe: a deployment that loaded it before v0.2.0 gains only its prison network, in the same case, and one that already has the network is left as it is. **PaySim** is a download: get `PS_20174392719_1491204439457_log.csv` from its Kaggle page and pass it with `ospreyflow demo add paysim --file <path>`; it is checked by size and checksum before anything starts. PaySim is CC BY-SA 4.0 (E. A. Lopez-Rojas, A. Elmir and S. Axelsson, 2016); its licence and attribution travel with it.

**Prison Intelligence** seeds its case through the Ingest Studio's own pipelines, as a data engineer would, and has commands for rehearsing a demonstration: `--reset-live` between rehearsals, and two for the session itself (`DEMO_GUIDE.md` in the repository gives each, in full). It needs `components.post_ingest_resolution` off (appendix A), or a live load in the demonstration adds automatic "same as" links and every rehearsal reset then refuses. An install whose `demo_packs` names it (the `crime` starter's does) writes the setting off itself (section 1a). Added later, on a deployment where it is

on, `ospreyflow demo add prison-intelligence` refuses, in words, with nothing added: set `post_ingest_resolution: false` under `components:` in the deployment's `osprey.yaml`, run `ospreyflow apply`, then add it again. Resolution is the whole deployment's setting; no case or dataset can turn it off on its own. Its **scale cohort** (`prison-intelligence-scale`) is written straight into the graph in a case of its own, with no pipeline runs, so the rehearsal reset does not touch it; adding it again changes nothing, and a run that stopped part-way says so rather than finishing it. `python -m scripts.write_pid_files --out <folder> --profile scale` writes its 3,000 prison numbers as `scale_cohort_list.txt`, to paste into *Add many from a list*.

**Enron** is the one pack of **real personal data**: the email of real people, released during the US regulator's investigation and distributed by Carnegie Mellon University. OspreyFlow never carries it, and an install never adds it. To use it, download `enron_mail_20150507.tar.gz` (423 MB) from https://www.cs.cmu.edu/~enron/ yourself, then:

```
ospreyflow demo add enron --file enron_mail_20150507.tar.gz
```

It checks the file is exactly the May 7, 2015 version (size and SHA-256), then says what it is — real people's names, addresses and private correspondence; **no licence is stated**, CMU distributing it "as a resource for researchers" and asking that you "be sensitive to the privacy of the people involved"; your organisation needs its **own lawful basis** to process it — and loads it only when you type `yes`. (`--accept-real-data` accepts in a scripted run, and says so.) It is unpacked into the demo data folder — 150 mailboxes, about 517,000 messages and 2.5 GB, so allow 3 GB free with the download — with a record of the acceptance beside it, and loads into its own case, "Enron corpus (real data)", shared with no demo account but the administrator and analyst. The terms are in `packages/demo_fixtures/licences/enron/NOTICE.md`.

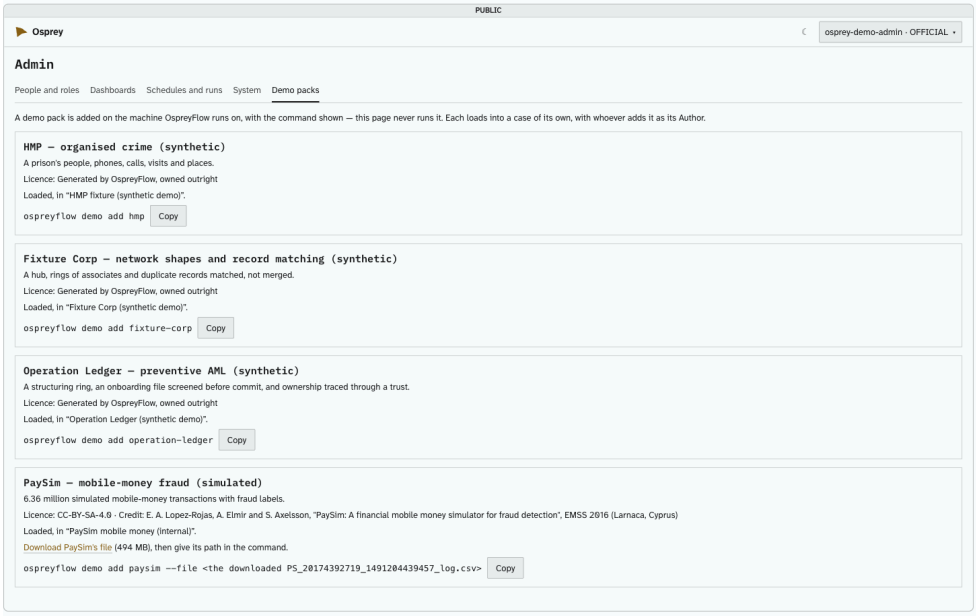



Figure 5. Admin → Demo packs: what each pack shows, where it was loaded, and the command for the rest

## 12. Dashboards

With dashboards on, **report sync** pulls each case's figures into a reporting database every 15 minutes (`reporting.sync_interval_seconds`), and **Superset** shows them at `bi.`, signing people in through the deployment's identity provider (below). A business intelligence tool (Power BI, Tableau, Qlik) reads the same figures:

1. register the dashboard in Admin → Dashboards and copy its secret (shown once);
2. add it to `REPORT_SYNC_DASHBOARDS` in `deployment.env` (a JSON list of `{"client_id", "secret"}`) and restart: `ospreyflow stop`, `ospreyflow start`;
3. a case's Author gives the dashboard's account Viewer on the case.

Each pull is made as that account, at its clearance, audited and recorded in the export ledger.

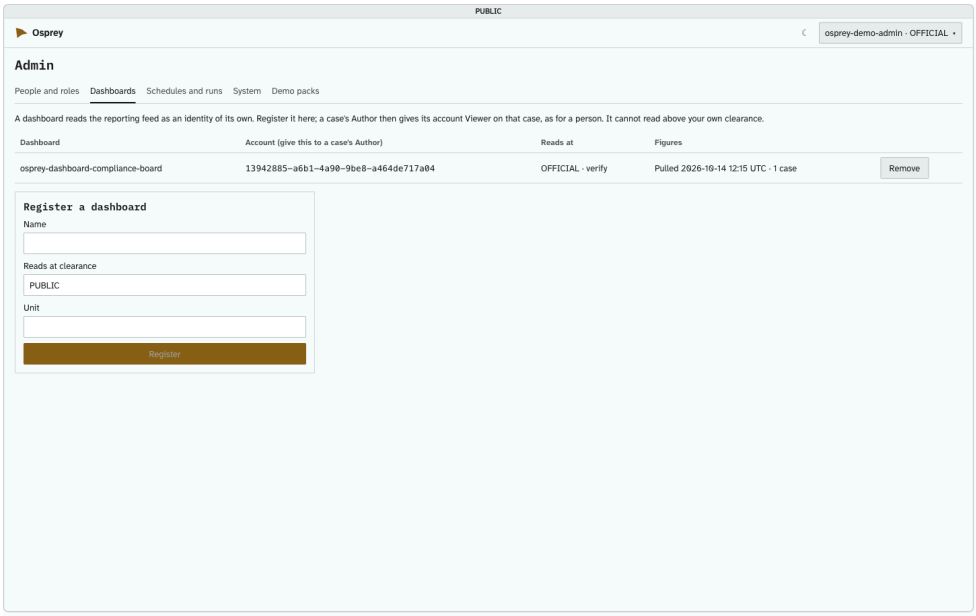



Figure 6. Admin → Dashboards: registering a dashboard's account and seeing when it last pulled

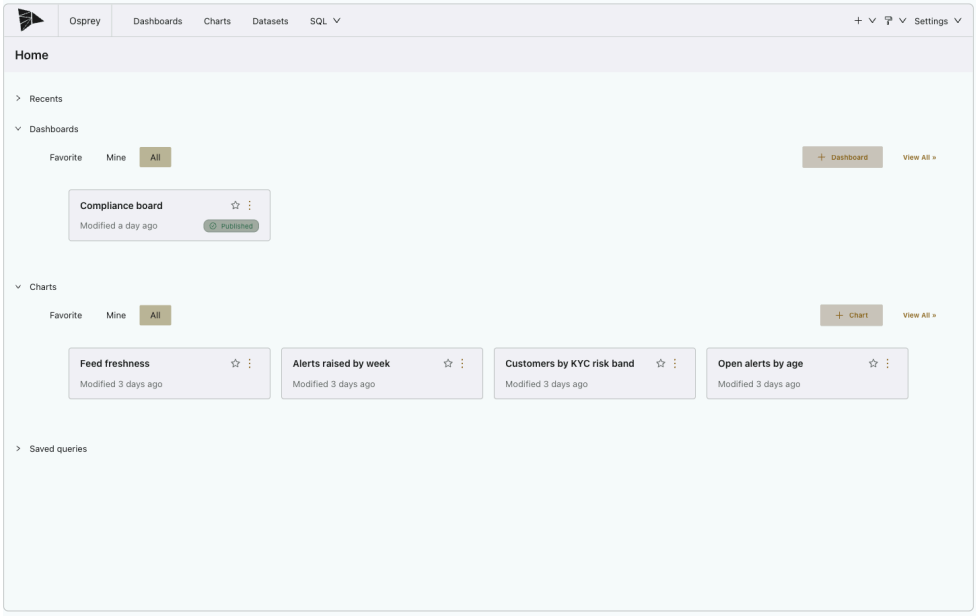



Figure 7. Superset at bi.: the boards and charts built on the reporting figures

### The monitoring board

The feed also carries four monitoring sections, for every kind of alert (typology, hotlist and monitor), each a row of `section`, `label`, `typology`, `week_start` and `value` in the reporting database's `figures` table, beside `raised`, `open_by_age` and `outcome`:

| `section` | `label` | What it counts |
|---|---|---|
| `raised_by_rule` | `typology` (with its `typology`), `hotlists` or `monitors` | alerts raised each week, by rule |
| `closed` | the closing reason as stored: `true_positive` (True match), `false_positive` (False positive), `duplicate`, `no_further_action` or `referred`; or `closed` (taken back, no outcome) | alerts closed each week, by outcome |
| `time_to_close` | `under a day`, `1 to 7 days`, `7 to 30 days`, `over 30 days` | alerts closed in the period, by how long they took |
| `hotlist_matches` | `hotlists` | hotlist matches each week |

A typology rule is named by its typology, never by its own name, which an analyst writes and the feed does not carry. Every figure is counted as the dashboard's account may see it; a hotlist kept "only me" is counted for its owner alone, so never on a dashboard.

**In the Glass**, the rail's **Dashboards** draws an **Alert monitoring** board itself, first among the boards, from the same figures counted as the person reading it: raised each week and by rule, closed by outcome, time to close, hotlist matches and the team view. A Reports Viewer's *Open the dashboard* opens it filtered to an alert's rule and period. It needs no Superset set-up. For a board of your own in Superset, none ships as a file: build it from the `figures` table, filtered on these sections — for example a stacked bar of `raised_by_rule` by `week_start` and `label`, a bar of `closed` by `label`, a table of `time_to_close`, and a line of `hotlist_matches` — with a filter on `case_name`. Report sync fills it on its next pull; nothing else needs to change.

## 13. Backup and restore

**Every install.** `ospreyflow backup` writes a set to `<backups folder>/<deployment>/<time>-<deployment>-<commit>/`. The backups folder is asked for at setup (`folders.backups` in the answers file, the **Backups folder** field on the guided page's Folders screen, or the install's prompt), offering `~/OspreyFlow/backups`, and is written to `osprey.yaml` as `components.storage.backups`. `<deployment>` is the `deployment.name` you gave (`--name`), or the profile (`local-lite`, `small`), so two deployments' sets never mix. The set holds the graph store, every PostgreSQL database (the identity provider's accounts as their own export), the analytics database, the object store (each object with its checksum), the configuration, and a manifest of checksums. Taken while the Conduit runs, the stores may be captured at slightly different instants — it says so; `--require-quiesced` refuses to run unless the Conduit is stopped.

`ospreyflow restore <set>` is a **dry run** first: it checks every checksum and estimates how long it will take. `ospreyflow restore <set> --yes` restores. It refuses a set whose checksums do not match, a deployment that is not empty, and a set from another ontology version. Passwords are not restored: the deployment's own are kept. Once PostgreSQL is restored, the restore starts the identity provider (Keycloak) again and waits until it answers before it brings the accounts back: a Keycloak left running while the database under it was replaced refused the restore, with "could not authenticate to Keycloak: 500" (section 16).

**Small.** The cloud protects the data: the database's own backups and snapshots, and the server's daily backup. `ospreyflow backup` refuses a deployment on a managed database, saying so; restore from the cloud's console.

**Small on your own server.** As every install: written to the backups folder (`folders.backups`, or `server.backups`, its older name, section 5a.3; giving both with different folders is refused), each set readable by its owner only; the certificate's key and `deployment.env` are never in it. Schedule it with a cron line, for example `0 2 * * * cd /opt/ospreyflow && ~/.local/bin/ospreyflow backup`. A person who signs in through the organisation's identity provider is restored still linked to it. OpenSearch is not in the set, as on Lite (below).

**A fresh deployment** has no published recipes and no analytics events yet: its first set records them as **empty** (the manifest's `empty` list, and the backup's last lines say so), and a restore of it restores nothing for them. **Where the stores keep their data** (Lite, and Small on your own server). In Docker named volumes of the deployment's own: `<project>_postgres-data` (every PostgreSQL database — the Conduit's records, the accounts, the audit log), `<project>_arcadedb-databases` and `<project>_arcadedb-config` (the graph and its server's settings), `<project>_valkey-data` (the working sets and job queues), `<project>_opensearch-data`, beside `<project>_osprey-data`, `<project>_osprey-staging` and `<project>_objectstore-data`. `<project>` is `osprey-local-lite`, `osprey-small`, or the `deployment.name` you gave; `docker volume ls` lists them. They outlive a stopped, recreated or removed container, so a restart, `ospreyflow apply`, an update and `uninstall --keep-data` keep them; `ospreyflow uninstall` without `--keep-data` removes them. A deployment installed with v0.4.10 or earlier kept PostgreSQL and ArcadeDB in unnamed volumes, and Valkey and OpenSearch inside their containers; its data is moved into the named volumes once (section 14). A backup reads each store through its own running server, so it is the same wherever the data is kept. **Not in a backup:** Valkey's working sets and queues, and OpenSearch's search index, which is rebuilt from the graph instead: a restore's last step, once the graph and the texts are back, runs `python -m scripts.rebuild_search_index` in the Conduit's container, in a deployment that runs an OpenSearch (`components.search: opensearch`, the default). With `postgres-fulltext` there is no index to rebuild.

**A backup that fails** removes the set it had started, and says so, so no half-written set is left beside the good ones. If it cannot remove all of it, it says what it could not remove, renames the set `<set>.incomplete` with a file `INCOMPLETE` in it, and `ospreyflow restore` refuses it; remove it as root (`sudo rm -rf <set>.incomplete`).

**Where sets are, and cleaning them up.** A backup is never written inside the OspreyFlow folder (the checkout: the folder holding `OspreyFlow_Core`, and everything in it). `--out-root <folder>` writes a set elsewhere, but a folder inside the checkout is refused, and `ospreyflow doctor` fails if the backups folder is inside it. `/var/lib/osprey/backups`, the settings' placeholder, is refused at setup except on Small on your own server. A deployment installed by name cannot be called `local-lite`, `small` or `cluster`, or the checkout's own `deployment.name`, since the checkout's own deployment keeps its backups under that name. Give two checkouts on one machine different backups folders: both deployments are `local-lite`, so they would otherwise share a subfolder. An `osprey.yaml` from v0.4.x or earlier names no backups folder (or the placeholder `/var/lib/osprey/backups`), so its sets go to `~/OspreyFlow/backups/<deployment>/`, and the backup's first line says so. Name a folder as `components.storage.backups` to stop that line.

Sets taken before this release may still be in the checkout's `backups/`, in a named deployment's `~/.ospreyflow/deployments/<name>/backups/`, or directly in a server's backups folder. `ospreyflow doctor` names each such folder, with the sets' total size and the one command that moves them (`mkdir -p <folder>/<deployment> && mv <sets> <folder>/<deployment>/`). It never moves or deletes a set itself. Until they are moved, `ospreyflow restore` with no set lists them beside the deployment's own sets, each with its move command, and `ospreyflow restore <set name>` still restores one, looking in the deployment's folder first. A set the doctor cannot read all of (a server's are the owner's only) is given as "at least" its size, and its move needs `sudo`.

**A synced folder.** A set holds the deployment's data and any real-data exception it was given. `ospreyflow doctor` warns when the backups folder is under a folder a sync client copies: on macOS, `~/Library/CloudStorage` (Google Drive, OneDrive, Dropbox), `~/Library/Mobile Documents` (iCloud Drive), `~/Documents` or `~/Desktop` (which iCloud syncs when "Desktop & Documents" is on); and a `OneDrive` folder on any system (Windows, or a Windows home folder under WSL's `/mnt/c/`). It is a warning, not a refusal, because you may mean it. A folder reached through a link is judged by where the link points. `ospreyflow doctor --config <answers>` checks the answers' folder before the install.

**Cleaning up.** Nothing removes old sets automatically. Each set is a folder named `<UTC time>-<deployment>-<commit>`, the commit in full, for example `20261109T020000Z-local-lite-3e5a1c2…` (40 characters). To remove one, delete its folder: `rm -rf ~/OspreyFlow/backups/local-lite/<set>` (on a server, as the account that runs the backup). Keep at least the newest set that `ospreyflow restore` accepts.

**Once the object store holds files** (a demo pack or an upload has put some there), it is copied as the account that runs `ospreyflow backup`, so that account can remove its working copy. With v0.4.8 and earlier on Linux such a backup failed with "Permission denied" (section 16).

**Enterprise.** The cloud protects its managed services as for Small. **The graph store and the analytics database run in the cluster, and nothing backs them up yet**: `ospreyflow backup` drives a Compose deployment and does not reach a cluster. Until it does, take snapshots of their volumes with the cloud's own tools.

**Audit.** The audit log is in the same PostgreSQL as everything else, so it is in the same backup and shares its retention.

## 14. Updates

Releases are tagged `vMAJOR.MINOR.PATCH`, with signed images and a signed list of every image by digest. Each release's notes are its section of `CHANGELOG.md`.

**Which installs `update` moves, and how the others are updated:**

| Your install | How it is updated |
|---|---|
| Lite, installed from a release tag | `ospreyflow update` (below) |
| Lite, built from the checkout (`--build`, or a checkout on no release tag) | `git pull`, then `ospreyflow start --build`. `update` refuses this install, saying so |
| Small | **Not yet by `update`**: its first step, the backup, refuses a deployment on a managed database (section 13). The cloud's own backups protect the data |
| Small on your own server, installed from a release tag | `ospreyflow update`, as Lite: its backup is written to `<server.backups>/<deployment>/` first |
| Enterprise | Move the checkout to the release's tag and run the install again: the chart is upgraded in place, every password and account kept |

**Checking for a newer release.** The deployment never calls out to look. Run `ospreyflow update --check` on the computer that holds the checkout: it asks the repository's releases and leaves the answer where Admin → System shows it, with when it asked: "*vX.Y.Z* is available", "Up to date", or "The last update check could not answer" and why; before the first check it says "Not checked for updates yet", and an install built from its checkout is told it moves with `git pull` and `ospreyflow start --build`. It checks only when you run it — to be told each week, add it to that computer's own scheduler, for example a cron line `0 8 * * 1 ospreyflow update --check`. If the repository is private, set `GITHUB_TOKEN` to a token that can read it first; without one the check cannot answer, and says so.

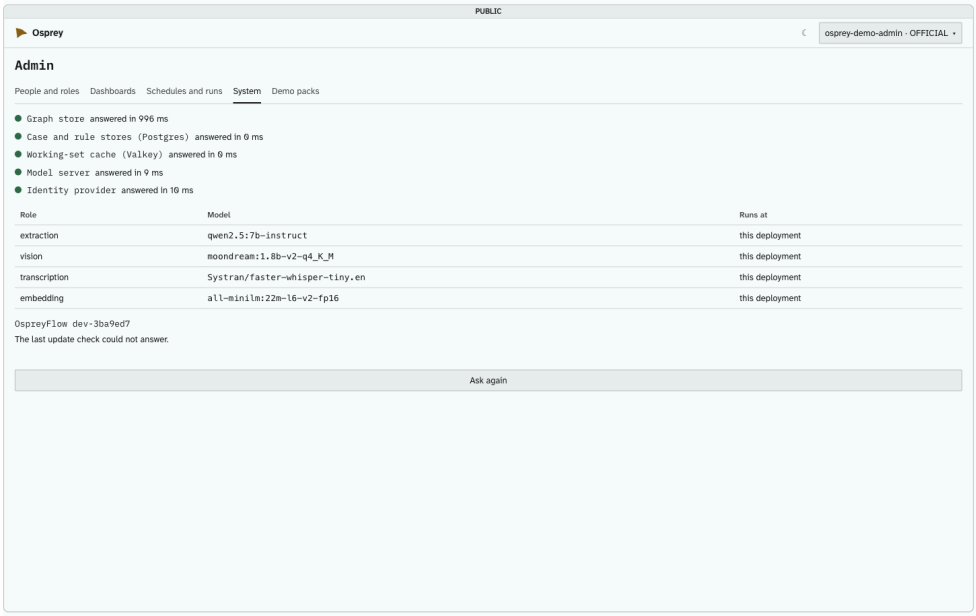



Figure 8. Admin → System: each component's health, the models in use, the version, and the last update check

**Moving to a release.**

- `ospreyflow update` moves to the newest release (`--to vX.Y.Z` for another; `--yes` asks nothing). It checks every image's signature first and changes nothing if one fails; refuses if a local change to a file would be overwritten ("commit or undo them first"); **backs everything up**; moves the checkout to the tag; starts the release's images and checks each service runs them. If anything fails after the backup it **rolls back** — the previous release and its data restored from the backup just taken — and says so.
- **Without internet**: on a machine with it, `ospreyflow update --make-bundle <file> --to vX.Y.Z` writes the release, verified, to one file; carry it over and run `ospreyflow update --from <file>`, which checks it again with no network. - **A bundle carries one platform's images**: `linux/amd64` unless `--platform` names another, whatever the machine making it runs on, so a bundle made on an Apple-silicon Mac is for an amd64 server as it stands. A release is built for `linux/amd64` and `linux/arm64`; for an arm64 server, add `--platform linux/arm64`. Any other platform is refused before anything is fetched, and says which platforms a release has. - `--from` refuses a bundle for another platform than its machine's before it checks or loads anything, and says what to run instead, for example: "this bundle carries the images for linux/arm64, and this machine is linux/amd64; nothing was verified or loaded. Make one for it on any machine that reaches the release: ospreyflow update --make-bundle FILE --platform linux/amd64". A bundle made before this version names no platform: it carries the platform of the machine that made it, and on another it is refused when its cosign image is checked.

An update moves forward only.

**The stores' one-time move to named volumes.** A deployment installed with v0.4.10 or earlier keeps its PostgreSQL and ArcadeDB data in unnamed volumes, and Valkey's and OpenSearch's inside their containers (section 13). The first `ospreyflow update` after that — after its backup and before anything starts — moves the data into the stores' named volumes, once; so does the first `ospreyflow start`, `start --build`, `apply` or `install` that brings such a deployment up from a newer checkout. The deployment is stopped while it moves: each store is started alone on its old data and asked what it holds, its data is copied with its own image keeping every owner and permission (Valkey's from its container, through a temporary image of it that is removed afterwards), the copy is checked file by file against the original, and the store is started on its named volume in a container of its own, apart from the deployment's, and must hold the same as before. Only then does the command start the deployment on the named volumes. It says, for example:

```
The stores' data moves to named volumes, once: postgres, arcadedb, valkey, opensearch. The deployment is stopped while it moves;
the old volumes are kept.
  postgres: the databases keycloak, osprey, postgres, superset.
  postgres: copying /var/lib/postgresql/data from 3f9c…e1 to osprey-small_postgres-data…
  postgres: /var/lib/postgresql/data copied and checked (2114 entries, the same owners, modes and contents).
  …
  valkey: keys that do not expire db0: 1.
  valkey: copying /data from valkey's container to osprey-small_valkey-data…
  …
  opensearch: holds no index of its own, so nothing is copied; it starts on its named volume empty.
  postgres: on its named volume it holds the databases keycloak, osprey, postgres, superset, as before.
  …
The stores' data is in their named volumes, checked; they start on them next.
The old volumes are left in place: 3f9c…e1, 7a20…4b, c51d…90, 0be8…7f. Once the deployment works as before, remove them with:
  docker volume rm 3f9c…e1 7a20…4b c51d…90 0be8…7f
```

Run again, it does nothing. It needs room for a second copy of the stores' data on the disk where Docker keeps its volumes (`ospreyflow doctor` shows that disk). **If the move fails**, it says why and removes nothing: the named volumes it filled are removed, each store's data is where it was, no container of the deployment's has been replaced, and every file the command wrote is put back as it was, so the deployment still runs from the files that name its old data. An update then rolls back to the previous release on that data, with nothing restored ("rolled back to … on its own data, which was never moved"). `apply`, `install` and `start --build` stop, saying "…, and the deployment's files are as they were. The deployment is stopped; ospreyflow start starts it on that data." — or "Nothing was stopped." when the move refused before it stopped anything — and `ospreyflow start` then brings the deployment up on its old data. If an update fails after a move that succeeded, it rolls back as for any other failure (the backup restored) and removes the named volumes the move filled; the old volumes are kept either way.

### 14.1 Removing the old store volumes

After the move, each store's old volume is left as it was — a long hexadecimal name — and nothing uses it. Check the deployment first: sign in, open a case, and take a backup (`ospreyflow backup`, section 13). Then remove the volumes the move named, with the command it printed:

```
docker volume rm <name> <name> …
```

Docker refuses to remove a volume a container still uses, so nothing in use can be removed this way. If the move's words are lost, `docker volume ls --filter dangling=true` lists the volumes no container uses; this deployment's are among them, but so may be other programs', so do not remove them all (`docker volume prune` would). Until they are removed they cost only disk.

## 15. Scheduled and watched pipelines

A published pipeline can run on a **schedule** (hourly, daily, on weekdays or weekly at a time, in a named time zone, or a cron expression; never more often than every 15 minutes) and when a **file arrives** in its dataset's folder (a filename pattern such as `*.csv`; each new file runs once, a minute after it stops changing). Both are set on the Ingest Studio's Publish screen by someone holding `schedule_pipelines`, and run **as that person**, with every check their own run would get. A run that is refused or fails tells its owner in their alerts; three refusals in a row pause it. Admin → Schedules and runs lists every one.

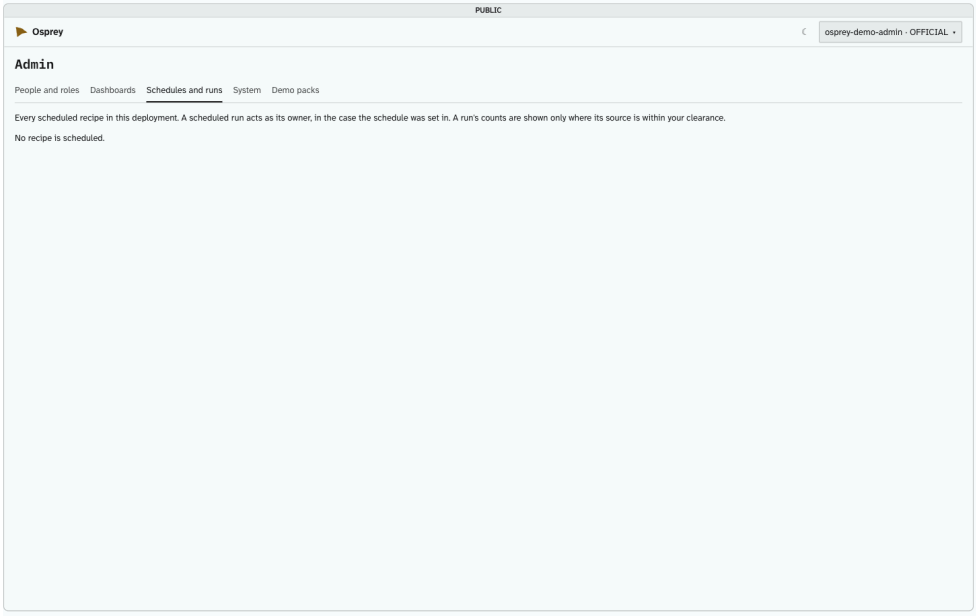



Figure 9. Admin → Schedules and runs

## 16. When something is wrong

| Symptom | Look at |
|---|---|
| `install` stops at the checks | The crossed line says what to fix; nothing was changed |
| A service is not healthy | `ospreyflow status`, then `ospreyflow logs <service>` |
| The page does not open | `ospreyflow status`; that port 80 (Lite) or the DNS records (Small) are right |
| Nobody can sign in | `ospreyflow logs keycloak`; that the address in `osprey.yaml` is the one in the browser; then `ospreyflow repair-sign-in` |
| Rules say "the rule's deployer could not be resolved", a hotlist reads **Stopped**, or a list refresh re-screens 0 customers — typically after the stores were wiped; Admin → System's **Acting for people** says "The Conduit cannot act for people" | The Conduit cannot act for people: the identity provider no longer holds its client secret. Run `ospreyflow repair-sign-in`, then run the rule again. The System line turns green within half a minute |
| Someone signing in through the organisation is told "This email address already belongs to an OspreyFlow account" | An account you made holds their email, and OspreyFlow does not join the two by itself (section 5a.1). Join them in Admin → People and roles' *Refused organisation sign-ins*, or remove that account and they arrive again, or they sign in with that account (section 9.7) |
| *Refused organisation sign-ins* does not list someone who was refused | It lists the last seven days, from a deployment updated to the release after v0.4.10 and repaired since (`ospreyflow repair-sign-in`, which also makes the identity provider record the refusals). Someone refused before that, or more than seven days ago, is not listed: ask them to sign in through the organisation once more, then look again. Someone already joined to an account is not listed either |
| Admin → People and roles says "the identity provider refused the Conduit — its account needs manage-users, manage-clients and view-events" | Run `ospreyflow repair-sign-in`, which grants the Conduit's account what it needs |
| Removing someone is refused: "the only enabled person who can manage people" | Give someone else the Admin role (or the `manage_people` right) first, so the deployment is never left with no administrator. Your own account cannot be removed either: another administrator removes it |
| `doctor`, the install or `repair-sign-in` warns "Sign-in through the organisation joins by email" | `sign_in.organisation.trust_email` is on (section 5a.1). Keep it only with the security officer's written sign-off; otherwise set `trust_email: false` in `osprey.yaml` and run `ospreyflow apply` |
| Windows ask people to sign in again after about half an hour away | As intended: a window renews its sign-in only after the person has done something, so one left alone ends at the identity provider's idle limit (Keycloak's default, 30 minutes). The page is kept; they sign in again in a small window |
| `doctor`, `install` or `apply` says "the certificate is refused" | Each reason is named, and nothing was changed. "does not match": the key is another certificate's. "encrypted with a passphrase": write the key unencrypted (`openssl pkey -in <encrypted> -out <key>`), mode 600. "does not cover id....": a wildcard for the parent domain covers one label only; ask for `id.<host>` and `bi.<host>`, or `*.<host>` (section 5a). "expired" or "not valid until": a new certificate, or the server's clock. "does not reach the organisation's root": put the intermediates after the server certificate. "the identity provider ... cannot" read the root: `chmod 644` the `ca` file. Then run the command again |
| Nobody can sign in through the organisation (Small on your own server) | The organisation's page says the redirect URI is not registered: register exactly the address `ospreyflow doctor --mode small --config install.yaml` prints (section 5a.1). The sign-in comes back with "Unexpected error when authenticating with identity provider": the client secret is wrong (put the right one in `deployment.env`, then `ospreyflow repair-sign-in`) or the server cannot reach the provider (`login.microsoftonline.com` for Entra ID). `repair-sign-in` says "could not read the organisation's sign-in settings": the issuer is wrong, the provider cannot be reached, or — for a provider on the organisation's own certificates — `server.ca` is missing |
| Someone signed in through the organisation and sees nothing | As intended until an administrator grants them roles and access in Admin → People and roles (section 5a.1) |
| `doctor` says too little disk where backups are written | Give `server.backups` more room, or name another folder; remove old sets |
| People on the network cannot connect to Small on your own server | Port 443 is open in front of the server — its firewall or security group, or the `DOCKER-USER` chain; `ufw` does not filter a port Docker publishes — and the three names resolve to the server in the organisation's DNS |
| `doctor`, `install` or `apply` refuses the GPU | Each reason is named, and nothing was changed: install the NVIDIA driver and restart until `nvidia-smi` lists the GPU; install the NVIDIA Container Toolkit and run `sudo nvidia-ctk runtime configure --runtime=docker` and `sudo systemctl restart docker`; on macOS or Windows, set the GPU to `none` (section 5a.4) |
| `ospreyflow update --from` says "this bundle carries the images for linux/arm64, and this machine is linux/amd64", or "the bundle's cosign image is not the one pinned for linux/amd64" | The bundle was made for another platform: the second words are a bundle made with v0.4.10 or earlier, before `--platform`, which carried the platform of the machine that made it (an Apple-silicon Mac's is arm64). Nothing was verified or loaded. Make it again with `ospreyflow update --make-bundle <file> --platform linux/amd64` (the default) on any machine that reaches the release (section 14) |
| `ospreyflow demo add` or an upload fails with "Permission denied: '/var/lib/osprey/ingest/uploaded/...'", or `install`, `apply`, `start` or `update` says "the Conduit (uid 10001) cannot write .../uploaded" | Linux only: the Conduit's upload folder in `server.ingest` (Lite: `components.storage.ingest`) is not its own. A deployment installed or updated with v0.4.8 or earlier has it so: run `ospreyflow apply` or `ospreyflow start` once with a later version, which gives the folder over (section 5a). When giving it over fails, the command names Docker's reason; or give it over yourself, `sudo chown 10001:10001 <server.ingest>/uploaded`, and run the command again |
| `ospreyflow backup` fails with "Permission denied" on a file under `.objects-staging`, or a folder named `….incomplete` is left where backups are written | Linux, v0.4.8 or earlier, once the object store holds files: the object store's copy belonged to the Conduit's user. Update, then back up again. Remove what was left as root (`sudo rm -rf <folder>`); a folder with an `INCOMPLETE` file in it is not a backup, and `restore` refuses it (section 13) |
| Ask on the local engine fails after the extraction model was changed (the GPU switched on, or `models.extraction`) | `ospreyflow apply` fetches the newly chosen model, and waits for it, before anything that uses it starts again; if the download fails it stops with nothing changed, saying "the model download (ollama-models) did not finish": `ospreyflow logs ollama-models` says why, then run `ospreyflow apply` again. With v0.4.8 or earlier, `apply` never fetched it: `docker compose --env-file <deployment>/deployment.env -f <deployment>/compose.yaml up -d --force-recreate --no-deps ollama-models` fetches it (the 14b is about 9 GB) |
| A Small server never answered | Its log, `/var/log/ospreyflow-first-boot.log` (Session Manager on AWS) |
| An update rolled back | Its own words say why, and where its backup is |

| Symptom | Look at |
|---|---|
| `start`, `apply`, `install` or `update` says "the stores' data could not be moved to named volumes" | Nothing was removed, and the deployment's files are as they were: `ospreyflow start` runs it on its old data (section 14). "both its current volume … and the named volume … hold data": the named volume is left from an earlier attempt — look at it, and remove it (`docker volume rm <name>`) only if it holds nothing you need; then run the command again. "holds the indexes …": OpenSearch holds an index OspreyFlow did not write, which would not survive the move; snapshot or remove it first. "No space left on device": free room for a second copy of the stores' data where Docker keeps its volumes. "is not the same as the original": the copy did not keep an owner or a permission; say so, with the line it names |
| Old unnamed volumes after the move | Expected: section 14.1 says how to remove them once the deployment works as before |
| `restore` fails on 'identity' with "could not authenticate to Keycloak: 500" | The identity provider was running on a database replaced under it, and builds its tables only when it starts. From the release after v0.4.10 the restore starts it again itself before that step. With v0.4.10 or earlier, everything before the accounts is restored: run `ospreyflow stop` then `ospreyflow start`, and ask for the accounts to be brought back from the same set (the restore's identity step on its own); do not run the whole restore again, which refuses a deployment that is no longer empty |
| The model download stopped with `rename …-partial …: no such file or directory` | A model server restarted mid-download and removed the half-fetched file (fixed from the release after 15 October 2026). Run `ospreyflow start` while the deployment is up: it starts the download again and the server keeps running, so it completes |

## Appendix A — every `osprey.yaml` setting

Made from the deployment's own schema. Settings marked *section* hold the settings below them.

| Option | Value | Default | What it does |
|---|---|---|---|
| `profile` | `local-lite` \| `small` \| `cluster` \| `cloud-platform` | `local-lite` | Which kind of deployment: one machine (local-lite), a cloud server on managed services or a server of your own with every store in a container (small), or a cluster. |
| `components` | section | — | Which stores the deployment runs, and where their data lives. |
| `components.graph_store` | `arcadedb` \| `janusgraph` | `arcadedb` | The graph store. |
| `components.analytics_engine` | `duckdb` \| `clickhouse` | `duckdb` | Where events are counted: DuckDB inside the Conduit, or ClickHouse shared by several. |
| `components.post_ingest_resolution` | bool | true | Whether a load queues entity resolution afterwards (`OSPREY_POST_INGEST_RESOLUTION`). False for a demonstration whose people must not gain automatic `SAME_AS` links; an analyst's own Resolve now still works. |
| `components.search` | `opensearch` \| `postgres-fulltext` | `opensearch` | Search; postgres-fulltext is the lighter variant. |
| `components.storage` | section | — | Folders: inside the containers, and on the host for ingest and tiles. |
| `components.storage.data` | str | `/var/lib/osprey/data` | Where the deployment keeps its data inside the containers. |
| `components.storage.staging` | str | `/var/lib/osprey/staging` | Where loads stage their rows before they reach the graph. |
| `components.storage.backups` | str | `/var/lib/osprey/backups` | Where backups are written. |
| `components.storage.ingest` | str | `/var/lib/osprey/ingest` | The host folder of source files the Ingest Studio lists (read-only to it; uploads go to its uploaded/ folder). A relative path is read from the folder osprey.yaml is in. |
| `components.storage.tiles` | str | `/var/lib/osprey/tiles` | The host folder a built basemap lives in. A relative path is read from the folder osprey.yaml is in. |
| `components.source_path` | str or none | none | The owned services (workspace, api, ingest) are PULLED, by the digest recorded in versions.lock, from the registry reference harness/render.py's own service_images names. This is the operator path: the harness image itself carries no services/ or apps/workspace source, and a review found that the documented one-command bootstrap could not Launch without it — a clean laptop has no checkout. Set to a checkout root containing services/api/Dockerfile, services/ingest/Dockerfile and apps/workspace/Dockerfile (this repository's own root, for a developer/CI run) to BUILD owned images from source instead. Declared and the Dockerfiles absent is refused by name (harness.render.MissingDockerfileError) — never silently treated as the pull path. |

| Option | Value | Default | What it does |
|---|---|---|---|
| `models` | section | — | The local models, and the client's own model providers (engines) if any are enabled. |
| `models.local_only` | bool | true | No hosted fallback |
| `models.hosted_fallback` | str or none | none | A provider name, never a credential. |
| `models.sendable_handling_codes` | list of str | — | Which handling codes may leave for a hosted model. |
| `models.provider` | section or none | none | The older one-provider form, read as a one-entry providers list; not with providers. |
| `models.provider.name` | str | required | LiteLLM's name for the provider: openai, anthropic, gemini, azure, bedrock... |
| `models.provider.label` | str or none | none | The name analysts see for this engine. Default: OpenAI, Anthropic or Gemini for those three, else the provider's name capitalised. |
| `models.provider.roles` | mapping | required | The roles it takes, each with the provider's model for it |
| `models.provider.api_base` | str or none | none | The provider's address, where it is not LiteLLM's default (an Azure deployment, a proxy) |
| `models.provider.privacy_contract` | bool | false | True when the deployment's organisation holds a data-processing agreement with the provider covering this key. A dataset whose egress is `contracted` is sent only to a provider marked so. Default: false. |
| `models.provider.contract_reference` | str or none | none | The agreement's reference, in words (for example DPA 2026/07); never a secret. Shown beside the mark. |
| `models.provider.kind` | `provider` \| `gateway` \| `bedrock` | `provider` | ADR-135 Amendments 4 and 7: provider (a hosted provider LiteLLM knows by name), or at profile: cloud-platform only, gateway (the client's own OpenAI-compatible AI gateway, at api_base) or bedrock (Amazon Bedrock in London). Default: provider. |
| `models.provider.auth` | `key` \| `iam_role` or none | none | ADR-135 Amendments 4 and 7: key (entered in Admin › Models, kept by the model gateway alone), or at profile: cloud-platform only, iam_role (the gateway's own IAM role: no key is stored). Default: iam_role for bedrock, else key. |
| `models.provider.region` | str or none | none | Bedrock's region (profile: cloud-platform): eu-west-2 (London) only, and the default for bedrock. |
| `models.providers` | list of section | — | The providers (engines) an administrator enables, each reached through the deployment's gateway; each key is OSPREY_MODEL_KEY_<NAME>. |
| `models.providers.name` | str | required | LiteLLM's name for the provider: openai, anthropic, gemini, azure, bedrock... |
| `models.providers.label` | str or none | none | The name analysts see for this engine. Default: OpenAI, Anthropic or Gemini for those three, else the provider's name capitalised. |
| `models.providers.roles` | mapping | required | The roles it takes, each with the provider's model for it |
| `models.providers.api_base` | str or none | none | The provider's address, where it is not LiteLLM's default (an Azure deployment, a proxy) |
| `models.providers.privacy_contract` | bool | false | True when the deployment's organisation holds a data-processing agreement with the provider covering this key. A dataset whose egress is `contracted` is sent only to a provider marked so. Default: false. |
| `models.providers.contract_reference` | str or none | none | The agreement's reference, in words (for example DPA 2026/07); never a secret. Shown beside the mark. |
| `models.providers.kind` | `provider` \| `gateway` \| `bedrock` | `provider` | ADR-135 Amendments 4 and 7: provider (a hosted provider LiteLLM knows by name), or at profile: cloud-platform only, gateway (the client's own OpenAI-compatible AI gateway, at api_base) or bedrock (Amazon Bedrock in London). Default: provider. |
| `models.providers.auth` | `key` \| `iam_role` or none | none | ADR-135 Amendments 4 and 7: key (entered in Admin › Models, kept by the model gateway alone), or at profile: cloud-platform only, iam_role (the gateway's own IAM role: no key is stored). Default: iam_role for bedrock, else key. |

| Option | Value | Default | What it does |
|---|---|---|---|
| `models.providers.region` | str or none | none | Bedrock's region (profile: cloud-platform): eu-west-2 (London) only, and the default for bedrock. |
| `models.defaults` | mapping | — | Each role's default engine, `local` or an enabled provider's name. A role not named runs on `local` (for the single `provider`, on it). |
| `models.extraction` | `qwen2.5:7b-instruct` \| `qwen2.5:14b-instruct` | `qwen2.5:7b-instruct` | The local model that extracts entities from text. Default: qwen2.5:7b-instruct, the model the product ships with; with resources.gpu: nvidia and this not named, qwen2.5:14b-instruct. |
| `models.vision` | `moondream:1.8b-v2-q4_K_M` | `moondream:1.8b-v2-q4_K_M` | The local model that describes an image and reads its text. |
| `models.transcription` | `Systran/faster-whisper-tiny.en` | `Systran/faster-whisper-tiny.en` | The local model that transcribes a video's speech. |
| `models.embedding` | `all-minilm:22m-l6-v2-fp16` | `all-minilm:22m-l6-v2-fp16` | The local model that turns text into vectors. |
| `models.extraction_engine` | `deep_read` \| `laurium` or none | none | ADR-135 Amendments 5 and 6: deep_read or, at profile: cloud-platform only, laurium (its own service, every call through the gateway). Left unset: laurium on cloud-platform (its preset), deep_read on every other profile. |
| `governance` | section | — | Identity, handling, ontology and the marking shown on screen. |
| `governance.identity_provider` | str | `keycloak` | The identity provider people sign in through. |
| `governance.handling_scheme` | str | `uk-law-enforcement` | The handling scheme every item is marked under. |
| `governance.ontology` | str | `default` | The ontology the deployment starts from. |
| `governance.organisation_sign_in` | str or none | none | The alias of an organisation's own identity provider brokered by Keycloak. When set, the welcome page offers *Continue with organisation sign-in* (*Continue with <label>* when `organisation_provider` names one), which goes straight to it. Default: none — one *Sign in* to the OspreyFlow form. |
| `governance.organisation_provider` | section or none | none | Small on a server of your own: the organisation's identity provider, brokered by Keycloak; its client secret is never here (section 5a.1). |
| `governance.organisation_provider.label` | str | required | The provider's name as people know it, shown on the welcome page's button (Continue with <label>) and on the identity provider's own sign-in pages (for example 'Example Department account'). |
| `governance.organisation_provider.issuer` | str | required | The provider's issuer, an https:// address; its discovery document is read from <issuer>/.well-known/openid-configuration (for Entra ID, https://login.microsoftonline.com/<tenant>/v2.0). |
| `governance.organisation_provider.client_id` | str | required | The application (client) id the organisation registered for OspreyFlow. |
| `governance.organisation_provider.trust_email` | bool | false | ADR-114 Amendment 33, 'Step 33': true joins a person arriving through the organisation to the OspreyFlow account holding the same email address, automatically, with its roles and clearance. Off by default: a person whose email an account holds is refused in words, and an administrator joins them in Admin, People and roles. Turn it on only with the organisation's security officer's written sign-off that every address its provider gives is verified and cannot be set by the person who holds it: anyone who can make the provider give an address takes over the account that holds it (the 2023 'nOAuth' account takeovers). |
| `governance.marking` | str or none | none | The protective marking shown where no case data is on screen: the welcome page, Home, the Ingest Studio and the Admin area; inside a case, the strip shows this or the highest marking on screen, whichever is higher. One of the handling scheme's classifications. Default: the scheme's lowest. |
| `governance.real_data_exceptions` | str | `config/real_data_exceptions.yaml` | A path to the gitignored list, never its contents. |
| `cluster` | section | — | A Kubernetes deployment: its namespace, storage classes and machines. |
| `cluster.hosts` | list of section | — | One machine. |
| `cluster.hosts.name` | str | required | The machine's name |

| Option | Value | Default | What it does |
|---|---|---|---|
| `cluster.hosts.address` | str | required | Where the machine is reached |
| `cluster.hosts.roles` | list of str | — | What runs on it |
| `cluster.namespace` | str | `ospreyflow` | The Kubernetes namespace the deployment is installed in |
| `cluster.storage_class` | str or none | none | The storage class each store's own volumes use; the cluster's default when unset |
| `cluster.shared_storage_class` | str or none | none | Required for a cluster: the storage class of the one volume every Conduit shares (ReadWriteMany) — EFS on AWS, Azure Files on Azure |
| `cloud_platform` | section or none | none | A namespace on a shared Kubernetes platform (profile cloud-platform only): the platform's settings file, the namespace, its registry, and what its egress may reach. |
| `cloud_platform.platform` | str | `client` | The platform's settings file, by name |
| `cloud_platform.namespace` | str or none | none | The namespace the platform's team created for the deployment (required) |
| `cloud_platform.environment` | `development` \| `production` | `development` | One copy of each store; production runs the cluster's copies (ArcadeDB 3, ClickHouse 2, Keeper 3) |
| `cloud_platform.shape` | `standard` \| `poc` | `standard` | The stores as the environment sets them. poc: the proof-of-concept shape, a development namespace's only: one ArcadeDB and one ClickHouse running its own Keeper, no disruption budgets, and the Ingest root on a claim of its own |
| `cloud_platform.registry` | str or none | none | Where every image is pulled from (required): the namespace's ECR, as `ospreyflow images push --registry` copied them there |
| `cloud_platform.allow_from` | list of str | — | The networks (CIDR) the platform's ingress admits; empty: every address |
| `cloud_platform.egress_nets` | mapping | — | For each host the namespace reaches (a model provider, a proxied map provider, the mail server, a connector host, S3 and STS unless the platform's settings name theirs), the networks (CIDR) its traffic is allowed to; a host with none is refused at render. No network wider than /16 (IPv4) or /48 (IPv6), and never a default route |
| `cloud_platform.tls_secret` | str or none | none | The platform's own certificate. The Kubernetes Secret holding the certificate for the deployment's name (the Glass's: the profile renders no sign-in or reporting name), where the platform's wildcard does not cover it |
| `cloud_platform.claims` | section or none | none | How people sign in with Entra ID (ADR-148 Amendment 8): the tenant, the Glass's and the API's app registrations, where each claim comes from and the first administrators. |
| `cloud_platform.claims.tenant_id` | str | required | The client's Entra tenant id |
| `cloud_platform.claims.client_id` | str | required | The Glass's own app registration (application id) |
| `cloud_platform.claims.api_client_id` | str | required | This API's app registration (application id): the token's audience |
| `cloud_platform.claims.superset_client_id` | str or none | none | Superset's own app registration (application id), when reporting.superset is on: people sign in to Superset with it, and its delegated token reads the Conduit's GET /v1/me and /v1/me/rights alone |
| `cloud_platform.claims.api_id_uri` | str or none | none | The API's application id URI, which the Glass's scope names |
| `cloud_platform.claims.token_version` | `2.0` \| `1.0` | `2.0` | The access token version the API's registration is issued (accessTokenAcceptedVersion): the issuer and audience the Conduit checks follow it |
| `cloud_platform.claims.scope` | str | `access_as_user` | The delegated scope the Glass asks the API for |
| `cloud_platform.claims.clearance` | mapping | required | Where clearance comes from: {claim: <name>} or {groups: {<group id>: <value>}} |
| `cloud_platform.claims.org_unit` | mapping | required | Where the organisational unit comes from: {claim: ...} or {groups: {...}} |
| `cloud_platform.claims.handling_codes` | mapping | required | Where the handling codes come from: {claim: ...} or {groups: {<id>: [codes]}} |
| `cloud_platform.claims.groups_claim` | str | `groups` | The token claim listing the person's Entra group ids, which a {groups: ...} table above is read from |

| Option | Value | Default | What it does |
|---|---|---|---|
| `cloud_platform.claims.first_administrators` | list of str | required | The people given the Admin role at install, by Entra object id (at least one) |
| `cloud_platform.claims.claims_mapping_policy` | bool | false | Whether a claims-mapping policy signs the API's tokens with its own key (the keys are then read with ?appid=<api_client_id>) |
| `cloud_platform.connector_hosts` | list of str | — | The hosts a SQL or API connection may reach, each as host or host:port (a name, not an IPv6 literal), with its networks in egress_nets under the host alone. The namespace's egress allows each host on its ports; the Conduit's own allow-list (OSPREY_CONNECTOR_EGRESS) holds the hosts alone, so a connection to a listed host on a port not listed here passes the Conduit and times out at the egress. A bare host is reached on 443 (an API connection over HTTPS); a SQL connection needs its database's port here (db.example.org:5432). A host given twice with two ports is reached on both |
| `cloud_platform.connector_sources` | section | — | The S3 buckets and Athena workgroups an S3 or Athena connection may read: each the Conduit's own egress row and the namespace role's read (ADR-140 Amendment 21). |
| `cloud_platform.connector_sources.s3` | list of section | — | One bucket, its region, and the folder a connection may read at or under. |
| `cloud_platform.connector_sources.s3.bucket` | str | required | The bucket's own name (no dot) |
| `cloud_platform.connector_sources.s3.region` | str | required | The bucket's region (eu-west-2) |
| `cloud_platform.connector_sources.s3.prefix` | str | "" | The folder a connection may read at or under, each name ending in / (exports/client-a/) |
| `cloud_platform.connector_sources.athena` | list of section | — | One workgroup, its region, its databases, its results location (the only place a declared source gives the role a write) and its tables' locations. |
| `cloud_platform.connector_sources.athena.workgroup` | str | required | The workgroup's name |
| `cloud_platform.connector_sources.athena.region` | str | required | The workgroup's region (eu-west-2) |
| `cloud_platform.connector_sources.athena.databases` | list of str | required | The Glue databases a connection may read |
| `cloud_platform.connector_sources.athena.results_location` | str | required | Where Athena writes each query's results (s3://bucket/folder/): the only place a declared source gives the role a write. A folder, never a bucket's top |
| `cloud_platform.connector_sources.athena.table_locations` | list of str | required | Where the databases' tables keep their objects (s3://bucket/folder/), at least one, read by Athena as the namespace's role: read-only, and never reached by the Conduit |
| `network` | section | — | The address the deployment answers at, and what it publishes. |
| `network.expose_conduit` | bool | false | Publish the Conduit's own port on the host in addition to the workspace's. Not needed to use the deployment — the workspace proxies /v1 — and turning it on widens the exposed surface by a whole tier. For an operator debugging the Conduit directly, or a second client that is not the Glass. |
| `network.public_origin` | str | `http://ospreyflow.localhost` | The origin a browser uses to reach the Glass; the identity provider is `id.` and the dashboards `bi.` in front of the same host, with the same scheme and port, and the front proxy publishes that port. `06_DECISIONS.md` ADR-050 objection 2's resolution: the identity-provider realm is rendered from this value at apply time and the Glass's public client is registered with an exact redirect URI and post-logout URI derived from it — no wildcards. Change this to move the deployment to another name or port; nothing else needs to agree with it. |
| `network.tls` | section or none | none | Small on a server of your own: the organisation's certificate (ADR-114 Amendment 33). |
| `network.tls.certificate` | str | required | The server certificate, then its intermediates, in PEM: an absolute path. |
| `network.tls.key` | str | required | The certificate's private key in PEM, unencrypted: an absolute path. Owned by the installing account, mode 600; the front proxy runs as that account to read it. |

| Option | Value | Default | What it does |
|---|---|---|---|
| `network.tls.ca` | str or none | none | Optional: the organisation's root certificate (PEM), an absolute path. With it, the certificate's chain is checked to reach it, and the host's own tools trust it. |
| `network.redirect_http` | bool | false | Small on a server of your own, with network.tls only: also publish port 80, and only to send people to the https:// address. Default: false — port 443 alone. |
| `network.listen_address` | str or none | none | Small on a server of your own, with network.tls only: the one address of the server the front proxy publishes on. Default: none — every interface. |
| `network.access_key` | bool | false | Small over https:// only: the front proxy asks every browser for a shared key (the browser's own user name and key box) on all three names before anything loads, and every answer says noindex. The key's bcrypt hash is set on the server by `python -m harness.access_key set <the deployment's folder>`, never here. Default: false. |
| `map` | section or none | none | The basemaps the map offers. |
| `map.default` | str | required | The provider the map opens on, by its id |
| `map.providers` | list of section | required | One basemap. |
| `map.providers.id` | str | required | The provider's own name, as map.default names it |
| `map.providers.label` | str | required | What the Glass's map menu calls it |
| `map.providers.kind` | `vector` \| `raster` \| `image` \| `dem` | required | |
| `map.providers.licence` | section | required | The basemap's licence. |
| `map.providers.licence.id` | str | required | The licence's identifier, e.g. ODbL-1.0 or OGL-UK-3.0 |
| `map.providers.licence.redistributable` | bool | required | Whether the tiles may be passed on to others |
| `map.providers.licence.client_scope` | `open` \| `per-deployment` \| `per-seat` | required | Who the licence covers: anyone, this deployment, or each seat |
| `map.providers.licence.note` | str or none | none | Anything the licence asks to be said |
| `map.providers.source` | str or none | none | Where the tiles are: a file (file://...pmtiles) or a provider's address; one of source, service and endpoint, or profile |
| `map.providers.service` | `wmts` \| `wms` \| `wfs` \| `ogc-features` or none | none | |
| `map.providers.endpoint` | str or none | none | An OGC service's base address (with service), never a tile URL |
| `map.providers.layer` | str or none | none | The service's layer to show |
| `map.providers.tile_matrix_set` | str or none | none | WMTS: the tile matrix set |
| `map.providers.format` | str or none | none | WMTS: the tile image format |
| `map.providers.wmts_style` | str or none | none | WMTS: the service's STYLE |
| `map.providers.zoom_min` | int or none | none | The lowest zoom the provider serves |
| `map.providers.zoom_max` | int or none | none | The highest zoom the provider serves |
| `map.providers.profile` | str or none | none | A ready-made provider (providers/<profile>.yaml) to use |
| `map.providers.variables` | mapping | — | Values the profile's addresses are filled with |
| `map.providers.credential` | str or none | none | The provider's key, as env:VARIABLE — a name, never the key itself |
| `map.providers.credential_param` | str or none | none | WMTS: the query parameter the provider's key goes in |
| `map.providers.proxy` | `required` \| `recommended` \| `none` | `none` | Whether tiles are fetched through the Conduit (which caches them and keeps the key on the server) rather than by the browser |
| `map.providers.cache` | section or none | none | Keeping fetched tiles a while (online providers only). |
| `map.providers.cache.ttl_days` | int | required | How long a fetched tile is kept, in days |
| `map.providers.cache.prefetch_areas` | list of str | — | Areas whose tiles are fetched ahead of use |
| `map.providers.style` | str or none | none | The map style: bundled:osprey-dark, bundled:osprey-light, or the profile's own |
| `map.providers.attribution` | str | required | The credit shown on the map, as the licence asks |

| Option | Value | Default | What it does |
|---|---|---|---|
| `reporting` | section | — | Dashboards for the business: report sync and Superset. |
| `reporting.sync` | bool | false | Run report-sync |
| `reporting.sync_interval_seconds` | int | `900` | How often each case is pulled into the mart, in seconds. |
| `reporting.sync_memory` | str | `256m` | Report sync's memory limit. |
| `reporting.superset` | bool | false | Run Superset |
| `reporting.superset_memory` | str | `2g` | Superset's memory limit. |
| `monitoring` | section | — | Monitoring and alerts: whom a new hotlist's alerts reach, and who changes it. |
| `monitoring.hotlist_audience` | `only_me` \| `team` | `only_me` | Whom a new hotlist's alerts reach: its owner alone (only_me), or also the owner's team, the people of the owner's organisational unit (team). Applies to hotlists made after it is set, never to an existing one. |
| `monitoring.hotlist_audience_editable` | bool | true | Whether a hotlist's owner may choose its audience, when making it or later. When false, every new hotlist takes hotlist_audience and a change is refused. |
| `connectors` | section | — | The Studio's SQL and API connectors: the private hosts an operator admits them to. |
| `connectors.private_hosts` | list of str | — | The private hosts a SQL or API connection may reach: each a host name in full (nomis-replica.client.internal) or a network inside 10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16, 100.64.0.0/10 or fc00::/7 (10.20.0.0/16) that a connection's host name resolves into. Everything else inside a network stays refused. Never admitted, whatever is listed: this machine, a cloud's metadata services (169.254.0.0/16, fd00:ec2::/32, 100.100.0.0/16), Docker's and the cluster's own names, and any address in the Conduit's own networks or the deployment's own services'. A host must still be on the egress allow-list. |
| `connectors.secrets` | list of str | — | The name of each SQL or API connection's secret (NOMIS_REPLICA for OSPREY_CONNECTION_SECRET_NOMIS_REPLICA in deployment.env). Only the Conduit is given a declared secret, every other service having it blanked, and a connection whose secret is not declared reads nothing. |
| `mail` | section or none | none | A mail server, for invitations and password resets by email. |
| `mail.host` | str | required | The mail server's name |
| `mail.port` | int | `587` | The mail server's port. |
| `mail.from_address` | str | required | The address invitations come from |
| `mail.starttls` | bool | true | Whether mail is sent over TLS (STARTTLS). |
| `mail.username` | str or none | none | A relay that takes mail without signing in. With one, the password comes from OSPREY_SMTP_PASSWORD at install. |
| `welcome` | section | — | The welcome page before sign-in: its About section and footer links. |
| `welcome.about` | bool | true | Off for an internal-only deployment. |
| `welcome.account_help` | str or none | none | Where people get help with their account. |
| `welcome.accessibility` | str or none | none | The organisation's accessibility statement. |
| `welcome.privacy` | str or none | none | The organisation's privacy notice. |
| `welcome.service_status` | str or none | none | A page saying whether the service is up. |
| `deployment` | section | — | Which deployment this is, on a machine that runs more than one. |
| `deployment.name` | str or none | none | Names this deployment's Compose project, its volumes and its rendered folder, so a second deployment on the same machine shares none of them. |

| Option | Value | Default | What it does |
|---|---|---|---|
| `deployment.graph_port` | int or none | none | The port on this machine (127.0.0.1 only) the graph store's own tools reach it at. A deployment installed beside another with ospreyflow install --name is given one of its own, so the two share no port. |
| `deployment.highest_marking` | str or none | none | The highest marking this deployment may hold: a load or an import marked above it is refused before anything is written, in words that say this limit and never the item's content. A demo pack that declares no highest marking is judged as the scheme's highest, so under a lower setting it is refused. One of the handling scheme's classifications. Left unset, it is the scheme's highest, or OFFICIAL-SENSITIVE on the cloud-platform profile. |
| `appearance` | section | — | How every page looks: the deployment's brand, and what its page title names. |
| `appearance.brand` | `ospreyflow` \| `govuk` | `ospreyflow` | The GOV.UK look, for a service on a gov.uk domain only. |
| `appearance.service_name` | str or none | none | The service's name, in the page title. |
| `appearance.organisation` | str or none | none | The organisation in the GOV.UK footer and the page title. |
| `appearance.phase` | `alpha` \| `beta` \| `live` \| `none` | `none` | The phase banner shows at alpha or beta. |
| `appearance.banner_text` | str or none | none | The banner's own words, in place of "This is a new service.", in the Glass and on the sign-in page: after the phase's tag at alpha or beta, alone at live or none. One line of at most 200 characters. |
| `grading` | section | — | The scheme every drawn node and link is graded in (ADR-143 decision 11); changed only by `ospreyflow grading change`. |
| `grading.scheme` | str | `5x5x5` | The scheme drawn items are graded in: 5x5x5; 3x5x2, whose handling code (P or C) is part of the grade and never merged with the marking; or the path of a scheme file (.yaml, beside this file unless absolute) naming its own scheme and each part's grades. |
| `external` | section | — | What a cloud runs for the deployment instead of a container (Small). |
| `external.postgres` | section or none | none | A cloud's managed PostgreSQL; its password arrives at install. |
| `external.postgres.host` | str | required | The managed server's address |
| `external.postgres.port` | int | `5432` | Its port |
| `external.postgres.database` | str | `ospreyflow` | The deployment's database on it |
| `external.postgres.user` | str | `osprey` | The login, which needs CREATEROLE and CREATEDB there |
| `external.postgres.sslmode` | `require` \| `verify-ca` \| `verify-full` | `require` | A managed server is reached over TLS. |
| `external.object_store` | section or none | none | A cloud's S3, for every S3-protocol store (AWS). |
| `external.object_store.endpoint` | str | required | Host and port, no scheme: always HTTPS |
| `external.object_store.region` | str | required | The region the buckets live in |
| `external.object_store.credentials` | `instance` \| `keys` | `instance` | The server's own cloud identity, no key anywhere; `keys` reads OSPREY_S3_ACCESS_KEY and OSPREY_S3_SECRET_KEY at apply. |
| `external.object_store.bucket_prefix` | str | `ospreyflow-` | Each bucket is <prefix><name>, as OpenTofu made them |
| `external.media` | section or none | none | Media on Azure Blob; its key arrives at install. |
| `external.media.blob_account` | str | required | The Blob storage account |
| `external.media.blob_container` | str | `media` | The container media is kept in |
| `external.valkey` | section or none | none | A cloud's managed Valkey or Redis (cluster only). |
| `external.valkey.host` | str | required | The managed cache's address |
| `external.valkey.port` | int | `6379` | Its port |
| `external.valkey.tls` | bool | true | Whether it is reached over TLS |
| `external.search` | section or none | none | A cloud's managed OpenSearch (cluster on AWS only). |

| Option | Value | Default | What it does |
|---|---|---|---|
| `external.search.url` | str | required | The domain's HTTPS address |
| `resources` | section | — | Small on a server of your own: the stores sized to the server's memory (section 5a.2); and, on Lite or such a Small on Linux, the local engine on an NVIDIA GPU (section 5a.4). |
| `resources.memory_gib` | int or none | none | The memory the stores are sized to, in GiB (as Docker reports it). Default: none — the stores keep their fixed sizes. |
| `resources.graph_heap_gib` | int or none | none | Overrides the graph store's heap (-Xmx), in GiB; at most 31. |
| `resources.search_heap_gib` | float or none | none | Overrides OpenSearch's heap (-Xms and -Xmx), in GiB. |
| `resources.postgres_shared_buffers_gib` | float or none | none | Overrides PostgreSQL's shared_buffers, in GiB. |
| `resources.gpu` | `none` \| `nvidia` | `none` | The local engine runs on the CPU. nvidia: the ollama service reserves every NVIDIA GPU, and the extraction model is qwen2.5:14b-instruct unless models.extraction names one. The NVIDIA driver and Container Toolkit are the administrator's to install. |